MANUAL DEL SISTEMA
ARQUITECTURA, CÓDIGO Y OPERACIÓN

Proyecto: Sistema de Gestión Web para KineFit Chile

Fecha de emisión:

25 de Octubre de 2026

Índice General

Índice General 1
Introducción 4
I. Visión General del Sistema 6
1.1 Propósito y Alcance Técnico 6
1.2 Objetivos de Calidad 6
1.3 Stakeholders 7
1.4 Contexto del Sistema 7
II. Arquitectura de la Solución 8
2.1 Estrategia de Solución 8
2.2 Contenedores 8
2.3 Backend por Capas 10
2.3.1 Capa Api 12
2.3.2 Capa Application 12
2.3.3 Capa Domain 13
2.3.4 Capa Infrastructure 13
2.3.5 Canalización de Peticiones 13
2.4 Frontend 14
2.4.1 Enrutamiento 16
2.4.2 Servicios, Datos y Estado 16
2.4.3 Sesión del Panel y Protección de Rutas 17
2.5 Modelo de Dominio 17
2.6 Máquina de Estados de la Cita 18
2.7 Inventario de Controladores 20
2.8 Decisiones de Arquitectura 22
III. Modelo de Datos 24
3.1 Convenciones del Esquema 24
3.2 Vista General del Modelo 24
3.3 Diccionario de Datos 25
3.3.1 Agenda y Reservas 26
3.3.2 Personas y Catálogo 34
3.3.3 Documentos Clínicos 39
3.3.4 Ventas y Finanzas 45
3.3.5 Sitio Público y Configuración 49
3.3.6 Auditoría 55
3.4 Enumeraciones 56
3.5 Índices y Reglas de Negocio en la Base 58
3.6 Migraciones 59
IV. Flujos Críticos 60
4.1 Reserva Web 60
4.2 Pago con Webpay Plus 61

4.3 Reserva Manual 64
4.4 Generación de Agenda 66
4.5 Consentimientos y Firma Pública 68
4.6 Notificaciones por Correo 71
4.7 Sesión del Personal 73
4.8 Inicio de Sesión del Paciente 73
4.9 Venta y Reparto 75
V. Seguridad 78
5.1 Autenticación, Roles y Políticas 78
5.2 Controles OWASP ASVS 4.0.3, Nivel 1 79
5.3 Protección de los Documentos Clínicos 81
5.4 Secretos y Configuración Sensible 81
5.5 Auditoría y Trazabilidad 82
VI. Infraestructura, Despliegue y Servicios Externos 84
6.1 Vista de Despliegue 84
6.2 Servidor 85
6.3 Contenedores, Redes y Volúmenes 85
6.4 Publicación Web, Dominios y Certificados 86
6.5 Integración y Entrega Continua 87
6.6 Configuración por Entorno 89
6.7 Servicios Externos 91
6.7.1 Transbank Webpay Plus 91
6.7.2 Google Identity 91
6.7.3 Google Places 91
6.7.4 Resend 91
6.7.5 Cloudinary 91
6.7.6 Cloudflare R2 92
6.7.7 GitHub y GitHub Container Registry 92
6.7.8 Hetzner Cloud 92
6.8 Entorno de Desarrollo Local 92
VII. Operación y Continuidad del Servicio 94
7.1 Procesos en Segundo Plano 94
7.2 Respaldo y Verificación 94
7.3 Plan de Recuperación ante Desastres 96
7.4 Runbook de Incidentes 98
7.5 Gestión de Cambios y Reversión 99
VIII. Calidad, Evolución y Mantenimiento 100
8.1 Pruebas Automatizadas del Backend 100
8.2 Calidad del Frontend 101
8.3 Plan de Hardening y Evolución Continua 101
8.4 Plan de Contingencia 102
8.5 Inventario de Dependencias y Licencias 103

Glosario 106
Referencias Normativas 108

Introducción

Este manual describe el Sistema de Gestión Web de KineFit Chile desde el punto de vista de su construcción: la arquitectura, el código del backend y del frontend, el modelo de datos, los flujos críticos, la seguridad, el despliegue en el servidor y la operación diaria.

El manual cubre los dos repositorios del proyecto, kinefit-backend y kinefit-frontend, y la infraestructura sobre la que corren. El uso del Panel de Administración se explica en el Manual de Usuario, que es el complemento de este documento.

Este manual está dirigido a programadores y a quien administre el servidor. Supone conocimientos de C# y .NET, de TypeScript y React, de SQL y PostgreSQL, y del uso básico de Docker, nginx y Git. No reemplaza la lectura del código: explica cómo están organizadas sus piezas, por qué están así y dónde buscar cada cosa.

El manual avanza de lo general a lo particular. El capítulo I presenta el sistema y su contexto. El capítulo II describe la arquitectura del backend y del frontend. El capítulo III documenta el modelo de datos tabla por tabla. El capítulo IV recorre los flujos críticos con diagramas de actividad. El capítulo V reúne los controles de seguridad. El capítulo VI explica la infraestructura, el despliegue y los servicios externos. El capítulo VII cubre la operación: procesos en segundo plano, respaldos, recuperación ante desastres e incidentes. El capítulo VIII trata la calidad, la evolución planificada y el inventario de dependencias.

Al final se incluyen un glosario, las referencias normativas y un anexo que relaciona cada figura con su archivo fuente.

Las convenciones de este manual son las siguientes:

- Los nombres de clases, tablas, columnas, rutas, variables de configuración y comandos se escriben tal como aparecen en el código.
- Las rutas de la API se indican con su verbo HTTP, por ejemplo POST /api/citas. Los parámetros de ruta se escriben entre llaves, por ejemplo /api/citas/{id}.
- Las claves de configuración se escriben con dos puntos, por ejemplo Webpay:MontoAnticipo. Como variable de entorno, los dos puntos se reemplazan por doble guion bajo: Webpay__MontoAnticipo.
- Los comandos se muestran en letra monoespaciada. Los valores entre signos menor y mayor, como <usuario>, se reemplazan por el valor real, que nunca se escribe en este documento.

- Las marcas de tiempo se guardan en UTC. Las fechas y horas de la agenda representan la hora local del centro, y toda regla que compara con el momento actual lo convierte a la zona horaria America/Santiago.
- Cada figura se identifica con el número del capítulo en romanos y un correlativo, por ejemplo Figura IV.2. Las figuras extensas se dividen en partes que conservan el mismo número. Las fuentes de cada figura se entregan en formato Mermaid y PlantUML.

Nota: Este manual no contiene credenciales, contraseñas, claves de API ni direcciones IP. Las variables que las contienen se nombran por su clave y se explica su propósito; sus valores se administran fuera del repositorio.

I. Visión General del Sistema

1.1 Propósito y Alcance Técnico

El sistema permite que los pacientes de KineFit Chile reserven atenciones desde el sitio web y paguen un anticipo en línea, y que el personal del centro administre la agenda, los pacientes, los documentos clínicos, las ventas y el contenido del sitio desde un Panel de Administración.

Técnicamente se compone de:

- **Backend:** una API REST en .NET 10 que concentra las reglas de negocio, la seguridad y el acceso a datos;
- **Frontend:** una aplicación Next.js 16 que sirve el sitio público, el panel y la página pública de firma de documentos;
- **Persistencia:** una base PostgreSQL 16 y un volumen de archivos para los adjuntos clínicos;
- **Infraestructura:** un servidor virtual en Hetzner Cloud con nginx y Docker, desplegado automáticamente desde GitHub Actions.

1.2 Objetivos de Calidad

Las decisiones de diseño descritas en este manual responden a cinco objetivos de calidad, ordenados por prioridad:

Objetivo	Qué significa en KineFit	Cómo lo logra el sistema
Integridad de la agenda	Un bloque horario nunca queda reservado por dos pacientes.	Índice único sobre la ocupación de bloques, transacciones de base de datos y una única definición de bloques consecutivos.
Confiabilidad del cobro	Un pago no se pierde ni se aplica dos veces.	Reclamo atómico de la transacción, confirmación idempotente y expiración automática.
Confidencialidad clínica	La información clínica solo la ve el personal autorizado.	Políticas por rol, acotamiento por especialista, archivos con nombre opaco fuera de la base y enlaces de firma de un solo uso.
Trazabilidad	Todo cambio relevante queda registrado con su autor.	Interceptor de auditoría inmutable sobre las transiciones de cita y 27 entidades.
Mantenibilidad	El sistema se puede cambiar sin romper lo existente.	Capas separadas, contrato tipado en el frontend y pruebas de extremo a extremo sobre PostgreSQL real.

1.3 Stakeholders

Stakeholders	Interés principal en la arquitectura
Pacientes	Reservar y pagar sin fricción; que sus datos estén protegidos.
Administración del centro	Operar la agenda, las ventas y el sitio; que los cobros y repartos sean correctos.
Especialistas	Gestionar sus citas y documentos clínicos sin ver recursos ajenos.
Equipo de desarrollo y mantención	Entender, modificar, desplegar y recuperar el sistema.

1.4 Contexto del Sistema

La Figura I.1 muestra el sistema como una sola caja, sus tres tipos de usuario y los sistemas externos con que se comunica. Cada servicio externo se describe en detalle en la sección 6.7.

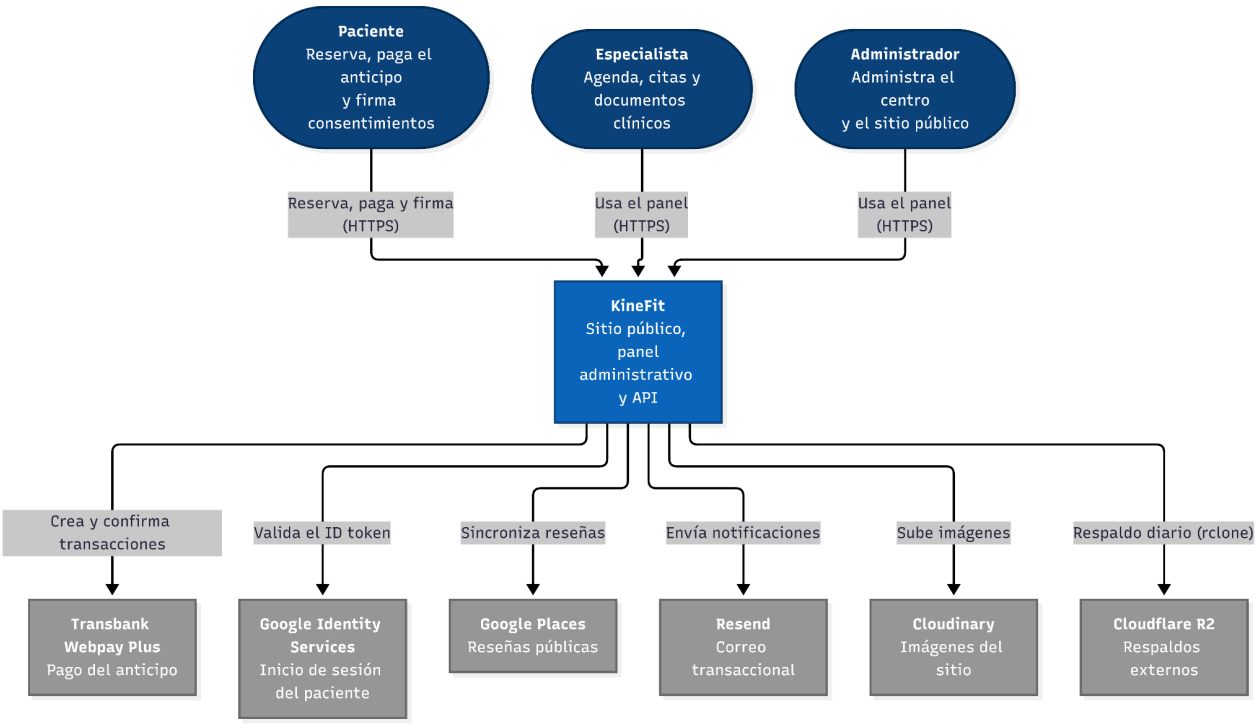


Figura I.1 Diagrama de contexto del sistema (C4, nivel 1)

El paciente usa el sitio público para reservar, pagar y firmar documentos. La administración y los especialistas usan el Panel de Administración. El sistema delega el cobro en Transbank, la identidad del paciente en Google, el correo en Resend, las imágenes del sitio en Cloudinary y los respaldos en Cloudflare R2.

II. Arquitectura de la Solución

2.1 Estrategia de Solución

La solución separa la presentación de las reglas de negocio. El frontend no contiene reglas que decidan sobre datos: toda validación que importa se repite o se realiza en la API, y la API nunca confía en valores que el cliente pueda manipular, como el monto del anticipo, el total de una venta o la especialista asociada a una sesión.

Las reglas más delicadas se concentran en piezas pequeñas y únicas: una máquina de estados para las citas, una definición de bloques consecutivos, un cálculo de reparto y una conversión de zona horaria. Cuando la concurrencia puede romper una regla, la última barrera la pone la base de datos, mediante índices únicos y actualizaciones condicionadas, y no una comprobación previa en memoria.

El sistema se despliega como contenedores Docker en un servidor propio. Las migraciones de la base se aplican al arrancar la API, y los procesos periódicos, como la expiración de pagos, la agenda y los correos, se ejecutan dentro del mismo proceso de la API.

2.2 Contenedores

La Figura II.1 descompone el sistema en sus unidades desplegables.

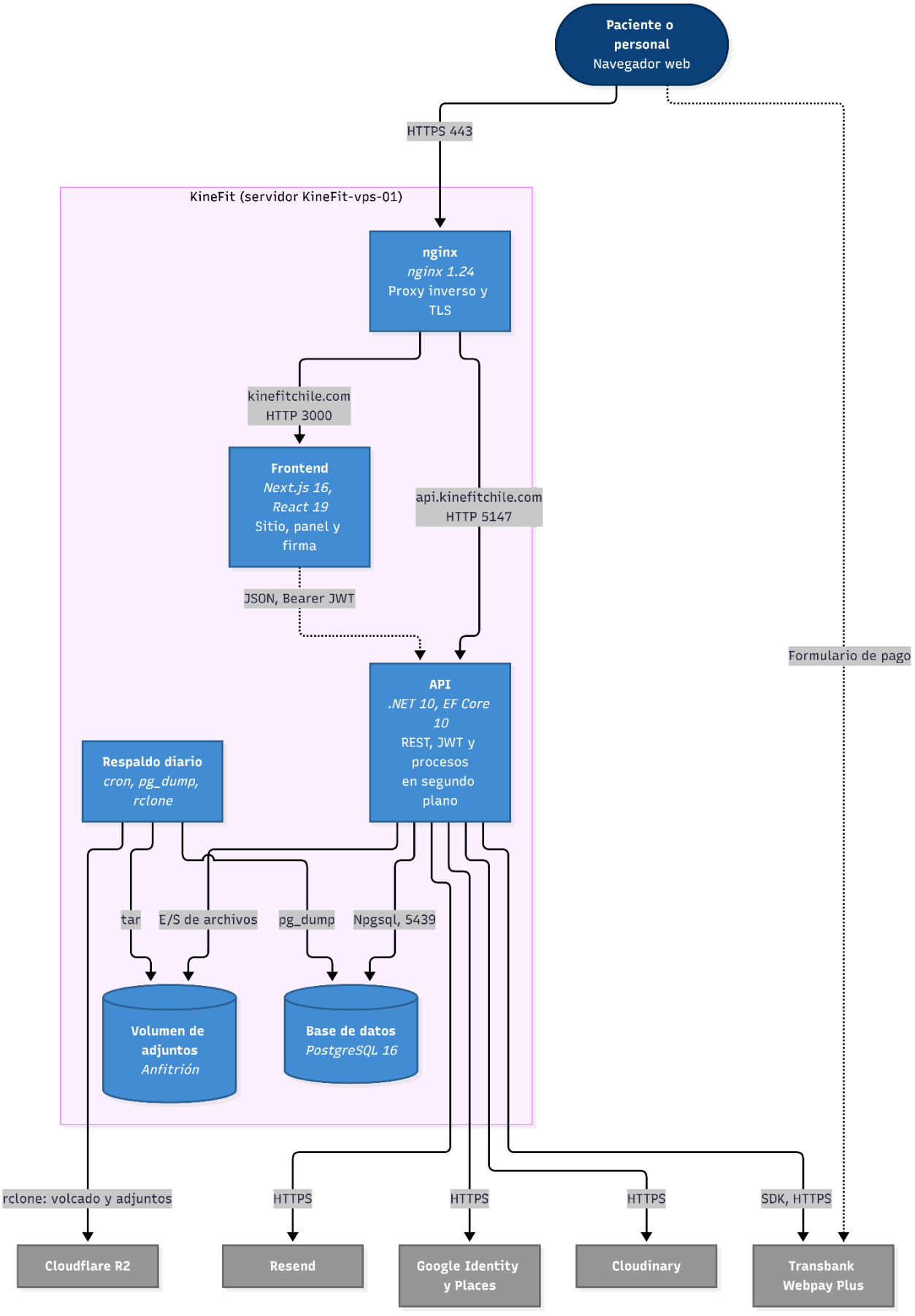


Figura II.1 Diagrama de contenedores (C4, nivel 2)

Contenedor	Tecnología	Responsabilidad
nginx	nginx 1.24 en el anfitrión	Termina TLS y reenvía cada dominio al contenedor que corresponde.
Frontend	Next.js 16.2.9, React 19.2.4, TypeScript 5, Tailwind CSS 4	Sitio público, Panel de Administración y firma pública de documentos.
API	.NET 10, ASP.NET Core, Entity Framework Core 10, Npgsql	Reglas de negocio, autenticación, autorización, acceso a datos, integraciones y procesos en segundo plano.
Base de datos	PostgreSQL 16	Persistencia de todas las entidades del sistema.
Volumen de adjuntos	Directorio del anfitrión montado en la API	Archivos clínicos, PDF firmados, escaneos y plantillas en PDF.
Respaldo diario	Bash, cron, pg_dump, tar y rclone	Copia diaria de la base y de los adjuntos en Cloudflare R2.

2.3 Backend por Capas

El backend es un solo proyecto ASP.NET Core, reserva-citas-api, con espacio de nombres raíz reserva_citas_api. El código está en api-dotnet/src y se organiza en cuatro capas. La Figura II.2 muestra sus componentes y dependencias.

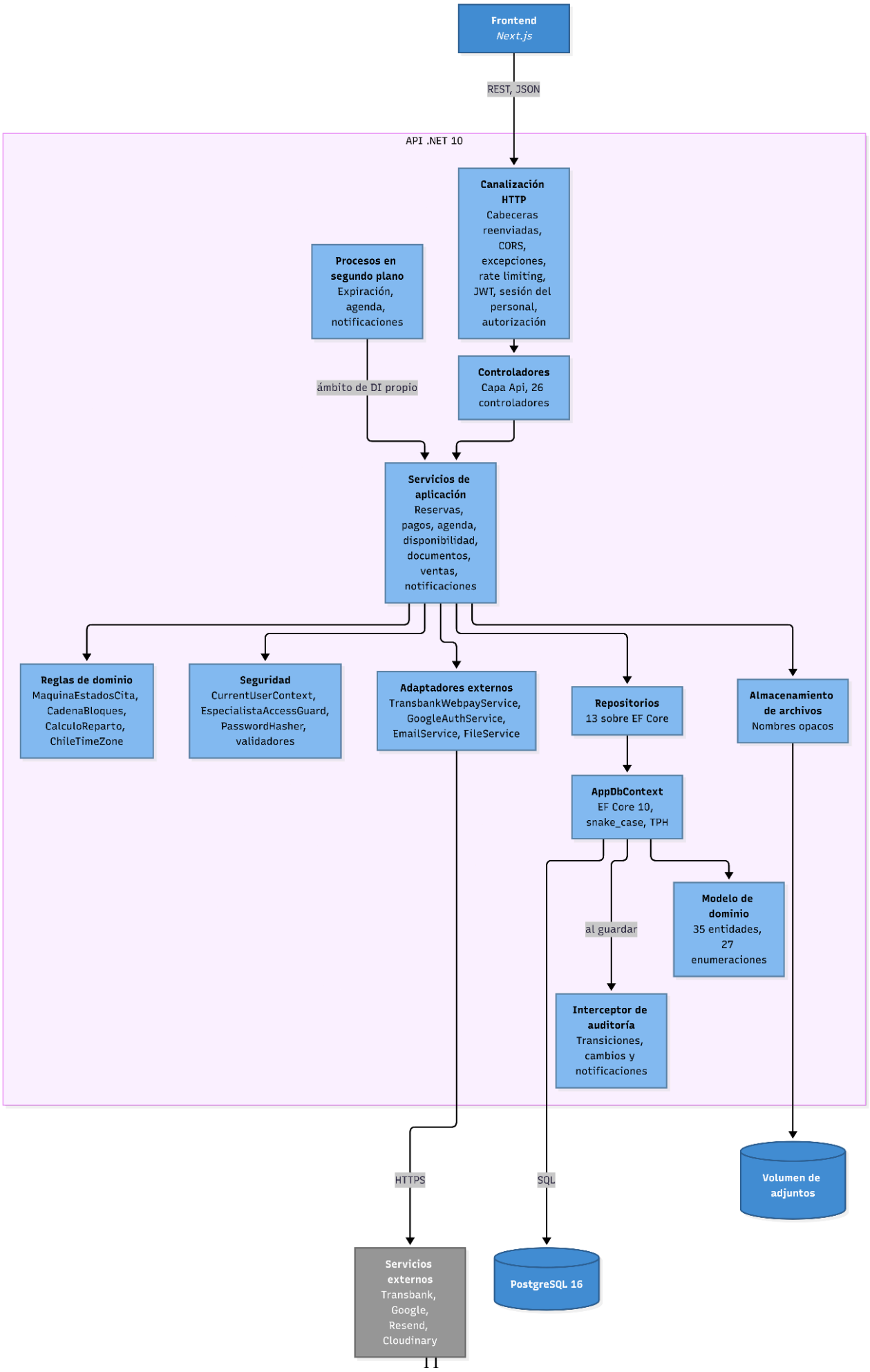

Frontend
Next.js
REST, JSON
API .NET 10
Canalización HTTP
Cabeceras reenviadas, CORS, excepciones, rate limiting, JWT, sesión del personal, autorización
Procesos en segundo plano
Expiración, agenda, notificaciones
ámbito de DI propio
Controladores
Capa Api, 26 controladores
Servicios de aplicación
Reservas, pagos, agenda, disponibilidad, documentos, ventas, notificaciones
Reglas de dominio
MaquinaEstadosCita, CadenaBloques, CalculoReparto, ChileTimeZone
Seguridad
CurrentUserContext, EspecialistaAccessGuard, PasswordHasher, validadores
Adaptadores externos
TransbankWebpayService, GoogleAuthService, EmailService, FileService
Repositorios
13 sobre EF Core
Almacenamiento de archivos
Nombres opacos
AppDbContext
EF Core 10, snake_case, TPH
Modelo de dominio
35 entidades, 27 enumeraciones
al guardar
Interceptor de auditoría
Transiciones, cambios y notificaciones
HTTPS
SQL
Volumen de adjuntos
Servicios externos
Transbank, Google, Resend, Cloudinary
PostgreSQL 16

Figura II.2 Diagrama de componentes del backend (C4, nivel 3)

2.3.1 Capa Api

Contiene los controladores y los middlewares. Los controladores heredan de BaseController, reciben la petición, declaran su política de acceso con el atributo Authorize y delegan en un servicio de la capa Application. No contienen reglas de negocio. Los 26 controladores y sus rutas se inventarían en la sección 2.7.

Hay dos middlewares propios. ExceptionHandlingMiddleware traduce las excepciones a respuestas con el formato ErrorDetail (status, error, message y timestamp) y convierte las violaciones de índices únicos de PostgreSQL en respuestas 409 con un mensaje por restricción. ValidacionSesionPersonalMiddleware revoca en tiempo real los tokens del personal, como se explica en la sección 4.7.

Excepción	**Respuesta**
KeyNotFoundException	404 NOT_FOUND
InvalidOperationException	409 CONFLICT
ArgumentException, BadHttpRequestException, FormatException	400 BAD_REQUEST
UnauthorizedAccessException	401 UNAUTHORIZED
ForbiddenException	403 con el código propio de la excepción
UnprocessableException	422 con el código propio de la excepción
BadGatewayException	502 BAD_GATEWAY
DbUpdateException por violación de unicidad	409 CONFLICT con mensaje según el índice
Cualquier otra	500 INTERNAL_ERROR

2.3.2 Capa Application

Contiene los casos de uso. Cada servicio expone una interfaz en Services/Interfaces y su implementación en Services/Implements, y se registra en el contenedor de inyección de dependencias de Program.cs. Los servicios devuelven un GenericResponse con los datos y un mensaje.

Junto a los servicios viven cuatro clases estáticas que concentran reglas que no deben existir en más de un lugar:

- **MaquinaEstadosCita:** tabla declarativa de las ocho transiciones de estado permitidas para una cita.
- **CadenaBloques:** única definición de bloques consecutivos y cálculo de horas de inicio viables.
- **CalculoReparto:** cálculo del IVA, la comisión del terminal y el reparto entre la profesional y el centro.
- **ChileTimeZone:** conversión entre UTC y la hora de Chile según las reglas de la zona America/Santiago.

La carpeta Security agrupa el contexto del usuario actual (CurrentUserContext), la guarda de acceso por especialista (EspecialistaAccessGuard), los nombres de claims y de políticas y el contexto que transporta el motivo de un cambio hasta la auditoría. La carpeta Validators contiene el hash de contraseñas y los validadores de RUT, teléfono y tipo de archivo. Los DTO de entrada y salida están en DTOs, organizados por dominio, y la plantilla HTML de los correos en Templates/Email.

2.3.3 Capa Domain

Contiene las 35 entidades y las 27 enumeraciones del dominio. Las entidades son clases simples, sin lógica, que Entity Framework Core mapea a tablas. El modelo de dominio se describe en la sección 2.5 y el de datos en el capítulo III.

2.3.4 Capa Infrastructure

Contiene el acceso a datos y los servicios técnicos:

- **Data:** AppDbContext, la fábrica usada por las herramientas de diseño, el sembrador inicial y las 67 migraciones.
- **Repositories:** 13 repositorios con sus interfaces, para las consultas que se reutilizan.
- **BackgroundServices:** los tres procesos periódicos, descritos en la sección 7.1.
- **Interceptors:** AuditingSaveChangesInterceptor, que audita y encola notificaciones al guardar.
- **Storage:** AlmacenamientoArchivosLocalService, que guarda los archivos en la ruta Adjuntos:RutaBase.

2.3.5 Canalización de Peticiones

Program.cs registra los middlewares en el siguiente orden. El orden importa: las cabeceras reenviadas deben procesarse antes del límite de peticiones, y la validación de sesión del personal después de la autenticación y antes de la autorización.

Orden	Middleware	Función
1	UseForwardedHeaders	Toma la IP y el protocolo del cliente desde las cabeceras de nginx, solo si la petición viene de un proxy confiable.
2	Swagger	Documentación interactiva de la API, solo en el entorno Development.
3	UseRouting	Resuelve el controlador y la acción.
4	UseCors	Aplica la política AllowedEcosystem con los orígenes permitidos.
5	ExceptionHandlingMiddleware	Convierte las excepciones en respuestas ErrorDetail.
6	UseRateLimiter	Aplica los límites DocumentosPublicos y AuthPersonal.
7	UseAuthentication	Valida el JWT.
8	ValidacionSesionPersonalMiddleware	Rechaza tokens del personal revocados.
9	UseAuthorization	Aplica las políticas de acceso.
10	MapControllers	Ejecuta el controlador.

Antes de construir la aplicación, Program.cs registra además el origen de datos de Npgsql con las enumeraciones nativas, el DbContext con la convención snake_case y el interceptor de auditoría, el límite de 30 MB para el cuerpo de las peticiones en Kestrel, el cliente de Resend, la implementación de Webpay según Webpay:Provider y los tres procesos en segundo plano. Si falta la cadena de conexión o la clave de firma JWT, la aplicación no arranca y el mensaje indica cuál falta y cómo entregarla.

2.4 Frontend

El frontend es una aplicación Next.js con App Router. Su código está en src y separa el enrutamiento de las pantallas, la comunicación con la API y el estado. La Figura II.3 muestra sus componentes.

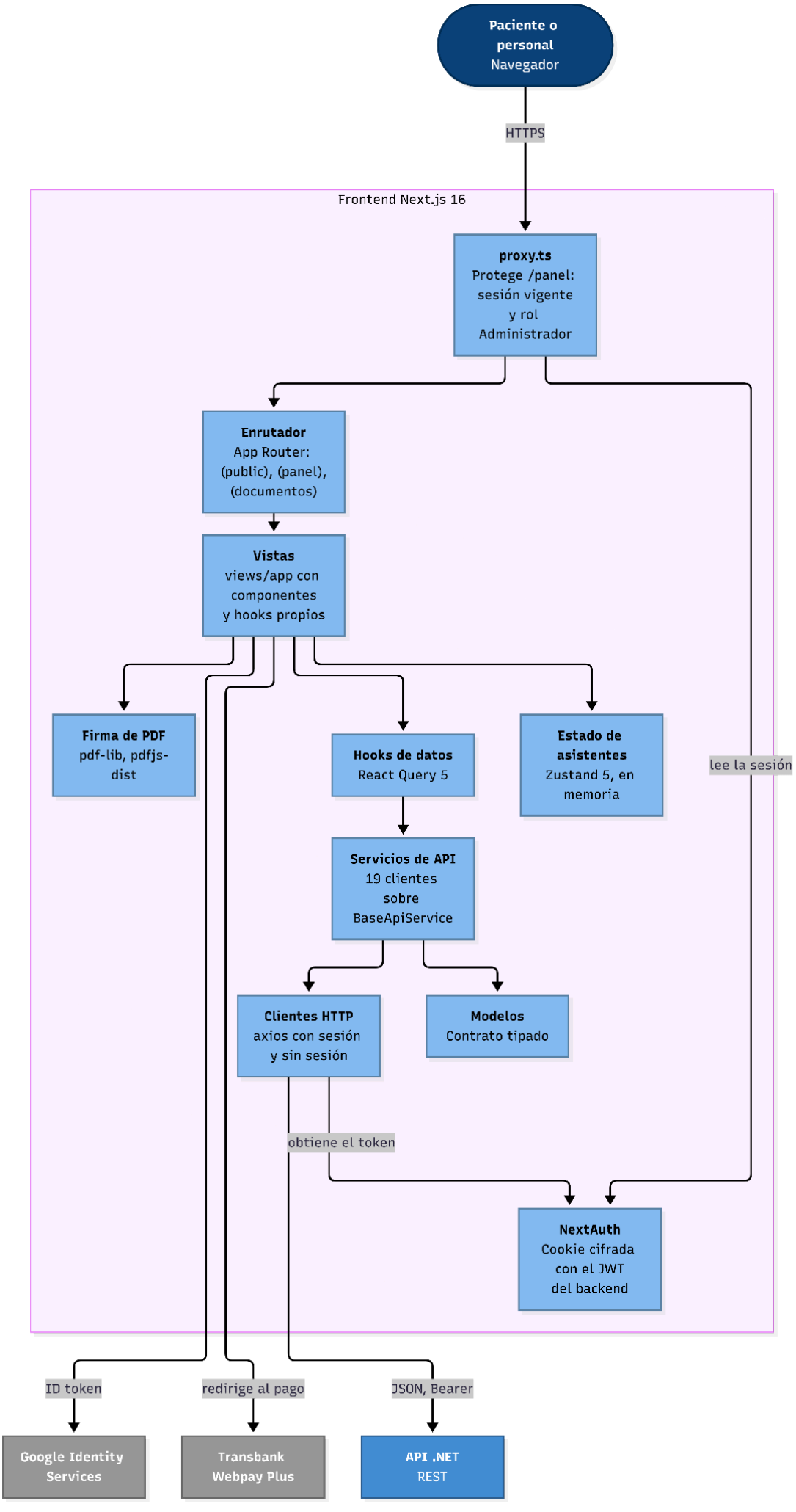

Paciente o personal
Navegador
HTTPS
Frontend Next.js 16
proxy.ts
Protege /panel: sesión vigente y rol Administrador
Enrutador
App Router: (public), (panel), (documentos)
Vistas
views/app con componentes y hooks propios
Firma de PDF
pdf-lib, pdfjs-dist
Hooks de datos
React Query 5
Estado de asistentes
Zustand 5, en memoria
lee la sesión
Servicios de API
19 clientes sobre BaseApiService
Clientes HTTP
axios con sesión y sin sesión
Modelos
Contrato tipado
obtiene el token
NextAuth
Cookie cifrada con el JWT del backend
ID token
redirige al pago
JSON, Bearer
Google Identity Services
Transbank Webpay Plus
API .NET
REST

Figura II.3 Diagrama de componentes del frontend (C4, nivel 3)

2.4.1 Enrutamiento

La carpeta app solo enruta: cada page.tsx importa una vista y la devuelve. Las rutas se agrupan en tres grupos:

Grupo	Rutas	Contenido
(public)	/, /confirmacion, /pago/confirmar, /politica-de-privacidad	Sitio público con la tarjeta de reserva, retorno de Webpay y política de privacidad.
(panel)	/panel/acceso y /panel/... dentro del subgrupo (shell)	Panel de Administración: agenda, nueva reserva, pacientes, documentos, ventas y configuración.
(documentos)	/documentos/[token]	Firma pública de un consentimiento a partir del enlace.

Además, app/api/auth/[...nextauth] expone los manejadores de NextAuth y app/api/revalidate regenera la portada después de cambios de contenido. Las pantallas reales viven en views/app, cada una con sus carpetas components y hooks.

Los detalles que se abren como ventana dentro de una pantalla se controlan con parámetros de la URL: fecha, cita y cancelar en la agenda, documento en Documentos, paciente en Pacientes y tab en Configuración. Esos parámetros se cambian con window.history.pushState o window.history.replaceState, que Next.js sincroniza con useSearchParams, y no con router.push. Las navegaciones a otra ruta siguen usando router.push.

2.4.2 Servicios, Datos y Estado

La comunicación con la API sigue tres niveles:

- **Servicios:** 19 clases en services, una por dominio, que heredan de BaseApiService y conocen las rutas de la API. Los tipos de petición y respuesta están en models.
- **Hooks de datos:** un hook de React Query por servicio en hooks/api. React Query mantiene la caché, no reintenta los errores 4xx salvo el 408, reintenta hasta tres veces los 5xx y los errores de red, y vuelve a consultar al recuperar el foco de la ventana.
- **Clientes HTTP:** dos instancias de axios con la URL base NEXT_PUBLIC_API_URL y 10 segundos de espera. axiosInstance agrega el token del panel desde la sesión de NextAuth. axiosInstanceSinSesion se usa en los flujos públicos, donde el token del paciente se entrega de forma explícita.

El estado de los asistentes se guarda en tres stores de Zustand en memoria: useBookingStore para la reserva pública, useNuevaReservaStore para la reserva desde el panel y useNuevaFichaStore para la creación de fichas. No se persisten: una recarga de la página reinicia el asistente y descarta el token del paciente.

lib/api.ts traduce los errores de la API a mensajes para la interfaz: distingue los errores de validación automática de ASP.NET de las excepciones de negocio con formato ErrorDetail y marca como reintentables los errores 5xx.

La agenda del panel se dibuja exclusivamente con los bloques que devuelve GET /api/agenda: agrupa en una tarjeta los bloques seguidos de una misma cita y en una sola fila los bloqueados contiguos. El frontend no tiene horarios propios: el horario del centro y la plantilla de cada especialista, que viven en el backend, determinan qué se muestra. El formulario de bloqueos pide las horas con campos de hora y el backend aplica el bloqueo a los bloques que se cruzan con el rango.

2.4.3 Sesión del Panel y Protección de Rutas

El panel usa NextAuth 5 con el proveedor Credentials. El navegador inicia sesión contra la API, recibe el JWT y lo entrega a NextAuth, que lo guarda dentro de su cookie de sesión cifrada con AUTH_SECRET y con una duración máxima de 24 horas. El middleware proxy.ts protege las rutas /panel: sin sesión vigente redirige a /panel/acceso, y reserva las rutas /panel/especialistas, /panel/landing y /panel/reportes al rol Administrador. Las páginas /panel/reportes y /panel/perfil existen, pero no tienen enlace en el menú: el módulo de reportes quedó fuera de la entrega.

proxy.ts es un control de navegación: evita mostrar pantallas que el usuario no puede usar. El control de acceso efectivo lo ejerce la API, que valida el JWT y aplica las políticas en cada petición.

2.5 Modelo de Dominio

La Figura II.4 muestra las entidades centrales y sus relaciones. El resto de las entidades, de configuración, contenido y auditoría, aparece en los diagramas entidad relación del capítulo III.

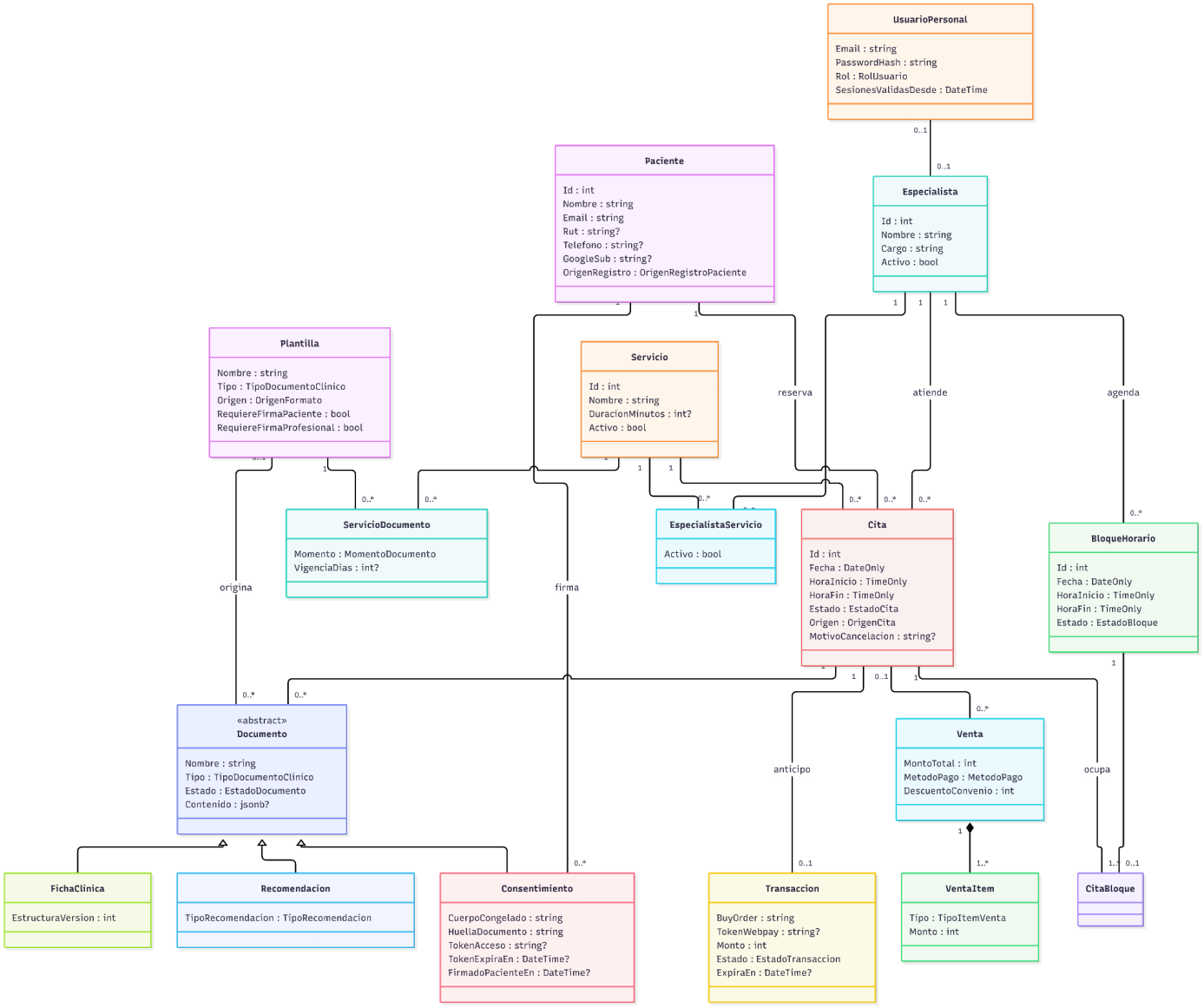


Figura II.4 Diagrama de clases del núcleo del dominio

Una Cita pertenece a un Paciente, a una Especialista y a un Servicio, y ocupa uno o más BloqueHorario a través de CitaBloque. Una cita web tiene como máximo una Transaccion de anticipo. Los documentos clínicos comparten la clase abstracta Documento y se especializan en FichaClinica, Recomendacion y Consentimiento. Plantilla define el contenido de un documento y ServicioDocumento indica qué plantillas exige cada servicio. UsuarioPersonal representa una cuenta del panel y se vincula opcionalmente con una Especialista. Venta registra un cobro y se compone de VentaItem.

2.6 Máquina de Estados de la Cita

MaquinaEstadosCita declara las transiciones permitidas. Una transición que no está en la tabla no se permite, sin necesidad de condiciones adicionales en el código. Cada transición indica qué actor puede ejecutarla y si libera o mantiene los bloques ocupados.

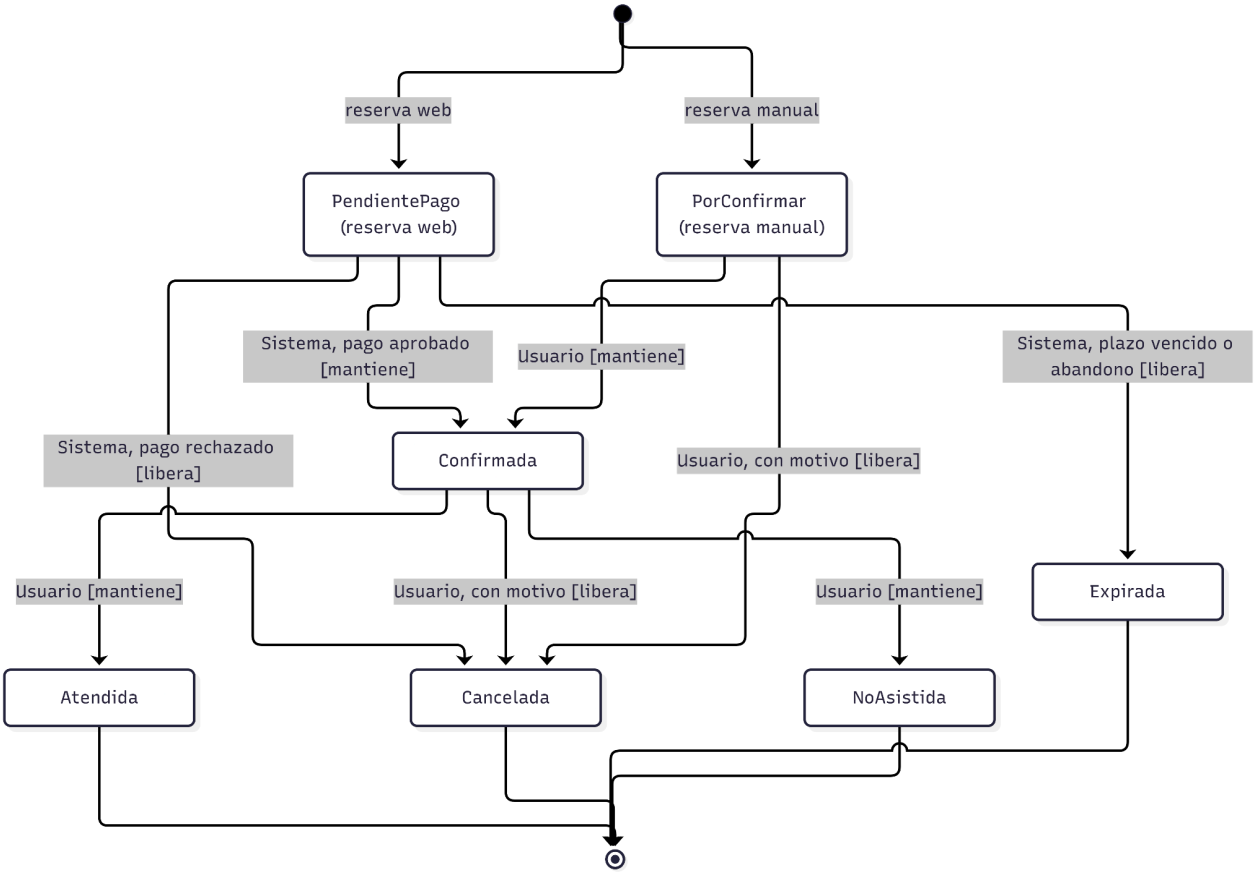


Figura II.5 Máquina de estados de la cita

Desde	**Hacia**	**Actor**	**Efecto en los bloques**
PendientePago	Confirmada	Sistema	Mantiene
PendientePago	Cancelada	Sistema	Libera
PendientePago	Expirada	Sistema	Libera
PorConfirmar	Confirmada	Usuario	Mantiene
PorConfirmar	Cancelada	Usuario	Libera
Confirmada	Cancelada	Usuario	Libera
Confirmada	Atendida	Usuario	Mantiene
Confirmada	NoAsistida	Usuario	Mantiene

Una reserva web nace en PendientePago y solo el sistema la saca de ese estado, al resolverse el pago. Una reserva manual nace en PorConfirmar. El personal no puede modificar una cita en PendientePago ni en un estado final, y la cancelación exige un motivo, que se guarda en la cita y en la auditoría. Al confirmar, el personal indica la vía de confirmación: Profesional, Correo o WhatsApp.

2.7 Inventario de Controladores

La API expone 123 endpoints en 26 controladores. La tabla indica la ruta base, la política que aplica por defecto y la cantidad de endpoints de cada uno. Las políticas se explican en la sección 5.1.

Controlador	Ruta base	Acceso	Endpoints	Responsabilidad
Agenda	/api/agenda	Personal	2	Grilla de la agenda y generación de bloques.
Auditoria	/api/auditoria	Personal y Administrador	2	Historial de una cita y eventos de auditoría.
Auth	/api/auth	Pública, Paciente y Personal	5	Inicio de sesión, perfil y cambio de contraseña.
BloqueHorario	/api/bloques	Pública y Personal	3	Bloques disponibles y cambios de estado.
BloqueoAgenda	/api/bloqueos-agenda	Personal y Administrador	4	Bloqueos de agenda.
Cita	/api/citas	Paciente y Personal	7	Reserva web, reserva manual, consulta y estados.
Configuracion	/api/configuracion	Pública y Personal	4	Configuración del sitio y reseñas de Google.
Contenido	/api/contenido	Pública y Administrador	2	Contenido institucional por clave.
Testimonio	/api/testimonios	Pública y Administrador	4	Testimonios del sitio.
ProcesoEtapa	/api/proceso-etapas	Pública y Administrador	4	Etapas del proceso de atención.
Disponibilidad	/api/disponibilidad	Pública	3	Fechas, horas y especialistas disponibles.
Documento	/api/documentos	Personal y Pública	35	Plantillas, fichas, recomendaciones, consentimientos, adjuntos y firma.
Empresa	/api/empresas	Personal, Paciente y Administrador	5	Convenios.

Controlador	Ruta base	Acceso	Endpoints	Responsabilidad
Especialista	/api/especialistas	Pública y Administrador	5	Profesionales.
File	/api/archivos/imagenes	Administrador	3	Imágenes del sitio en Cloudinary.
HorarioCentro	/api/horario-centro	Administrador	3	Horario de atención del centro.
Notificacion	/api/notificaciones	Administrador	1	Consulta de la bandeja de correos.
Paciente	/api/pacientes	Personal	6	Pacientes y verificación de RUT.
PlantillaHorario	/api/plantillas-horario	Personal	3	Horario de cada especialista.
Servicio	/api/servicios	Pública y Administrador	5	Catálogo y documentos exigidos.
Transaccion	/api/transacciones	Paciente, Pública y Personal	4	Pago con Webpay Plus.
UsuarioPersonal	/api/usuarios	Administrador	4	Cuentas del panel.
Venta	/api/ventas	Personal	3	Registro y consulta de cobros.
TerminalPago	/api/terminales	Personal y Administrador	2	Terminales de pago y sus comisiones.
Reparto	/api/reportes/repartos	Administrador	2	Acuerdos de reparto por especialista.
TasaImpuesto	/api/reportes/tasa-impuesto	Administrador	2	Tasa de IVA vigente.

Los endpoints que sostienen los flujos críticos son los siguientes:

Endpoint	Acceso	Uso
GET /api/disponibilidad/fechas, /horas y /especialistas	Pública	Disponibilidad para la reserva web.
POST /api/auth/google	Pública, 10 por minuto	Inicio de sesión del paciente.

Endpoint	Acceso	Uso
PATCH /api/auth/perfil	Paciente	RUT, teléfono y convenio del paciente.
POST /api/citas	Paciente	Reserva web en PendientePago.
POST /api/transacciones/iniciar	Paciente	Inicio del pago del anticipo.
POST /api/transacciones/confirmar	Pública	Confirmación al volver de Webpay.
POST /api/transacciones/anular	Pública	Abandono del pago en Webpay.
POST /api/auth/personal	Pública, 10 por minuto	Inicio de sesión del personal.
GET /api/agenda	Personal	Grilla de la agenda.
POST /api/citas/manual	Personal	Reserva manual en PorConfirmar.
PATCH /api/citas/{id}/estado	Personal	Transiciones de estado de una cita.
POST /api/agenda/generar	Personal	Generación de bloques.
GET /api/documentos/publico/{token}	Pública, 20 por minuto	Documento a firmar.
POST /api/documentos/publico/{token}/firmar	Pública, 20 por minuto	Firma del paciente.
POST /api/documentos/{id}/firma-profesional	Personal	Contrafirma de la profesional.
POST /api/documentos/{id}/rechazar	Personal	Rechazo de un consentimiento entregado, con motivo.
POST /api/ventas	Personal	Registro de un cobro.

2.8 Decisiones de Arquitectura

La tabla resume las decisiones que más condicionan el código, con su justificación y su consecuencia. Cada una puede revisarse, pero cambiarla afecta a varias partes del sistema.

Decisión	Justificación	Consecuencia
Agenda en bloques de 30 minutos; consecutivo significa que el fin de un bloque es el inicio del siguiente.	Una sola definición evita que el sitio ofrezca horas que la reserva rechaza. La colación corta la cadena sin reglas especiales.	Los servicios deben durar múltiplos de 30 minutos; un servicio sin duración no es reservable.
La doble reserva la impide un índice único sobre citas_bloques.bloque_horario_id.	Dos peticiones simultáneas pueden pasar cualquier comprobación previa; la base de datos rechaza a la segunda.	Liberar una cita borra sus filas de ocupación; la traza queda en la cita y en la auditoría.
Los pagos se resuelven con un reclamo atómico: UPDATE condicionado al estado Iniciado.	La confirmación, la anulación y la expiración pueden competir por la misma transacción.	Solo una vía gana; la confirmación es idempotente.
Los documentos clínicos comparten una tabla con herencia TPH.	Fichas, recomendaciones y consentimientos comparten ciclo de vida, auditoría y adjuntos.	La columna tipo discrimina; las columnas propias de un tipo admiten nulos.
Los enlaces de firma usan tokens aleatorios guardados como hash, y el documento se congela con su huella.	El enlace da acceso sin sesión; la huella garantiza que se firma lo que se leyó.	Un enlace no se puede recuperar desde la base; se reemite uno nuevo.
Los correos salen de una bandeja de salida en la base.	Un fallo del proveedor no debe revertir una reserva ni un pago.	El envío es asíncrono y se reintenta con espera creciente.
La hora local se calcula con la zona America/Santiago.	Chile ha cambiado su horario de verano varias veces por ley.	Las reglas de horario no dependen de un desfase fijo.
Las migraciones se aplican al arrancar la API.	El despliegue no requiere pasos manuales sobre la base.	Un despliegue es también un cambio de esquema.
Los procesos periódicos corren dentro de la API.	Evita otro componente que desplegar y vigilar.	La API se ejecuta en una sola instancia.
Las tarifas, el IVA y los repartos tienen vigencia por fecha y se cierran en lugar de sobrescribirse.	Una liquidación de un período pasado debe dar siempre el mismo resultado.	El cálculo busca las tasas vigentes a la fecha de cada venta.
El contenido del sitio se guarda en la base y se edita desde el panel.	El centro administra textos e imágenes sin depender de otro sistema.	El sitio lee su contenido desde la API.
Los valores sensibles se entregan por variables de entorno o por un archivo montado.	Ningún secreto debe quedar en el repositorio.	El servidor mantiene su propia configuración en /etc/kinefit.

Decisión	Justificación	Consecuencia
Los cambios de parámetros dentro de una misma ruta usan la History API del navegador.	En Next.js 16.2.9, router.push a la misma ruta no navega después de una carga directa con parámetros.	Al actualizar Next.js se puede revisar si el error se corrigió y volver a router.push, probando antes el caso de la recarga.

III. Modelo de Datos

3.1 Convenciones del Esquema

El esquema se genera desde las entidades del dominio con Entity Framework Core y se versiona como migraciones. Las convenciones son las siguientes:

- **Nombres:** tablas y columnas en snake_case, mediante EFCore.NamingConventions; las tablas se nombran en plural, por ejemplo citas y bloques_horarios.
- **Claves:** cada tabla tiene una columna id de tipo integer generada como identidad. Las claves foráneas terminan en _id.
- **Tiempo:** las marcas de tiempo son timestamptz y se guardan en UTC. Las columnas fecha y hora de la agenda son date y time y representan la hora local del centro.
- **Montos:** los montos en pesos chilenos son enteros; los porcentajes y tasas son numeric.
- **Enums:** las enumeraciones se guardan como enteros, con los valores de la sección 3.4. La única excepción es comisiones_terminal.tipo_modelo, que se guarda como texto.
- **Baja lógica:** los pacientes, especialistas, servicios, empresas y cuentas del panel se desactivan con la columna activo en lugar de eliminarse, para no dejar huérfanos a las citas, ventas y documentos que los referencian.
- **Integridad:** todas las claves foráneas restringen el borrado, salvo especialistas_servicios, que se elimina en cascada con su especialista.

El origen de datos de Npgsql registra además cinco tipos enumerados nativos de PostgreSQL (estado_bloque, estado_cita, estado_transaccion, modificado_por y origen_cita). Esos tipos existen en la base, pero ninguna columna los usa: las columnas equivalentes son integer.

3.2 Vista General del Modelo

El modelo tiene 32 tablas, 328 columnas y 43 relaciones con clave foránea. Las 35 entidades del dominio se reducen a 32 tablas porque FichaClinica, Recomendacion y Consentimiento comparten la tabla documentos. La Figura III.1 muestra todas las tablas y sus relaciones; las figuras siguientes detallan cada módulo con sus columnas.

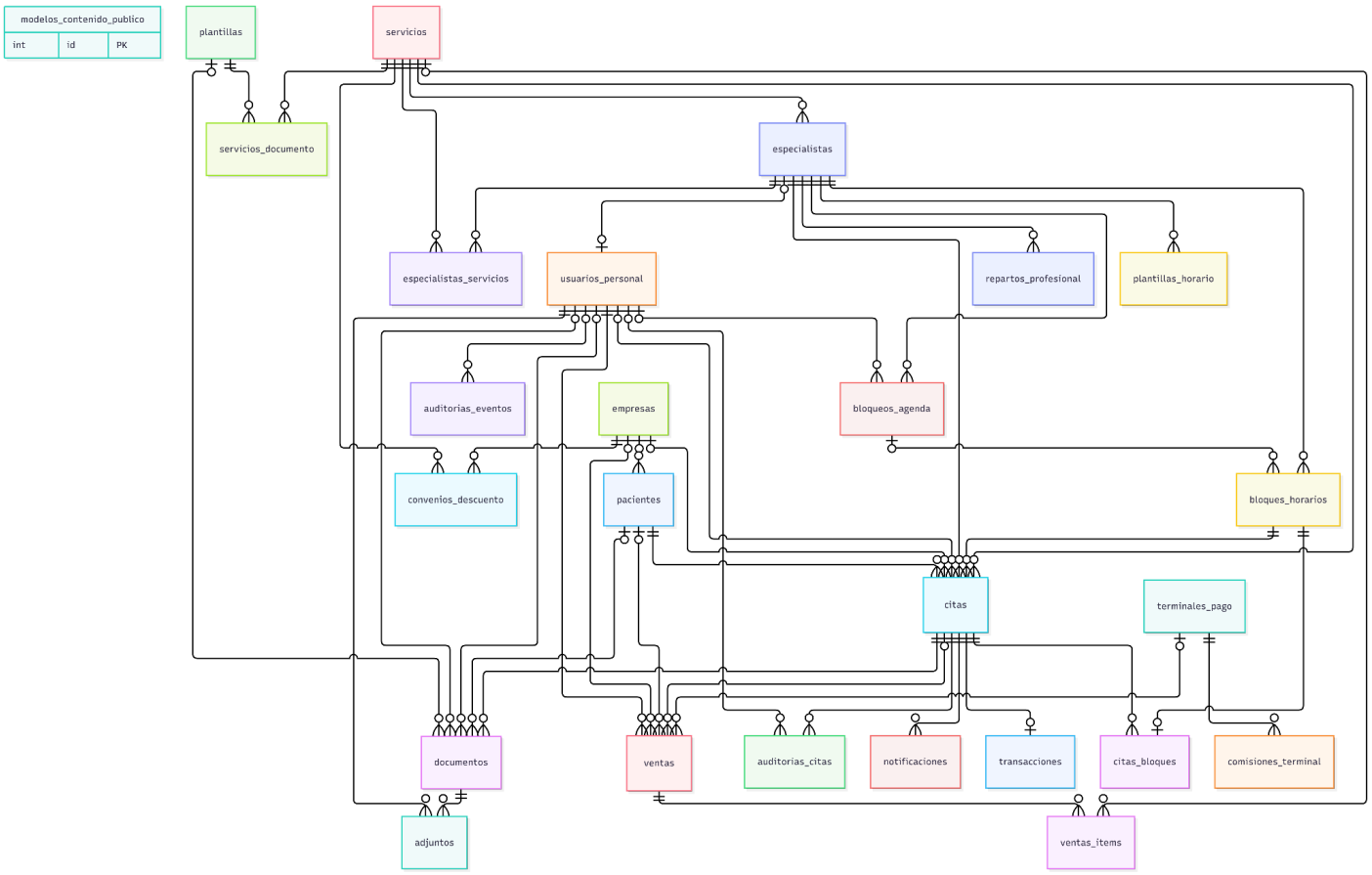


Figura III.1 Diagrama entidad relación: vista general de las 32 tablas (modelos contenidos públicos recortados en modelos_contenido_publico)

Módulo	**Tablas**
Agenda y reservas	horarios_centro, plantillas_horario, bloqueos_agenda, bloques_horarios, citas, citas_bloques, transacciones, notificaciones
Personas y catálogo	pacientes, especialistas, especialistas_servicios, servicios, empresas, convenios_descuento, usuarios_personal
Documentos clínicos	documentos, plantillas, servicios_documento, adjuntos
Ventas y finanzas	ventas, ventas_items, terminales_pago, comisiones_terminal, repartos_profesional, tasas_impuesto
Sitio público y configuración	landing_configs, contenidos_sitio, testimonios, proceso_etapas, configuraciones_sistema
Auditoría	auditorias_citas, auditorias_eventos

3.3 Diccionario de Datos

El diccionario describe cada tabla y cada columna.

En la columna Restricciones, PK indica la clave primaria, FK la clave foránea con la tabla de destino y Único la unicidad, sola o combinada con otras columnas. La condición entre paréntesis indica que el índice es filtrado, es decir, que la unicidad solo se exige en las filas que cumplen esa condición.

3.3.1 Agenda y Reservas

Estas tablas sostienen la agenda y el ciclo de vida de una reserva, desde la generación de los bloques hasta el pago del anticipo y los correos al paciente.

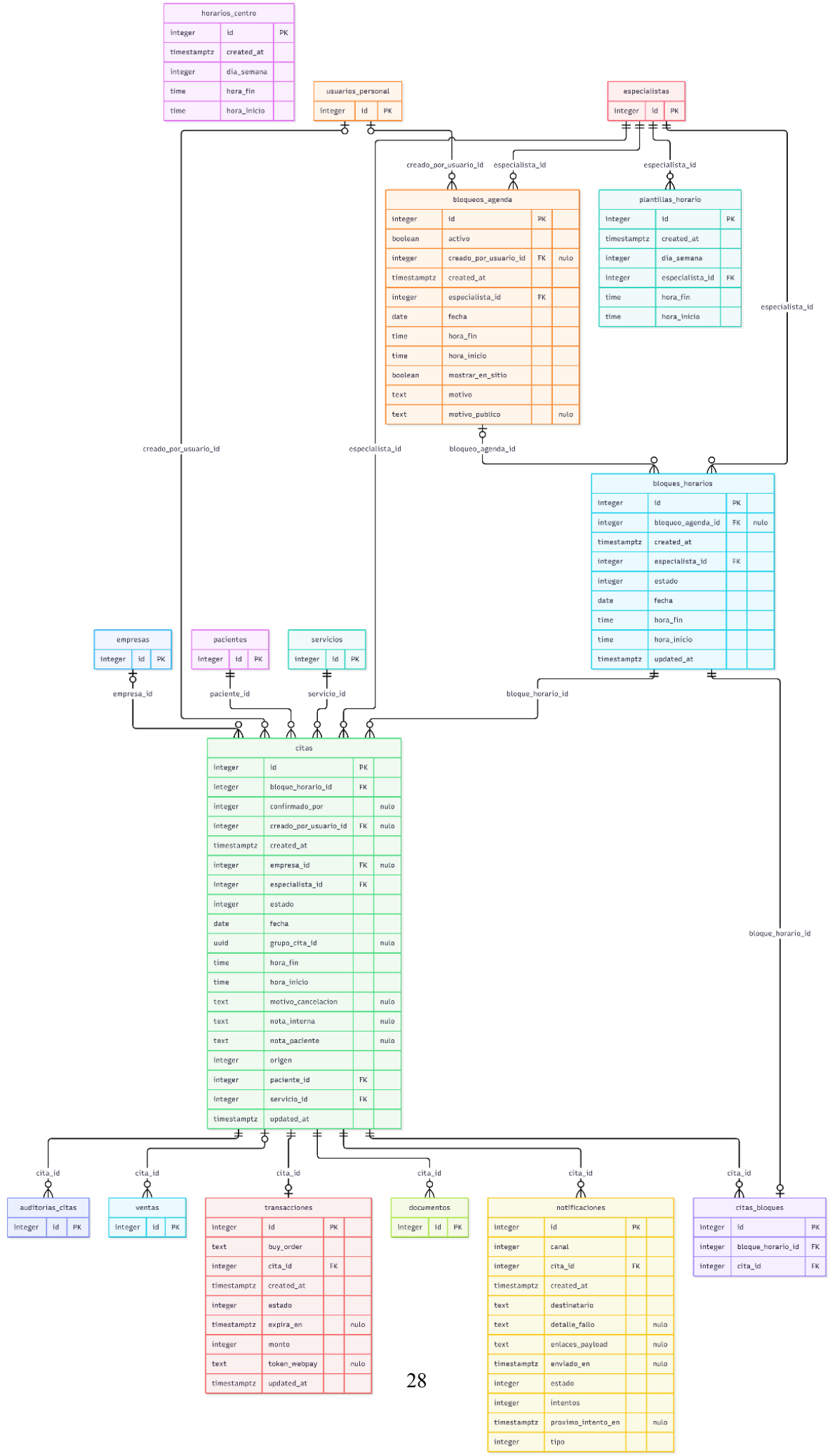

horarios_centro
integer id PK
timestamptz created_at
integer dia_semana
time hora_fin
time hora_inicio
usuarios_personal
integer id PK
especialistas
integer id PK
creado_por_usuario_id
especialista_id
especialista_id
bloqueos_agenda
integer id PK
boolean activo
integer creado_por_usuario_id FK nulo
timestamptz created_at
integer especialista_id FK
date fecha
time hora_fin
time hora_inicio
boolean mostrar_en_sitio
text motivo
text motivo_publico nulo
plantillas_horario
integer id PK
timestamptz created_at
integer dia_semana
integer especialista_id FK
time hora_fin
time hora_inicio
especialista_id
creado_por_usuario_id
especialista_id
bloqueo_agenda_id
bloques_horarios
integer id PK
integer bloqueo_agenda_id FK nulo
timestamptz created_at
integer especialista_id FK
integer estado
date fecha
time hora_fin
time hora_inicio
timestamptz updated_at
empresas
integer id PK
pacientes
integer id PK
servicios
integer id PK
empresa_id
paciente_id
servicio_id
bloque_horario_id
citas
integer id PK
integer bloque_horario_id FK
integer confirmado_por nulo
integer creado_por_usuario_id FK nulo
timestamptz created_at
integer empresa_id FK nulo
integer especialista_id FK
integer estado
date fecha
uuid grupo_cita_id nulo
time hora_fin
time hora_inicio
text motivo_cancelacion nulo
text nota_interna nulo
text nota_paciente nulo
integer origen
integer paciente_id FK
integer servicio_id FK
timestamptz updated_at
bloque_horario_id
cita_id
cita_id
cita_id
cita_id
cita_id
cita_id
auditorias_citas
integer id PK
ventas
integer id PK
transacciones
integer id PK
text buy_order
integer cita_id FK
timestamptz created_at
integer estado
timestamptz expira_en nulo
integer monto
text token_webpay nulo
timestamptz updated_at
documentos
integer id PK
notificaciones
integer id PK
integer canal
integer cita_id FK
timestamptz created_at
text destinatario
text detalle_fallo nulo
text enlaces_payload nulo
timestamptz enviado_en nulo
integer estado
integer intentos
timestamptz proximo_intento_en nulo
integer tipo
citas_bloques
integer id PK
integer bloque_horario_id FK
integer cita_id FK

Figura III.2 Diagrama entidad relación: agenda y reservas

Tabla horarios_centro. Tramos de atención del centro por día de la semana. Es la primera mitad de la intersección que produce la agenda.

Columna	Tipo	Nulo	Restricciones	Descripción
id	integer	No	PK, identidad	Identificador del registro, generado por la base como columna de identidad.
created_at	timestamptz	No	Por omisión CURRENT_TIMESTAMP	Fecha y hora de creación, en UTC.
dia_semana	integer	No	Único con hora_inicio	Día de la semana. Valores: 0 domingo a 6 sábado.
hora_fin	time	No		Fin del tramo. Un día con colación tiene dos tramos.
hora_inicio	time	No	Único con dia_semana	Inicio del tramo de atención del centro.

Tabla plantillas_horario. Tramos en que cada especialista atiende, por día de la semana. Es la segunda mitad de la intersección que produce la agenda.

Columna	Tipo	Nulo	Restricciones	Descripción
id	integer	No	PK, identidad	Identificador del registro, generado por la base como columna de identidad.
created_at	timestamptz	No	Por omisión CURRENT_TIMESTAMP	Fecha y hora de creación, en UTC.
dia_semana	integer	No	Único con especialista_id, hora_inicio	Día de la semana. Valores: 0 domingo a 6 sábado.
especialista_id	integer	No	FK → especialistas; Único con dia_semana, hora_inicio	Especialista a la que pertenece.
hora_fin	time	No		Fin del tramo en que atiende la especialista.

Columna	Tipo	Nulo	Restricciones	Descripción
hora_inicio	time	No	Único con especialista_id, dia_semana	Inicio del tramo en que atiende la especialista.

Tabla bloqueos_agenda. Excepciones puntuales sobre la agenda de una especialista: una fecha y un rango horario en que no se atiende.

Columna	Tipo	Nulo	Restricciones	Descripción
id	integer	No	PK, identidad	Identificador del registro, generado por la base como columna de identidad.
activo	boolean	No		Indica si el registro está vigente. Se desactiva en lugar de eliminarse.
creado_por_usuario_id	integer	Sí	FK → usuarios_personal	Usuario del personal que registró el bloqueo.
created_at	timestamptz	No	Por omisión CURRENT_TIMESTAMP	Fecha y hora de creación, en UTC.
especialista_id	integer	No	FK → especialistas	Especialista a la que pertenece.
fecha	date	No		Día afectado por el bloqueo.
hora_fin	time	No		Fin del rango bloqueado.
hora_inicio	time	No		Inicio del rango bloqueado.
mostrar_en_sitio	boolean	No		Si es verdadero, el sitio público muestra el motivo público en la franja bloqueada.
motivo	text	No		Motivo interno del bloqueo.
motivo_publico	text	Sí		Texto que ve el paciente cuando el bloqueo se muestra en el sitio.

Tabla bloques_horarios. Unidad reservable de la agenda: una franja de 30 minutos de una especialista en una fecha.

Columna	Tipo	Nulo	Restricciones	Descripción
id	integer	No	PK, identidad	Identificador del registro, generado por la base como columna de identidad.
bloqueo_agenda_id	integer	Sí	FK → bloqueos_agenda	Bloqueo que dejó este bloque en estado Bloqueado, si corresponde.
created_at	timestamptz	No	Por omisión CURRENT_TIMESTAMP	Fecha y hora de creación, en UTC.
especialista_id	integer	No	FK → especialistas; Único con fecha, hora_inicio	Especialista a la que pertenece.
estado	integer	No		Disponibilidad del bloque. Valores: 0 Disponible, 1 Bloqueado, 2 Reservado.
fecha	date	No	Único con especialista_id, hora_inicio	Día del bloque.
hora_fin	time	No		Fin del bloque, 30 minutos después del inicio. Dos bloques son consecutivos cuando este valor es igual al inicio del siguiente.
hora_inicio	time	No	Único con especialista_id, fecha	Inicio del bloque.
updated_at	timestamptz	No	Por omisión CURRENT_TIMESTAMP	Fecha y hora de la última modificación, en UTC.

Tabla citas. Reserva de una atención. Guarda su propio rango horario, fijado al momento de reservar.

Columna	Tipo	Nulo	Restricciones	Descripción
id	integer	No	PK, identidad	Identificador del registro, generado por la base como columna de identidad.
bloque_horario_id	integer	No	FK → bloques_horarios	Bloque inicial de la cita. La ocupación completa está en citas_bloques.

Columna	Tipo	Nulo	Restricciones	Descripción
confirmado_por	integer	Sí		Vía por la que se confirmó la cita. Nulo si no está confirmada. Valores: 0 Profesional, 1 Correo, 2 WhatsApp.
creado_por_usuario_id	integer	Sí	FK → usuarios_personal	Usuario del personal que registró una reserva manual. Nulo en las reservas web.
created_at	timestamptz	No	Por omisión CURRENT_TIMESTAMP	Fecha y hora de creación, en UTC.
empresa_id	integer	Sí	FK → empresas	Convenio con que se reservó, si el paciente lo indicó.
especialista_id	integer	No	FK → especialistas	Especialista que atiende.
estado	integer	No		Estado de la reserva en su ciclo de vida. Valores: 0 Pendiente (obsoleto), 1 Confirmada, 2 Cancelada, 3 Expirada, 4 PendientePago, 5 PorConfirmar, 6 Atendida, 7 NoAsistida.
fecha	date	No		Día de la atención, fijado al reservar.
grupo_cita_id	uuid	Sí		Mecanismo multibloque heredado: agrupa varias filas de cita de una misma atención. Las citas actuales usan citas_bloques.
hora_fin	time	No		Fin de la atención: el fin del último bloque ocupado.
hora_inicio	time	No		Inicio de la atención.
motivo_cancelacion	text	Sí		Motivo obligatorio al cancelar desde el panel.
nota_interna	text	Sí		Nota visible solo para el personal.
nota_paciente	text	Sí		Nota que el paciente o el personal deja para la atención; se incluye en el correo de confirmación.
origen	integer	No		Canal por el que se creó la reserva. Valores: 0 Web, 1 Manual.
paciente_id	integer	No	FK → pacientes	Paciente que asiste a la atención.

Columna	Tipo	Nulo	Restricciones	Descripción
servicio_id	integer	No	FK → servicios	Servicio reservado.
updated_at	timestamptz	No		Fecha y hora de la última modificación, en UTC.

Tabla citas_bloques. Ocupación de bloques por citas. Su índice único sobre bloque_horario_id es la barrera contra la doble reserva.

Columna	Tipo	Nulo	Restricciones	Descripción
id	integer	No	PK, identidad	Identificador del registro, generado por la base como columna de identidad.
bloque_horario_id	integer	No	FK → bloques_horarios; Único	Bloque ocupado. Índice único: un bloque solo puede estar ocupado por una cita.
cita_id	integer	No	FK → citas	Cita que ocupa el bloque.

Tabla transacciones. Pago de anticipo con Webpay Plus asociado a una cita web. Una transacción por cita.

Columna	Tipo	Nulo	Restricciones	Descripción
id	integer	No	PK, identidad	Identificador del registro, generado por la base como columna de identidad.
buy_order	text	No		Orden de compra enviada a Transbank, con el formato KF-{cita}-{segundos Unix}.
cita_id	integer	No	FK → citas; Único	Cita asociada.
created_at	timestamptz	No	Por omisión CURRENT_TIMESTAMP	Fecha y hora de creación, en UTC.
estado	integer	No		Estado del pago. Valores: 0 Iniciado, 1 Aprobado, 2 Rechazado, 3 Expirado.
expira_en	timestamptz	Sí		Momento en que la transacción vence si no se confirma. Nulo en las transacciones creadas antes de que existiera este campo.

Columna	Tipo	Nulo	Restricciones	Descripción
monto	integer	No		Monto del anticipo en pesos chilenos, tomado de Webpay:MontoAnticipo al iniciar.
token_webpay	text	Sí		Token que entrega Transbank al crear la transacción; con él se confirma o anula.
updated_at	timestamptz	No		Fecha y hora de la última modificación, en UTC.

Tabla notificaciones. Bandeja de salida de correos al paciente. El proceso en segundo plano las envía y reintenta.

Columna	Tipo	Nulo	Restricciones	Descripción
id	integer	No	PK, identidad	Identificador del registro, generado por la base como columna de identidad.
canal	integer	No		Canal de envío. Valores: 0 Correo.
cita_id	integer	No	FK → citas; Único con tipo (donde tipo IN (0, 1, 2))	Cita asociada.
created_at	timestamptz	No	Por omisión CURRENT_TIMESTAMP	Fecha y hora de creación, en UTC.
destinatario	text	No		Correo electrónico del paciente al momento de encolar.
detalle_fallo	text	Sí		Último error devuelto por el proveedor de correo.
enlaces_payload	text	Sí		JSON con los enlaces de firma que incluye el correo (nombre y URL de cada documento).
enviado_en	timestamptz	Sí		Momento del envío exitoso.
estado	integer	No		Estado del envío. Valores: 0 Pendiente, 1 Enviada, 2 Fallida.
intentos	integer	No		Intentos de envío realizados.

Columna	Tipo	Nulo	Restricciones	Descripción
proximo_intento_en	timestamptz	Sí		Momento a partir del cual se puede reintentar (espera de 2, 4, 8 y 16 minutos).
tipo	integer	No	Único con cita_id (donde tipo IN (0, 1, 2))	Motivo del correo. Valores: 0 Confirmacion, 1 Recordatorio, 2 CambioEstado, 3 DocumentoParaFirma, 4 DocumentoPostAtencion.

3.3.2 Personas y Catálogo

Estas tablas registran a los pacientes, los profesionales, las cuentas del panel, el catálogo de servicios y los convenios con empresas.

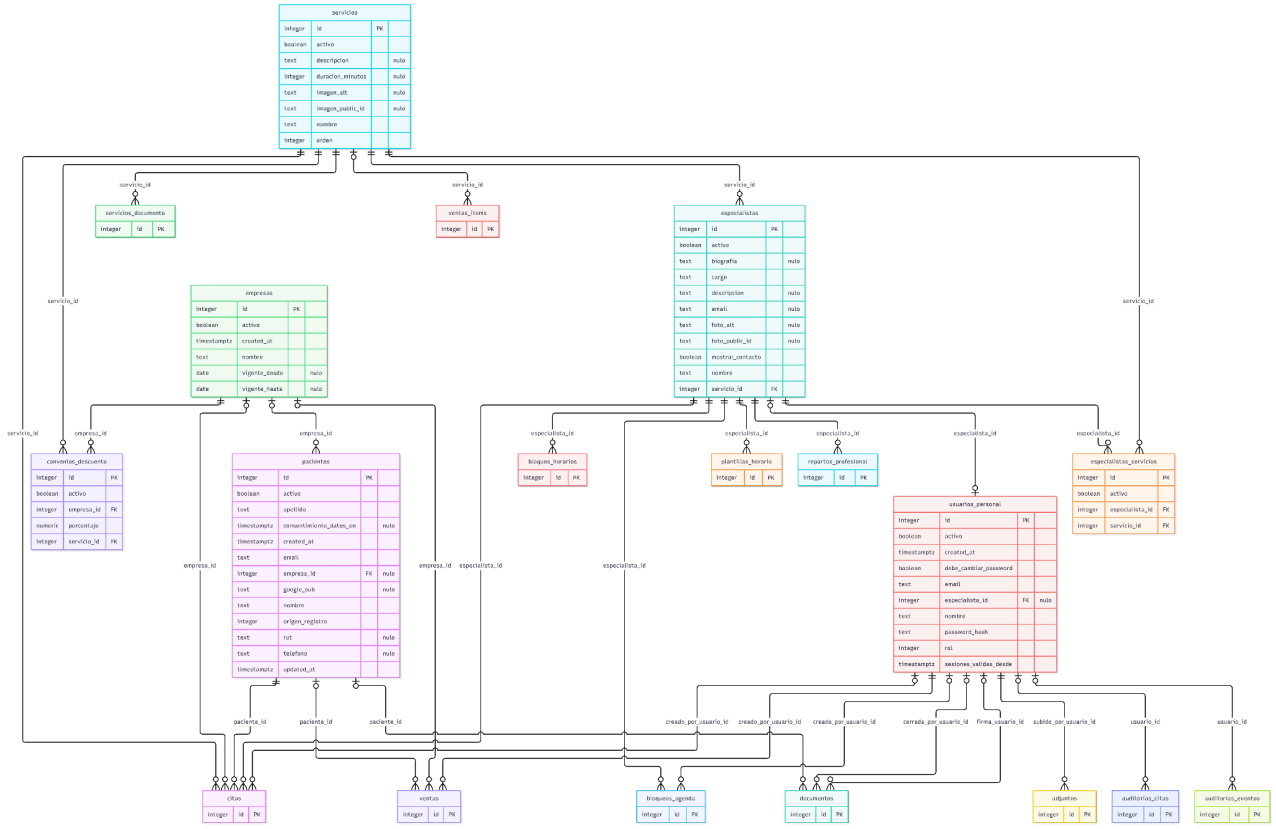


Figura III.3 Diagrama entidad relación: personas y catálogo

Tabla pacientes. Personas que reservan atenciones, registradas por Google o a mano por el personal.

Columna	Tipo	Nulo	Restricciones	Descripción
id	integer	No	PK, identidad	Identificador del registro, generado por la base como columna de identidad.
activo	boolean	No	Por omisión true	Indica si el registro está vigente. Se desactiva en lugar de eliminarse.
apellido	text	No		Apellido del paciente.
consentimiento_datos_en	timestamptz	Sí		Momento en que aceptó la política de privacidad al crear su cuenta.
created_at	timestamptz	No	Por omisión CURRENT_TIMESTAMP	Fecha y hora de creación, en UTC.
email	text	No		Correo del paciente. Recibe las notificaciones.
empresa_id	integer	Sí	FK → empresas	Convenio declarado por el paciente.
google_sub	text	Sí	Único (donde google_sub IS NOT NULL)	Identificador de la cuenta de Google. Nulo si el paciente fue registrado a mano. Único cuando no es nulo.
nombre	text	No		Nombre del paciente.
origen_registro	integer	No		Cómo se registró el paciente. Valores: 0 Web, 1 Manual.
rut	text	Sí	Único (donde rut IS NOT NULL)	RUT con dígito verificador validado, formato 12.345.678-5. Único cuando no es nulo. Obligatorio para reservar.
telefono	text	Sí		Celular chileno en formato +569XXXXXXXX. Obligatorio para reservar.
updated_at	timestamptz	No	Por omisión CURRENT_TIMESTAMP	Fecha y hora de la última modificación, en UTC.

Tabla especialistas. Profesionales del centro que prestan atenciones y tienen agenda propia.

Columna	Tipo	Nulo	Restricciones	Descripción
id	integer	No	PK, identidad	Identificador del registro, generado por la base como columna de identidad.
activo	boolean	No		Indica si el registro está vigente. Se desactiva en lugar de eliminarse.
biografia	text	Sí		Biografía extendida.
cargo	text	No		Título o cargo que muestra el sitio.
descripcion	text	Sí		Descripción breve para el sitio.
email	text	Sí		Correo de contacto de la profesional.
foto_alt	text	Sí		Texto alternativo de la foto.
foto_public_id	text	Sí		Identificador público de la foto en Cloudinary.
mostrar_contacto	boolean	No		Si es verdadero, el sitio muestra sus datos de contacto.
nombre	text	No		Nombre de la profesional.
servicio_id	integer	No	FK → servicios	Servicio principal heredado del modelo de un solo servicio. Las habilitaciones vigentes están en especialistas_servicios.

Tabla especialistas_servicios. Habilitación de cada especialista para prestar cada servicio.

Columna	Tipo	Nulo	Restricciones	Descripción
id	integer	No	PK, identidad	Identificador del registro, generado por la base como columna de identidad.
activo	boolean	No		Indica si el registro está vigente. Se desactiva en lugar de eliminarse.
especialista_id	integer	No	FK → especialistas, Cascade; Único con servicio_id	Especialista habilitada. Único junto con servicio_id.
servicio_id	integer	No	FK → servicios; Único con especialista_id	Servicio que puede prestar.

Tabla servicios. Catálogo de prestaciones que se pueden reservar.

Columna	Tipo	Nulo	Restricciones	Descripción
id	integer	No	PK, identidad	Identificador del registro, generado por la base como columna de identidad.
activo	boolean	No		Indica si el registro está vigente. Se desactiva en lugar de eliminarse.
descripcion	text	Sí		Descripción que muestra el sitio.
duracion_minutos	integer	Sí		Duración de la atención. Determina cuántos bloques de 30 minutos ocupa. Un servicio sin duración no es agendable.
nombre	text	No	Único	Nombre del servicio. Único.
orden	integer	No		Posición en el catálogo del sitio.

Tabla empresas. Convenios con empresas o instituciones cuyos trabajadores acceden a descuentos.

Columna	Tipo	Nulo	Restricciones	Descripción
id	integer	No	PK, identidad	Identificador del registro, generado por la base como columna de identidad.
activo	boolean	No		Indica si el registro está vigente. Se desactiva en lugar de eliminarse.
created_at	timestamptz	No	Por omisión CURRENT_TIMESTAMP	Fecha y hora de creación, en UTC.
nombre	text	No	Único	Nombre del convenio. Único.
vigente_desde	date	Sí		Inicio de la vigencia del convenio. Nulo sin límite.
vigente_hasta	date	Sí		Fin de la vigencia del convenio. Nulo sin límite.

Tabla convenios_descuento. Porcentaje de descuento que un convenio aplica a un servicio puntual.

Columna	Tipo	Nulo	Restricciones	Descripción
id	integer	No	PK, identidad	Identificador del registro, generado por la base como columna de identidad.
activo	boolean	No		Indica si el registro está vigente. Se desactiva en lugar de eliminarse.
empresa_id	integer	No	FK → empresas; Único con servicio_id	Convenio. Único junto con servicio_id.
porcentaje	numeric	No		Porcentaje de descuento sobre el precio del servicio.
servicio_id	integer	No	FK → servicios; Único con empresa_id	Servicio al que aplica el descuento.

Tabla usuarios_personal. Cuentas de acceso al panel (administración y especialistas), separadas de la ficha profesional.

Columna	Tipo	Nulo	Restricciones	Descripción
id	integer	No	PK, identidad	Identificador del registro, generado por la base como columna de identidad.
activo	boolean	No		Indica si el registro está vigente. Se desactiva en lugar de eliminarse.
created_at	timestamptz	No	Por omisión CURRENT_TIMESTAMP	Fecha y hora de creación, en UTC.
debe_cambiar_password	boolean	No		Verdadero al crear la cuenta con contraseña temporal; obliga a cambiarla.
email	text	No	Único	Correo con que inicia sesión. Único.
especialista_id	integer	Sí	FK → especialistas; Único (donde especialista_id IS NOT NULL)	Vínculo uno a uno con la ficha profesional, solo para el rol Especialista. Único cuando no es nulo.
nombre	text	No		Nombre de la persona.

Columna	Tipo	Nulo	Restricciones	Descripción
password_hash	text	No		Hash PBKDF2-HMAC-SHA256 con el formato {iteraciones}.{sal}.{clave}. Nunca se almacena la contraseña.
rol	integer	No		Rol que determina los permisos en el panel y en la API. Valores: 0 Administrador, 1 Especialista.
sesiones_validas_desde	timestamptz	No		Solo son válidos los tokens emitidos desde este momento. Desactivar la cuenta o cambiar la contraseña lo adelanta a ahora.

3.3.3 Documentos Clínicos

Estas tablas guardan las fichas, recomendaciones y consentimientos de cada cita, las plantillas que los originan y los metadatos de sus archivos.

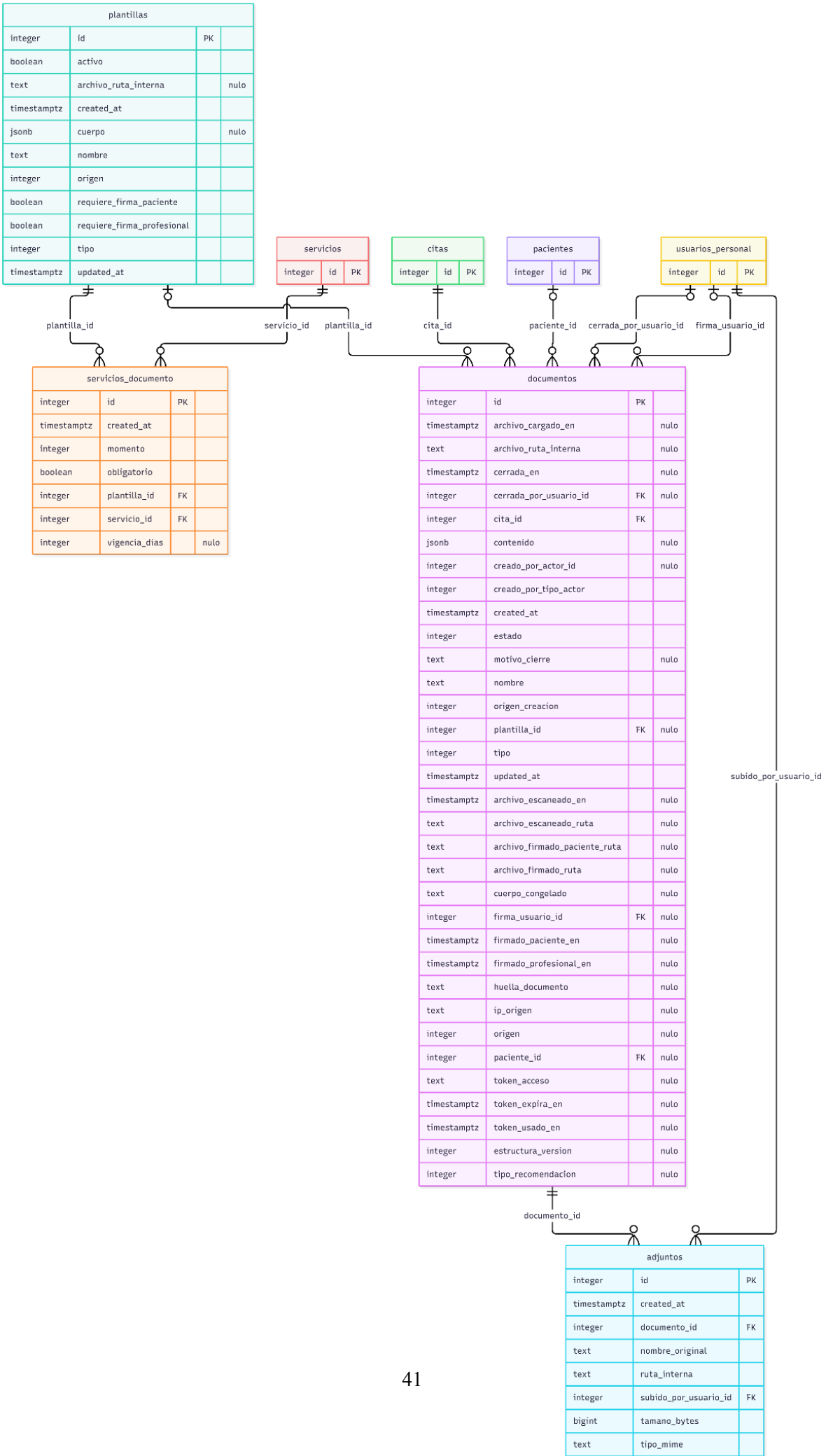

plantillas
integer id PK
boolean activo
text archivo_ruta_interna nulo
timestamptz created_at
jsonb cuerpo nulo
text nombre
integer origen
boolean requiere_firma_paciente
boolean requiere_firma_profesional
integer tipo
timestamptz updated_at
servicios
integer id PK
citas
integer id PK
pacientes
integer id PK
usuarios_personal
integer id PK
plantilla_id
servicio_id
plantilla_id
cita_id
paciente_id
cerrada_por_usuario_id
firma_usuario_id
servicios_documento
integer id PK
timestamptz created_at
integer momento
boolean obligatorio
integer plantilla_id FK
integer servicio_id FK
integer vigencia_dias nulo
documentos
integer id PK
timestamptz archivo_cargado_en nulo
text archivo_ruta_interna nulo
timestamptz cerrada_en nulo
integer cerrada_por_usuario_id FK nulo
integer cita_id FK
jsonb contenido nulo
integer creado_por_actor_id nulo
integer creado_por_tipo_actor
timestamptz created_at
integer estado
text motivo_cierre nulo
text nombre
integer origen_creacion
integer plantilla_id FK nulo
integer tipo
timestamptz updated_at
timestamptz archivo_escaneado_en nulo
text archivo_escaneado_ruta nulo
text archivo_firmado_paciente_ruta nulo
text archivo_firmado_ruta nulo
text cuerpo_congelado nulo
integer firma_usuario_id FK nulo
timestamptz firmado_paciente_en nulo
timestamptz firmado_profesional_en nulo
text huella_documento nulo
text ip_origen nulo
integer origen nulo
integer paciente_id FK nulo
text token_acceso nulo
timestamptz token_expira_en nulo
timestamptz token_usado_en nulo
integer estructura_version nulo
integer tipo_recomendacion nulo
subido_por_usuario_id
documento_id
adjuntos
integer id PK
timestamptz created_at
integer documento_id FK
text nombre_original
text ruta_interna
integer subido_por_usuario_id FK
bigint tamano_bytes
text tipo_mime

Figura III.4 Diagrama entidad relación: documentos clínicos

Tabla documentos. Documentos clínicos de una cita. Una sola tabla para tres tipos (herencia TPH, discriminador tipo): fichas clínicas, recomendaciones y consentimientos.

Columna	Tipo	Nulo	Restricciones	Descripción
id	integer	No	PK, identidad	Identificador del registro, generado por la base como columna de identidad.
archivo_cargado_en	timestamptz	Sí		Momento de la carga del archivo.
archivo_escaneado_en	timestamptz	Sí		Consentimiento: momento de la carga del escaneo.
archivo_escaneado_ruta	text	Sí		Consentimiento: escaneo del documento firmado en papel.
archivo_firmado_paciente_ruta	text	Sí		Consentimiento: PDF con solo la firma del paciente, previo a la del profesional.
archivo_firmado_ruta	text	Sí		Consentimiento: PDF firmado, en el volumen de adjuntos.
archivo_ruta_interna	text	Sí		Nombre opaco del archivo en el volumen de adjuntos, cuando el documento se cargó como archivo.
cerrada_en	timestamptz	Sí		Momento del cierre.
cerrada_por_usuario_id	integer	Sí	FK → usuarios_personal	Usuario del personal que lo cerró.
cita_id	integer	No	FK → citas; Único por tipo: tres índices filtrados (tipo 0, 1 y 2)	Cita a la que pertenece el documento.
contenido	jsonb	Sí		Respuestas de los campos, en JSON, para documentos del constructor.
creado_por_actor_id	integer	Sí		Identificador del actor que lo creó, según creado_por_tipo_actor.
creado_por_tipo_actor	integer	No		Tipo de actor que creó el documento. Valores: 0 Sistema, 1 Paciente, 2 Personal.

Columna	Tipo	Nulo	Restricciones	Descripción
created_at	timestamptz	No	Por omisión CURRENT_TIMESTAMP	Fecha y hora de creación, en UTC.
cuerpo_congelado	text	Sí		Consentimiento: copia JSON de la plantilla tal como se mostró (nombre, tipo, origen, cuerpo y archivo).
estado	integer	No		Estado del documento en su ciclo de vida. Valores: 0 Borrador, 1 Pendiente, 2 Completado, 3 Bloqueado, 4 CerradoPorBaja, 5 Anulado.
estructura_version	integer	Sí		Ficha clínica: versión de la estructura con que se completó.
firma_usuario_id	integer	Sí	FK → usuarios_personal	Consentimiento: profesional que contrafirmó.
firmado_paciente_en	timestamptz	Sí		Consentimiento: momento de la firma del paciente.
firmado_profesional_en	timestamptz	Sí		Consentimiento: momento de la firma del profesional.
huella_documento	text	Sí		Consentimiento: SHA-256 del cuerpo congelado. La firma se rechaza si la huella que vio el paciente no coincide.
ip_origen	text	Sí		Consentimiento: dirección IP desde la que se firmó.
motivo_cierre	text	Sí		Motivo del cierre, bloqueo o anulación.
motivo_rechazo	text	Sí		Consentimiento: motivo del último rechazo. Se guarda al rechazar y se vacía cuando el paciente vuelve a firmar o se carga el archivo en papel.
nombre	text	No		Nombre visible del documento.
origen	integer	Sí		Consentimiento: si se firmó en línea o se adjuntó escaneado. Valores: 0 Firmado, 1 Adjunto.

Columna	Tipo	Nulo	Restricciones	Descripción
origen_creacion	integer	No		Cómo nació el documento: desde una plantilla o como archivo cargado. Valores: 0 GeneradoDesdePlantilla, 1 ArchivoCargado.
paciente_id	integer	Sí	FK → pacientes	Consentimiento: paciente que firma.
plantilla_id	integer	Sí	FK → plantillas	Plantilla de origen. Nula si el documento se cargó como archivo.
tipo	integer	No		Discriminador de la herencia: qué clase de documento es la fila. Valores: 0 FichaClinica, 1 Recomendacion, 2 Consentimiento.
tipo_recomendacion	integer	Sí		Recomendación: si es la estándar de la plantilla o una personalizada. Valores: 0 Estandar, 1 Personalizada.
token_acceso	text	Sí	Único (donde token_acceso IS NOT NULL)	Consentimiento: SHA-256 del token del enlace de firma. El token en claro nunca se guarda. Único cuando no es nulo.
token_expira_en	timestamptz	Sí		Consentimiento: vencimiento del enlace de firma.
token_usado_en	timestamptz	Sí		Consentimiento: momento en que se usó el enlace. Un enlace usado no vuelve a abrir.
updated_at	timestamptz	No	Por omisión CURRENT_TIMESTAMP	Fecha y hora de la última modificación, en UTC.

Las fichas clínicas también congelan el cuerpo de su plantilla al crearse. Sin esa copia congelada, renombrar o eliminar un campo de la plantilla cambiaría retroactivamente cómo se lee una ficha ya cerrada.

El listado de documentos, GET /api/documentos, se ordena por created_at descendente y luego por id. Los filtros fechaDesde y fechaHasta se aplican sobre created_at, tomando el día completo en hora de Chile (ChileTimeZone.InicioDiaUtc). Cada documento de la respuesta incluye createdAt. El historial de documentos del paciente, GET /api/documentos/pacientes/{id}/historial, mantiene el orden por fecha de atención.

Tabla plantillas. Plantillas a partir de las cuales se generan los documentos clínicos: construidas en el panel o cargadas como PDF.

Columna	Tipo	Nulo	Restricciones	Descripción
id	integer	No	PK, identidad	Identificador del registro, generado por la base como columna de identidad.
activo	boolean	No		Indica si el registro está vigente. Se desactiva en lugar de eliminarse.
archivo_ruta_interna	text	Sí		PDF base de la plantilla, cuando su origen es Documento.
created_at	timestamptz	No		Fecha y hora de creación, en UTC.
cuerpo	jsonb	Sí		Definición de secciones y campos, en JSON, para plantillas del constructor.
nombre	text	No	Único	Nombre de la plantilla. Único.
origen	integer	No		Si la plantilla se armó en el constructor o se cargó como PDF. Valores: 0 Constructor, 1 Documento.
requiere_firma_paciente	boolean	No		Si es verdadero, el documento generado se envía al paciente para su firma.
requiere_firma_profesional	boolean	No		Si es verdadero, el documento queda Pendiente hasta la contrafirma del profesional.
tipo	integer	No		Tipo de documento que genera la plantilla. Valores: 0 FichaClinica, 1 Recomendacion, 2 Consentimiento.
updated_at	timestamptz	No		Fecha y hora de la última modificación, en UTC.

Tabla servicios_documento. Qué plantillas exige cada servicio y en qué momento de la atención se generan.

Columna	Tipo	Nulo	Restricciones	Descripción
id	integer	No	PK, identidad	Identificador del registro, generado por la base como columna de identidad.

Columna	Tipo	Nulo	Restricciones	Descripción
created_at	timestamptz	No		Fecha y hora de creación, en UTC.
momento	integer	No		Momento de la atención en que se genera el documento. Valores: 0 TrasConfirmarReserva, 1 AlFinalizarAtencion.
obligatorio	boolean	No		Indica si el documento es obligatorio para la atención.
plantilla_id	integer	No	FK → plantillas; Único con servicio_id	Plantilla exigida.
servicio_id	integer	No	FK → servicios; Único con plantilla_id	Servicio que exige la plantilla. Único junto con plantilla_id.
vigencia_dias	integer	Sí		Días durante los que un consentimiento firmado con la misma huella cubre las citas siguientes del mismo paciente. Nulo: se firma en cada cita.

Tabla adjuntos. Metadatos de los archivos de respaldo de un documento. El archivo vive en el volumen de adjuntos, no en la base.

Columna	Tipo	Nulo	Restricciones	Descripción
id	integer	No	PK, identidad	Identificador del registro, generado por la base como columna de identidad.
created_at	timestamptz	No	Por omisión CURRENT_TIMESTAMP	Fecha y hora de creación, en UTC.
documento_id	integer	No	FK → documentos	Documento al que respalda.
nombre_original	text	No		Nombre del archivo tal como se subió. Solo para mostrar.
ruta_interna	text	No		Nombre opaco (GUID) en el volumen de adjuntos. No deriva del nombre original ni de datos del paciente.
subido_por_usuario_id	integer	No	FK → usuarios_personal	Usuario del personal que lo adjuntó.

Columna	Tipo	Nulo	Restricciones	Descripción
tamano_bytes	bigint	No		Peso del archivo.
tipo_mime	text	No		Tipo detectado por los bytes iniciales del archivo, no por su extensión.

3.3.4 Ventas y Finanzas

Estas tablas registran los cobros y las tasas con que se calculan el IVA, la comisión del terminal y el reparto. Las tasas tienen vigencia por fecha y nunca se sobrescriben.

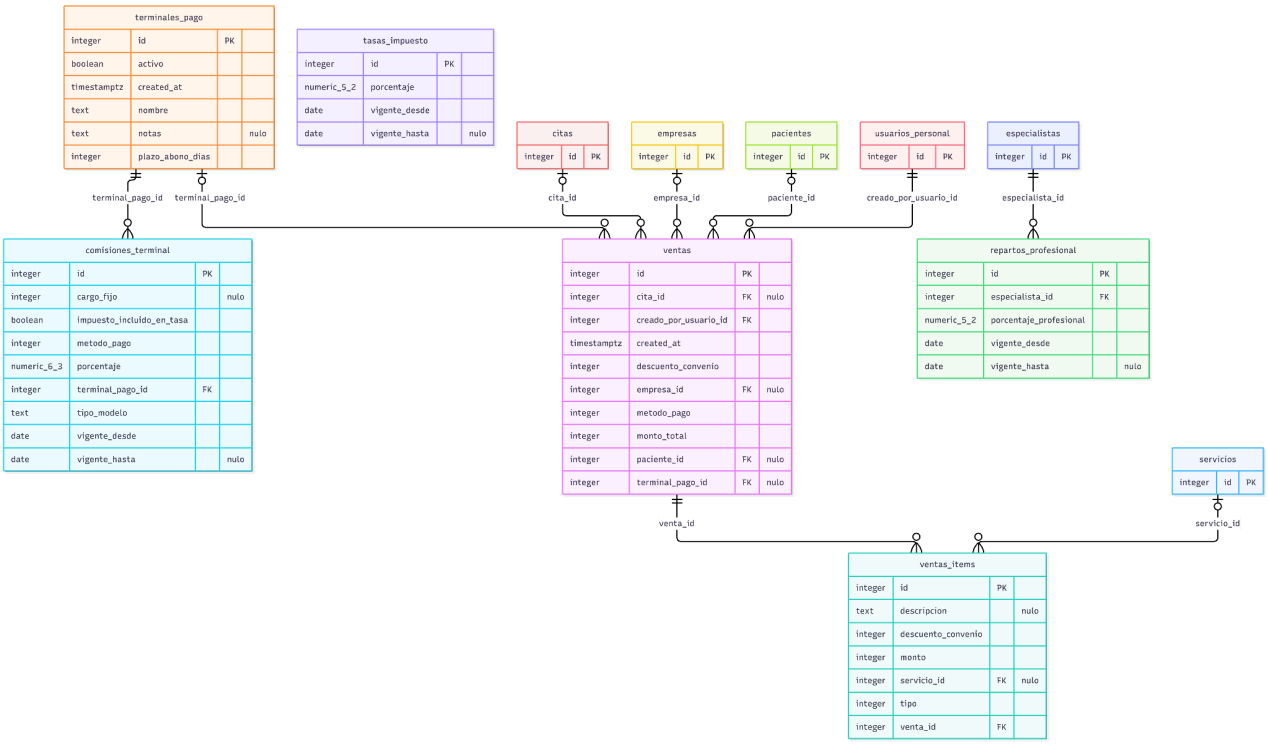


Figura III.5 Diagrama entidad relación: ventas y finanzas

Tabla ventas. Cobro registrado de una atención. Persiste hechos, no cálculos: IVA, comisión y reparto se calculan al leer.

Columna	Tipo	Nulo	Restricciones	Descripción
id	integer	No	PK, identidad	Identificador del registro, generado por la base como columna de identidad.
cita_id	integer	Sí	FK → citas	Cita cobrada. Nula si la venta solo tiene ítems no agendados.

Columna	Tipo	Nulo	Restricciones	Descripción
creado_por_usuario_id	integer	No	FK → usuarios_personal	Usuario del personal que registró el cobro.
created_at	timestamptz	No	Por omisión CURRENT_TIMESTAMP	Fecha y hora de creación, en UTC.
descuento_convenio	integer	No		Suma de los descuentos por convenio de los ítems, en pesos.
empresa_id	integer	Sí	FK → empresas	Convenio del paciente al momento de la venta. Se persiste para que un cambio posterior no altere lo cobrado.
metodo_pago	integer	No		Método con que se pagó. Valores: 0 Efectivo, 1 Transferencia, 2 Debito, 3 Credito.
monto_total	integer	No		Total cobrado en pesos, calculado en el servidor como suma de los ítems.
paciente_id	integer	Sí	FK → pacientes	Paciente que paga.
terminal_pago_id	integer	Sí	FK → terminales_pago	Terminal usado. Nulo en efectivo y transferencia.

Tabla ventas_items. Líneas de una venta: servicios del catálogo, productos o propinas.

Columna	Tipo	Nulo	Restricciones	Descripción
id	integer	No	PK, identidad	Identificador del registro, generado por la base como columna de identidad.
descripcion	text	Sí		Glosa de la línea cuando no proviene del catálogo.
descuento_convenio	integer	No		Descuento por convenio aplicado a la línea, en pesos.
monto	integer	No		Monto de la línea en pesos.
servicio_id	integer	Sí	FK → servicios	Servicio del catálogo, cuando la línea corresponde a una prestación.
tipo	integer	No		Clase de línea. Valores: 0 Servicio, 1 Producto, 2 Propina.

Columna	Tipo	Nulo	Restricciones	Descripción
venta_id	integer	No	FK → ventas	Venta a la que pertenece la línea.

Tabla terminales_pago. Máquinas de pago con tarjeta con que opera el centro.

Columna	Tipo	Nulo	Restricciones	Descripción
id	integer	No	PK, identidad	Identificador del registro, generado por la base como columna de identidad.
activo	boolean	No		Indica si el registro está vigente. Se desactiva en lugar de eliminarse.
created_at	timestamptz	No	Por omisión CURRENT_TIMESTAMP	Fecha y hora de creación, en UTC.
nombre	text	No	Único	Nombre del terminal. Único.
notas	text	Sí		Observaciones libres.
plazo_abono_dias	integer	No		Días que demora el abono de las ventas hechas con el terminal.

Tabla comisiones_terminal. Tasa que cobra un terminal por método de pago, con vigencia por fecha.

Columna	Tipo	Nulo	Restricciones	Descripción
id	integer	No	PK, identidad	Identificador del registro, generado por la base como columna de identidad.
cargo_fijo	integer	Sí		Cargo fijo por transacción en el modelo Mixto, en pesos. Nulo en el Porcentual.
impuesto_incluido_en_tasa	boolean	No		Falso si la tasa es neta y hay que sumarle el IVA vigente.
metodo_pago	integer	No	Único con terminal_pago_id (donde vigente_hasta IS NULL)	Método de pago al que aplica la tasa. Único vigente por terminal y método. Valores: 0 Efectivo, 1 Transferencia, 2 Debito, 3 Credito.
porcentaje	numeric(6,3)	No		Tasa en porcentaje, con tres decimales.

Columna	Tipo	Nulo	Restricciones	Descripción
terminal_pago_id	integer	No	FK → terminales_pago; Único con metodo_pago (donde vigente_hasta IS NULL)	Terminal al que aplica la tasa.
tipo_modelo	text	No		Forma de cobro del terminal. Se guarda como texto: Porcentual, Mixto.
vigente_desde	date	No		Inicio de la vigencia.
vigente_hasta	date	Sí		Fin de la vigencia. Nulo mientras rige: solo puede haber una tasa vigente por terminal y método.

Tabla repartos_profesional. Porcentaje de la base de reparto que corresponde a cada especialista, con vigencia por fecha.

Columna	Tipo	Nulo	Restricciones	Descripción
id	integer	No	PK, identidad	Identificador del registro, generado por la base como columna de identidad.
especialista_id	integer	No	FK → especialistas; Único (donde vigente_hasta IS NULL)	Especialista del acuerdo. Un solo acuerdo vigente por especialista (índice filtrado).
porcentaje_profesional	numeric(5,2)	No		Porcentaje de la base de reparto que corresponde a la profesional; el resto es del centro.
vigente_desde	date	No		Inicio de la vigencia.
vigente_hasta	date	Sí		Fin de la vigencia. Nulo mientras rige.

Tabla tasas_impuesto. Tasa de IVA vigente por fecha.

Columna	Tipo	Nulo	Restricciones	Descripción
id	integer	No	PK, identidad	Identificador del registro, generado por la base como columna de identidad.

Columna	Tipo	Nulo	Restricciones	Descripción
porcentaje	numeric(5,2)	No		Tasa de IVA en porcentaje.
vigente_desde	date	No		Inicio de la vigencia.
vigente_hasta	date	Sí		Fin de la vigencia. Nulo mientras rige.

3.3.5 Sitio Público y Configuración

Estas tablas guardan el contenido que el sitio público lee desde la API y los interruptores globales del sistema.

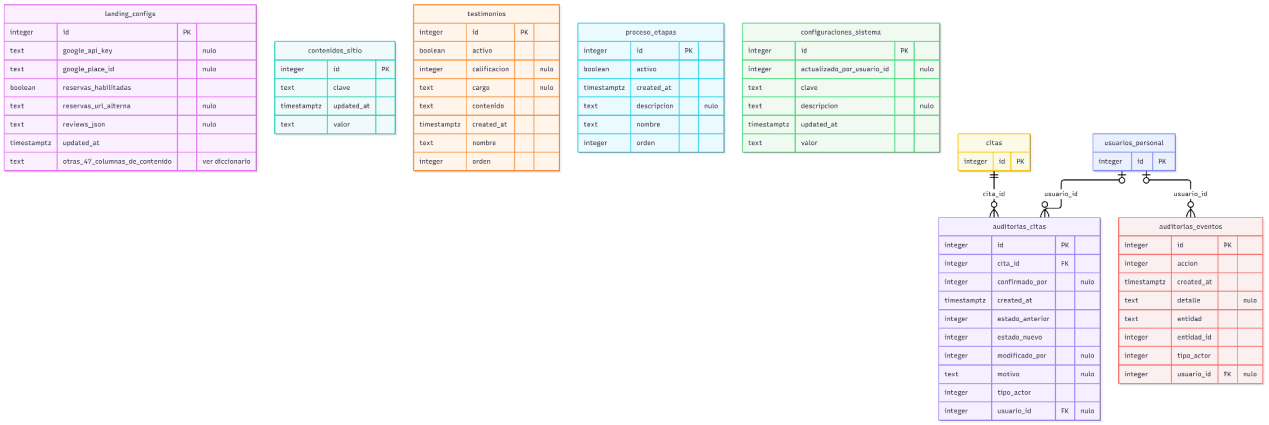


Figura III.6 Diagrama entidad relación: sitio público, configuración y auditoría

Tabla landing_configs. Configuración del sitio público: textos, imágenes, contacto, redes y el interruptor de reservas. Fila única.

Columna	Tipo	Nulo	Restricciones	Descripción
id	integer	No	PK, identidad	Identificador del registro, generado por la base como columna de identidad.
about_badge_text	text	Sí		Sección Quiénes Somos: texto de la etiqueta.
about_cta_text	text	Sí		Sección Quiénes Somos: texto del botón de acción.
about_description	text	Sí		Sección Quiénes Somos: texto descriptivo.
about_features_json	text	Sí		Sección Quiénes Somos: características destacadas, en JSON.

Columna	Tipo	Nulo	Restricciones	Descripción
about_title	text	Sí		Sección Quiénes Somos: título.
about_video_url	text	Sí		Sección Quiénes Somos: URL del video o reel de Instagram.
clinic_address	text	No		Datos de contacto del centro: dirección.
clinic_email	text	No		Datos de contacto del centro: correo.
clinic_name	text	No		Datos de contacto del centro: nombre.
clinic_phone	text	No		Datos de contacto del centro: teléfono para mostrar.
clinic_phone_raw	text	No		Datos de contacto del centro: teléfono sin formato, para enlaces.
embarazadas_json	text	Sí		Sección de atención a embarazadas: tarjetas, en JSON.
embarazadas_subtitle	text	Sí		Sección de atención a embarazadas: subtítulo.
embarazadas_title	text	Sí		Sección de atención a embarazadas: título.
footer_text	text	Sí		Texto del pie de página.
google_api_key	text	Sí		Clave de Google Places para sincronizar reseñas. Tiene precedencia la clave GooglePlaces:ApiKey de la configuración del servidor.
google_place_id	text	Sí		Place ID de Google Maps usado para sincronizar reseñas.
google_reviews_url	text	Sí		Enlace a las reseñas de Google del centro.
hero_badge_text	text	Sí		Portada del sitio: texto de la etiqueta.
hero_brand_name	text	No		Portada del sitio: nombre de marca.
hero_bullets_json	text	Sí		Portada del sitio: viñetas, en JSON.

Columna	Tipo	Nulo	Restricciones	Descripción
hero_cta_text	text	No		Portada del sitio: texto del botón de acción.
hero_description	text	No		Portada del sitio: texto descriptivo.
hero_image_url	text	Sí		Portada del sitio: URL de imagen.
hero_image_url1	text	Sí		Portada del sitio: URL de imagen 1 del carrusel.
hero_image_url2	text	Sí		Portada del sitio: URL de imagen 2 del carrusel.
hero_image_url3	text	Sí		Portada del sitio: URL de imagen 3 del carrusel.
hero_tagline	text	No		Portada del sitio: frase principal.
hours_saturday	text	No		Horario publicado: sábado.
hours_weekday	text	No		Horario publicado: lunes a viernes.
location_apple_maps_url	text	Sí		Sección de ubicación: enlace a Apple Maps.
location_subtitle	text	Sí		Sección de ubicación: subtítulo.
location_title	text	Sí		Sección de ubicación: título.
process_steps_json	text	Sí		Sección de proceso de atención: pasos, en JSON.
process_subtitle	text	Sí		Sección de proceso de atención: subtítulo.
process_title	text	Sí		Sección de proceso de atención: título.
reservas_habilitadas	boolean	No		Interruptor global de reservas en línea. Si es falso, la API rechaza crear citas web e iniciar pagos.
reservas_url_alterna	text	Sí		Enlace alternativo que muestra el sitio cuando las reservas en línea están desactivadas.
reviews_json	text	Sí		Reseñas sincronizadas desde Google Places, en JSON.
social_facebook	text	No		Enlace a red social: Facebook.

Columna	Tipo	Nulo	Restricciones	Descripción
social_instagram	text	No		Enlace a red social: Instagram.
social_tik_tok	text	No		Enlace a red social: TikTok.
social_whats_app	text	No		Enlace a red social: WhatsApp.
team_subtitle	text	Sí		Sección del equipo: subtítulo.
team_title	text	Sí		Sección del equipo: título.
testimonials_subtitle	text	Sí		Sección de testimonios: subtítulo.
testimonials_title	text	Sí		Sección de testimonios: título.
updated_at	timestamptz	No		Fecha y hora de la última modificación, en UTC.
vouchers_json	text	Sí		Sección de vouchers de regalo: tarjetas, en JSON.
vouchers_mostrar_nota	boolean	No		Sección de vouchers de regalo: si es verdadero, muestra la nota.
vouchers_nota	text	Sí		Sección de vouchers de regalo: nota al pie.
vouchers_subtitle	text	Sí		Sección de vouchers de regalo: subtítulo.
vouchers_title	text	Sí		Sección de vouchers de regalo: título.

Tabla contenidos_sitio. Bloques de contenido institucional del sitio organizados por clave y valor.

Columna	Tipo	Nulo	Restricciones	Descripción
id	integer	No	PK, identidad	Identificador del registro, generado por la base como columna de identidad.
clave	text	No	Único	Clave del bloque (por ejemplo mision, vision, whatsapp). Única.
updated_at	timestamptz	No	Por omisión CURRENT_TIMESTAMP	Fecha y hora de la última modificación, en UTC.
valor	text	No		Contenido del bloque.

Tabla testimonios. Opiniones de pacientes mostradas en el sitio público.

Columna	Tipo	Nulo	Restricciones	Descripción
id	integer	No	PK, identidad	Identificador del registro, generado por la base como columna de identidad.
activo	boolean	No		Indica si el registro está vigente. Se desactiva en lugar de eliminarse.
calificacion	integer	Sí		Calificación asignada a la opinión.
cargo	text	Sí		Descripción breve de quien opina.
contenido	text	No		Texto de la opinión.
created_at	timestamptz	No	Por omisión CURRENT_TIMESTAMP	Fecha y hora de creación, en UTC.
nombre	text	No		Nombre de quien opina.
orden	integer	No		Posición en el sitio.

Tabla proceso_etapas. Etapas del mapa de procesos que muestra el sitio público.

Columna	Tipo	Nulo	Restricciones	Descripción
id	integer	No	PK, identidad	Identificador del registro, generado por la base como columna de identidad.
activo	boolean	No		Indica si el registro está vigente. Se desactiva en lugar de eliminarse.
created_at	timestamptz	No	Por omisión CURRENT_TIMESTAMP	Fecha y hora de creación, en UTC.
descripcion	text	Sí		Descripción de la etapa.
nombre	text	No		Nombre de la etapa.
orden	integer	No		Posición en el mapa de procesos.

Tabla configuraciones_sistema. Interruptores globales del sistema por clave y valor.

Columna	Tipo	Nulo	Restricciones	Descripción
id	integer	No	PK, identidad	Identificador del registro, generado por la base como columna de identidad.
actualizado_por_usuario_id	integer	Sí		Usuario del personal que hizo el último cambio. Sin restricción de clave foránea.
clave	text	No	Único	Nombre del interruptor. Única.
descripcion	text	Sí		Para qué sirve el interruptor.
updated_at	timestamptz	No		Fecha y hora de la última modificación, en UTC.
valor	text	No		Valor del interruptor.

3.3.6 Auditoría

Estas tablas son de solo inserción. El interceptor de auditoría rechaza cualquier intento de modificar o eliminar una fila. Su diagrama es la Figura III.6.

Tabla auditorias_citas. Registro inmutable de cada cambio de estado de una cita.

Columna	Tipo	Nulo	Restricciones	Descripción
id	integer	No	PK, identidad	Identificador del registro, generado por la base como columna de identidad.
cita_id	integer	No	FK → citas	Cita que cambió de estado.
confirmado_por	integer	Sí		Por qué vía se confirmó, cuando el estado nuevo es Confirmada. Valores: 0 Profesional, 1 Correo, 2 WhatsApp.
created_at	timestamptz	No	Por omisión CURRENT_TIMESTAMP	Fecha y hora de creación, en UTC.
estado_anterior	integer	No		Estado previo. Valores: 0 Pendiente (obsoleto), 1 Confirmada, 2 Cancelada, 3 Expirada, 4 PendientePago, 5 PorConfirmar, 6 Atendida, 7 NoAsistida.

Columna	Tipo	Nulo	Restricciones	Descripción
estado_nuevo	integer	No		Estado resultante. Valores: 0 Pendiente (obsoleto), 1 Confirmada, 2 Cancelada, 3 Expirada, 4 PendientePago, 5 PorConfirmar, 6 Atendida, 7 NoAsistida.
modificado_por	integer	Sí		Clasificación heredada del actor, anterior a tipo_actor. Valores: 0 Admin, 1 Sistema.
motivo	text	Sí		Motivo entregado por la operación (por ejemplo el de cancelación o el de Webpay).
tipo_actor	integer	No		Quién ejecutó el cambio. Valores: 0 Sistema, 1 Paciente, 2 Personal.
usuario_id	integer	Sí	FK → usuarios_personal	Usuario del personal, cuando el actor es Personal.

Tabla auditorias_eventos. Registro inmutable de creación, modificación y eliminación de las entidades vigiladas.

Columna	Tipo	Nulo	Restricciones	Descripción
id	integer	No	PK, identidad	Identificador del registro, generado por la base como columna de identidad.
accion	integer	No		Operación realizada. Valores: 0 Creacion, 1 Modificacion, 2 Eliminacion, 3 Lectura.
created_at	timestamptz	No	Por omisión CURRENT_TIMESTAMP	Fecha y hora de creación, en UTC.
detalle	text	Sí		Cambios en formato campo: anterior → nuevo. Omite contraseñas, tokens e IP y describe los archivos sin exponer su ruta.
entidad	text	No		Nombre de la entidad afectada (por ejemplo Servicio, Consentimiento).
entidad_id	integer	No		Identificador del registro afectado.

Columna	Tipo	Nulo	Restricciones	Descripción
tipo_actor	integer	No		Quién la ejecutó. Valores: 0 Sistema, 1 Paciente, 2 Personal.
usuario_id	integer	Sí	FK → usuarios_personal	Usuario del personal, cuando el actor es Personal.

3.4 Enumeraciones

La tabla lista las enumeraciones que se guardan en columnas, con los identificadores exactos del código y su valor entero. Agregar un valor al final de una enumeración es seguro; cambiar el orden o eliminar un valor cambia el significado de los datos existentes y exige una migración de datos.

Enumeración	Valores	Columnas
AccionAuditoria	0 Creacion, 1 Modificacion, 2 Eliminacion, 3 Lectura	auditorias_eventos.accion
CanalNotificacion	0 Correo	notificaciones.canal
EstadoBloque	0 Disponible, 1 Bloqueado, 2 Reservado	bloques_horarios.estado
EstadoCita	0 Pendiente (obsoleto), 1 Confirmada, 2 Cancelada, 3 Expirada, 4 PendientePago, 5 PorConfirmar, 6 Atendida, 7 NoAsistida	auditorias_citas.estado_anterior, auditorias_citas.estado_nuevo, citas.estado
EstadoDocumento	0 Borrador, 1 Pendiente, 2 Completado, 3 Bloqueado, 4 CerradoPorBaja, 5 Anulado	documentos.estado
EstadoNotificacion	0 Pendiente, 1 Enviada, 2 Fallida	notificaciones.estado
EstadoTransaccion	0 Iniciado, 1 Aprobado, 2 Rechazado, 3 Expirado	transacciones.estado
MetodoPago	0 Efectivo, 1 Transferencia, 2 Debito, 3 Credito	comisiones_terminal.metodo_pago, ventas.metodo_pago
ModificadoPor	0 Admin, 1 Sistema	auditorias_citas.modificado_por
MomentoDocumento	0 TrasConfirmarReserva, 1 AlFinalizarAtencion	servicios_documento.momento
OrigenCita	0 Web, 1 Manual	citas.origen
OrigenConfirmacion	0 Profesional, 1 Correo, 2 WhatsApp	auditorias_citas.confirmado_por, citas.confirmado_por
OrigenCreacionDocumento	0 GeneradoDesdePlantilla, 1 ArchivoCargado	documentos.origen_creacion
OrigenDocumento	0 Firmado, 1 Adjunto	documentos.origen

Enumeración	Valores	Columnas
OrigenFormato	0 Constructor, 1 Documento	plantillas.origen
OrigenRegistroPaciente	0 Web, 1 Manual	pacientes.origen_registro
RolUsuario	0 Administrador, 1 Especialista	usuarios_personal.rol
TipoActorAuditoria	0 Sistema, 1 Paciente, 2 Personal	auditorias_citas.tipo_actor, auditorias_eventos.tipo_actor, documentos.creado_por_tipo_actor
TipoDocumentoClinico	0 FichaClinica, 1 Recomendacion, 2 Consentimiento	documentos.tipo, plantillas.tipo
TipoItemVenta	0 Servicio, 1 Producto, 2 Propina	ventas_items.tipo
TipoModeloComision	0 Porcentual, 1 Mixto	comisiones_terminal.tipo_modelo
TipoNotificacion	0 Confirmacion, 1 Recordatorio, 2 CambioEstado, 3 DocumentoParaFirma, 4 DocumentoPostAtencion	notificaciones.tipo
TipoRecomendacion	0 Estandar, 1 Personalizada	documentos.tipo_recomendacion
DayOfWeek (de .NET)	0 domingo a 6 sábado	horarios_centro.dia_semana, plantillas_horario.dia_semana

El valor 0 Pendiente de EstadoCita se conserva solo por compatibilidad con datos antiguos: ninguna operación actual lo asigna. Las enumeraciones ActorTransicion, EfectoBloque, CompletadoPor y TipoCampoFormato no tienen columna propia en el esquema.

3.5 Índices y Reglas de Negocio en la Base

Varias reglas de negocio no dependen del código sino de índices únicos. Son la última barrera cuando dos peticiones compiten, y ExceptionHandlingMiddleware traduce su violación a una respuesta 409 con un mensaje comprensible.

Índice	Regla que impone
citas_bloques (bloque_horario_id)	Un bloque lo ocupa una sola cita. Impide la doble reserva.
bloques_horarios (especialista_id, fecha, hora_inicio)	Un bloque no se genera dos veces. Hace idempotente la generación de agenda.
transacciones (cita_id)	Una cita tiene como máximo una transacción de anticipo.
documentos (cita_id) donde tipo = 0, 1 y 2	Una cita tiene como máximo una ficha, una recomendación y un consentimiento. Son tres índices filtrados independientes.
documentos (token_acceso) donde no es nulo	Un enlace de firma identifica a un solo documento.

Índice	Regla que impone
notificaciones (cita_id, tipo) donde tipo es 0, 1 o 2	Una cita recibe como máximo un correo de confirmación, uno de recordatorio y uno de cambio de estado.
pacientes (rut) y pacientes (google_sub), donde no son nulos	Un RUT y una cuenta de Google pertenecen a un solo paciente.
usuarios_personal (email) y usuarios_personal (especialista_id)	Un correo abre una sola cuenta y una especialista tiene como máximo una cuenta.
comisiones_terminal (terminal_pago_id, metodo_pago) donde vigente_hasta es nulo	Un terminal tiene una sola tasa vigente por método de pago.
repartos_profesional (especialista_id) donde vigente_hasta es nulo	Una especialista tiene un solo acuerdo de reparto vigente.
horarios_centro y plantillas_horario (día y hora de inicio)	No se repiten tramos horarios para el mismo día.
servicios, empresas, plantillas y terminales_pago (nombre)	No hay nombres duplicados en los catálogos.
especialistas_servicios, servicios_documento y convenios_descuento (pares)	Cada habilitación, exigencia de documento y descuento se registra una sola vez.
contenidos_sitio (clave) y configuraciones_sistema (clave)	Cada clave de contenido o configuración es única.

Como consecuencia del índice de consentimientos, cada servicio se configura con una sola plantilla de consentimiento en servicios_documento, considerando juntos sus dos momentos: TrasConfirmarReserva y AlFinalizarAtencion.

3.6 Migraciones

El historial del esquema está en 67 migraciones, en src/Infrastructure/Data/Migrations, desde InitialCreate, del 30 de junio de 2026, hasta AgregarMotivoRechazoConsentimiento, del 22 de octubre de 2026. Las migraciones se aplican automáticamente: DataSeeder.Initialize llama a MigrateAsync al arrancar la API, antes de atender peticiones.

Para crear una migración, las herramientas de EF Core construyen la aplicación, por lo que necesitan la cadena de conexión y la clave de firma JWT como variables de entorno. Desde la raíz del repositorio del backend:

```
ConnectionStrings__PostgreSQL="<cadena>" Jwt__Secret="<clave>" \
  dotnet ef migrations add <Nombre> -p api-dotnet/reserva-citas-api.csproj
\
  -o src/Infrastructure/Data/Migrations
```

Antes de fusionar una migración conviene revisar el código generado. La instantánea del modelo registra un único índice sobre documentos.cita_id, mientras que la base contiene los tres índices

filtrados que creó la migración DocumentoHierarchyRefactor: ix_documentos_cita_id_ficha, ix_documentos_cita_id_recomendacion e ix_documentos_cita_id_consentimiento. Si una migración nueva propone eliminarlos o recrearlos, esa parte debe quitarse a mano.

> **Nota:** Como las migraciones corren al arrancar, un despliegue a main aplica también los cambios de esquema. Una migración que borra o transforma datos debe probarse primero en el entorno de prueba y contar con un respaldo reciente, como se indica en la sección 7.5.

IV. Flujos Críticos

Este capítulo describe, con diagramas de actividad, los flujos cuya falla tiene mayor impacto: la reserva y el pago, la agenda, los documentos clínicos, los correos, las sesiones y las ventas. Cada figura indica los endpoints involucrados y los códigos de error que puede devolver.

4.1 Reserva Web

La reserva web la hace el paciente desde la tarjeta de reserva del sitio. El estado del asistente vive en useBookingStore, en memoria del navegador, igual que el token del paciente.

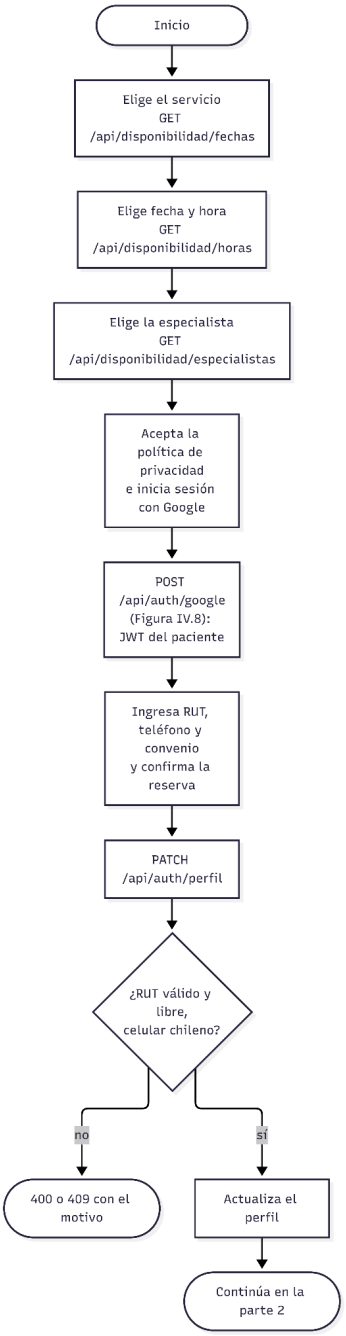


Figura IV.1 Reserva web: selección, identificación y perfil (parte 1 de 2)

La disponibilidad se consulta en tres pasos: fechas con al menos una hora viable para el servicio, horas viables en una fecha y especialistas que pueden atender a esa hora. Los tres endpoints usan CadenaBloques, de modo que el sitio nunca ofrece una hora que la reserva luego rechace. La ventana consultable es de 30 días desde hoy, en hora de Chile.

Antes de crear la cita, el frontend completa el perfil con PATCH /api/auth/perfil. La API valida el dígito verificador del RUT, que no esté registrado por otro paciente, que el teléfono sea un celular chileno y, si se indicó, que el convenio esté activo.

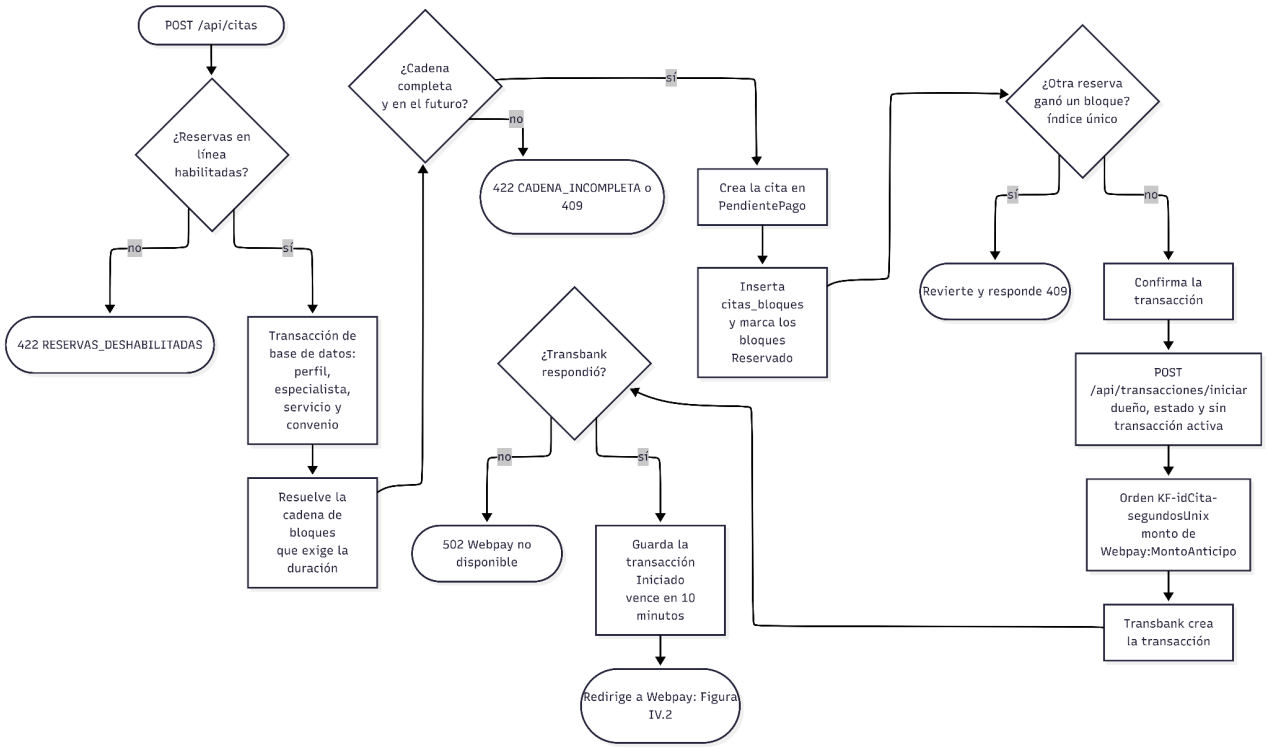


Figura IV.1 Reserva web: creación de la cita e inicio del pago (parte 2 de 2)

POST /api/citas y la reserva manual comparten el mismo método interno, CrearInternoAsync, que corre dentro de una transacción de base de datos. La cita web nace en PendientePago y sus bloques quedan Reservado. Si dos pacientes eligen el mismo bloque al mismo tiempo, ambos pueden pasar la comprobación previa, pero el índice único de citas_bloques rechaza al segundo y la API responde 409.

El monto del anticipo lo fija el servidor con Webpay:MontoAnticipo; el frontend no lo envía. La orden de compra tiene el formato KF-<id de la cita>-<segundos Unix> y la transacción vence a los Webpay:ExpiracionMinutos, 10 minutos por omisión.

4.2 Pago con Webpay Plus

Transbank devuelve al paciente a Webpay:ReturnUrl, que en producción es /confirmacion. Esa ruta reexporta la página /pago/confirmar, que decide qué hacer según los parámetros recibidos.

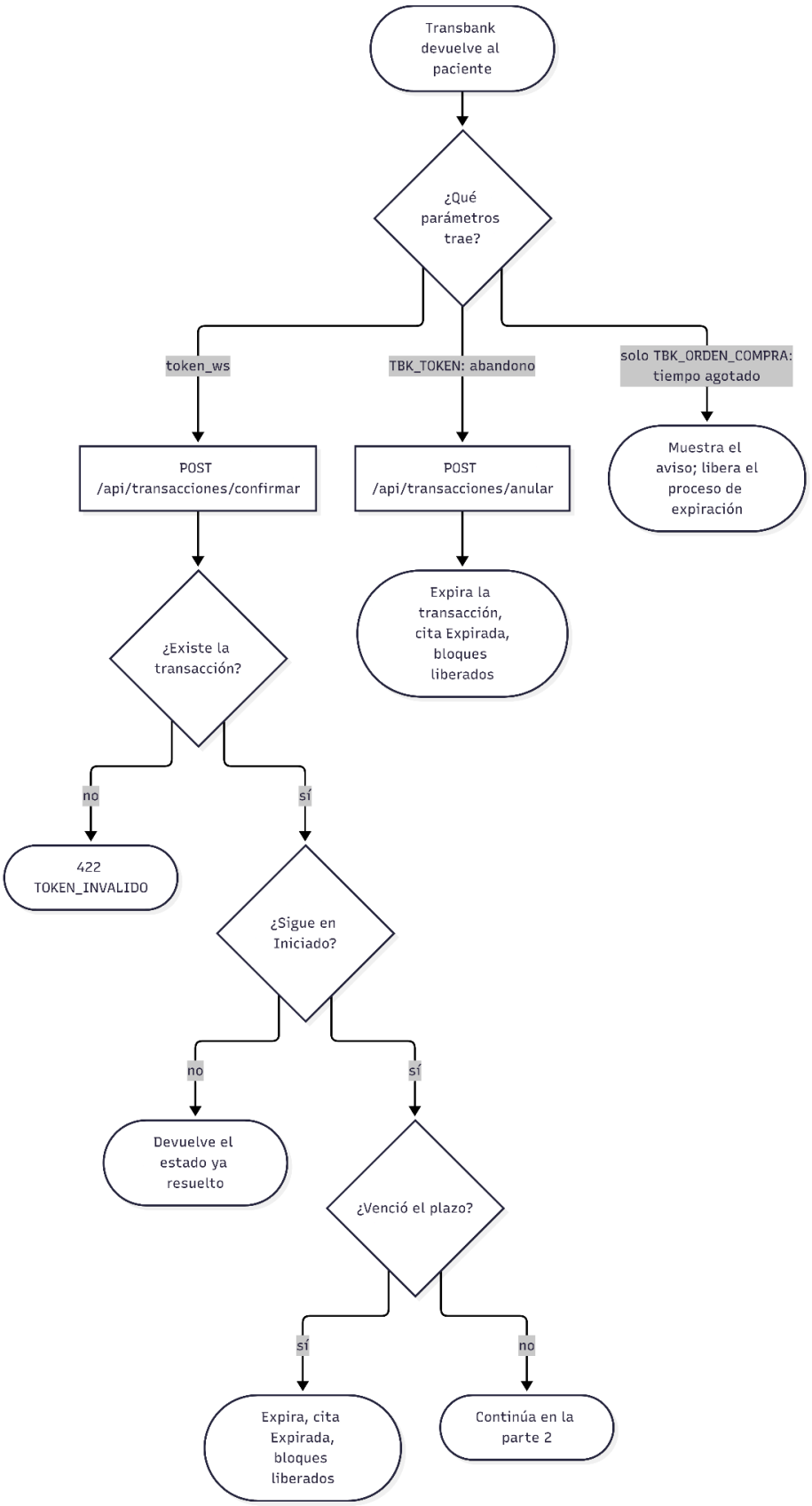


Figura IV.2 Retorno de Webpay al sitio (parte 1 de 2)

Cuando el paciente abandona el formulario de Webpay, Transbank devuelve TBK_TOKEN y la página llama a POST /api/transacciones/anular, que expira la transacción y libera los bloques.

Cuando se agota el tiempo en Webpay, solo llega TBK_ORDEN_COMPRA: la página muestra el aviso y la liberación la hace el proceso de expiración.

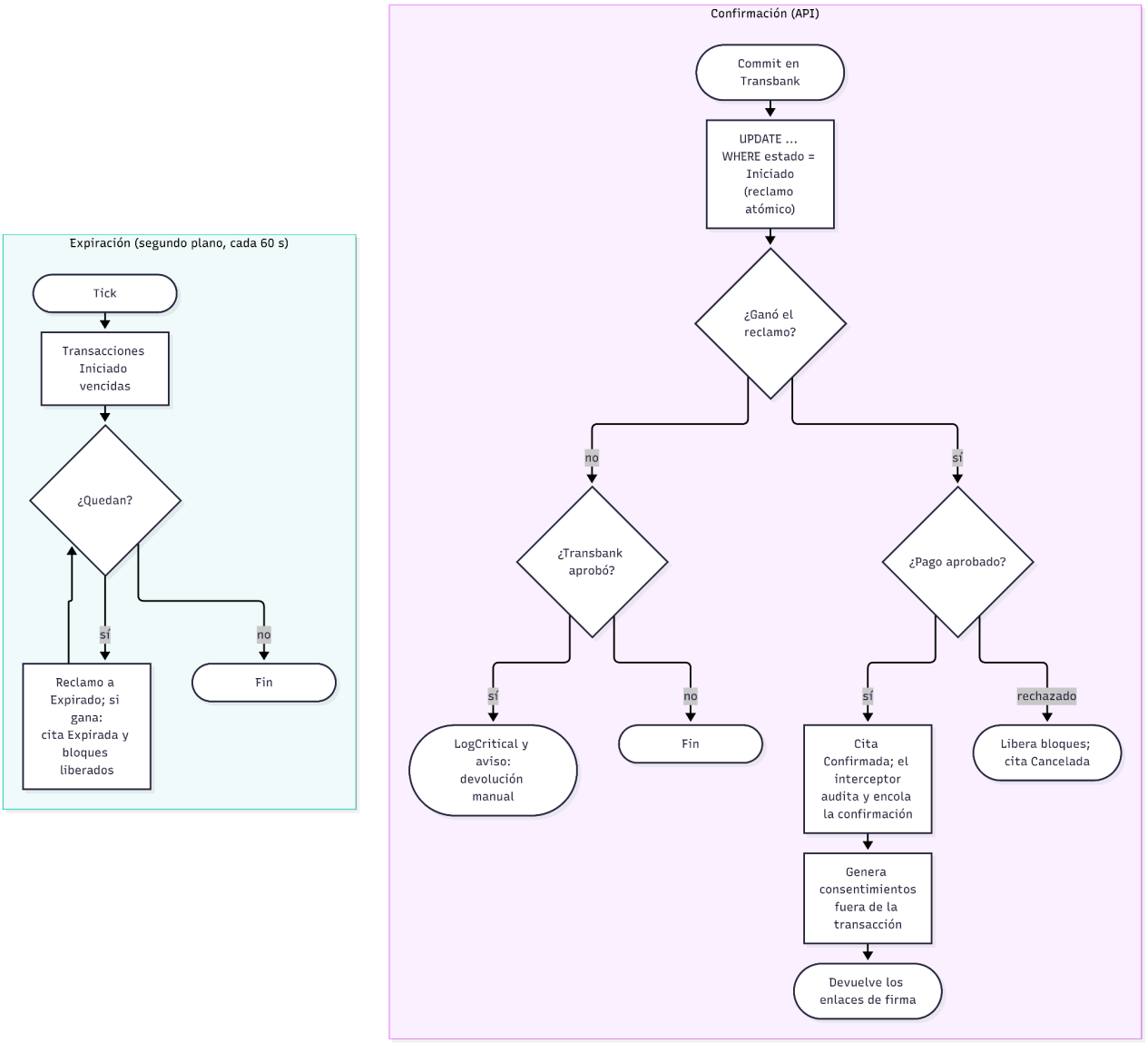


Figura IV.2 Confirmación con Transbank y expiración en segundo plano (parte 2 de 2)

Tres caminos pueden resolver una misma transacción: la confirmación, la anulación y la expiración. Todos pasan por un reclamo atómico, una actualización condicionada al estado Iniciado:

```
UPDATE transacciones SET estado = <nuevo> WHERE id = <id> AND estado = 0
```

Solo el camino cuya actualización afecta una fila continúa. La confirmación es idempotente: si la transacción ya se resolvió, devuelve el estado guardado sin volver a llamar a Transbank. Además verifica que la orden de compra informada por Transbank coincida con la guardada (ORDEN_COMPRA_NO_COINCIDE) y vuelve a comprobar el vencimiento aunque exista el proceso de expiración.

Si Transbank aprueba un pago cuyo reclamo ya lo ganó la expiración, la cita no se confirma, porque sus bloques pueden estar tomados. La API registra el caso con nivel Critical y el texto «Requiere gestión manual de devolución», y devuelve una advertencia al paciente. El procedimiento está en la sección 7.4.

La generación de consentimientos se ejecuta después de confirmar el pago y fuera de su transacción, a propósito: una falla al generar un documento no debe revertir un pago aprobado. La respuesta incluye los tokens de los documentos por firmar y la página enlaza a /documentos/{token} para cada uno.

4.3 Reserva Manual

El personal reserva desde Nueva Reserva, con el asistente de useNuevaReservaStore. La reserva manual admite de uno a tres bloques consecutivos de la misma especialista y fecha, y su cantidad debe coincidir con la duración del servicio.

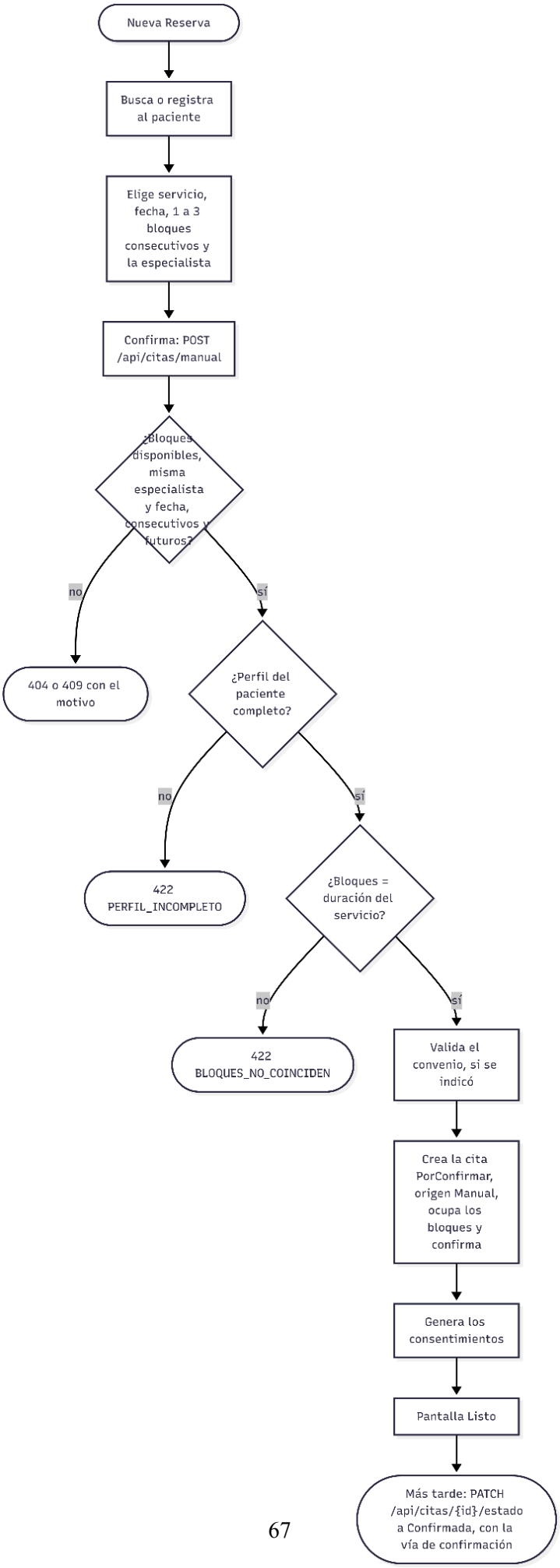

Nueva Reserva
Busca o registra al paciente
Elige servicio, fecha, 1 a 3 bloques consecutivos y la especialista
Confirma: POST /api/citas/manual
¿Bloques disponibles, misma especialista y fecha, consecutivos y futuros?
no
sí
404 o 409 con el motivo
¿Perfil del paciente completo?
no
sí
422 PERFIL_INCOMPLETO
¿Bloques = duración del servicio?
no
sí
422 BLOQUES_NO_COINCIDEN
Valida el convenio, si se indicó
Crea la cita PorConfirmar, origen Manual, ocupa los bloques y confirma
Genera los consentimientos
Pantalla Listo
Más tarde: PATCH /api/citas/{id}/estado a Confirmada, con la vía de confirmación

Figura IV.3 Reserva manual desde el panel

La cita manual nace en PorConfirmar, con origen Manual y el usuario que la registró en creado_por_usuario_id. No tiene transacción de pago. Al confirmarla, el personal indica la vía de confirmación (Profesional, Correo o WhatsApp), que queda en la cita y en la auditoría, y la nota dirigida al paciente se incluye en el correo de confirmación.

El rango horario de una cita se lee siempre de sus columnas fecha, hora_inicio y hora_fin, que se fijan al crearla a partir de su primer y su último bloque y se conservan aunque la cita termine cancelada o atendida. No se lee del bloque inicial ni de citas_bloques, cuyas filas se eliminan cuando la cita pasa a un estado que libera sus bloques. Así, el detalle (GET /api/citas/{id}) y el listado (GET /api/citas) muestran la duración real de las citas de 60 y 90 minutos.

4.4 Generación de Agenda

Los bloques no se crean a mano. GeneracionAgendaService los produce intersectando, para cada día de la semana, el horario del centro con la plantilla horaria de cada especialista, y cortando el resultado en bloques de 30 minutos. Como el centro no tiene tramo entre las 14:00 y las 15:00, la colación queda fuera sin una regla especial.

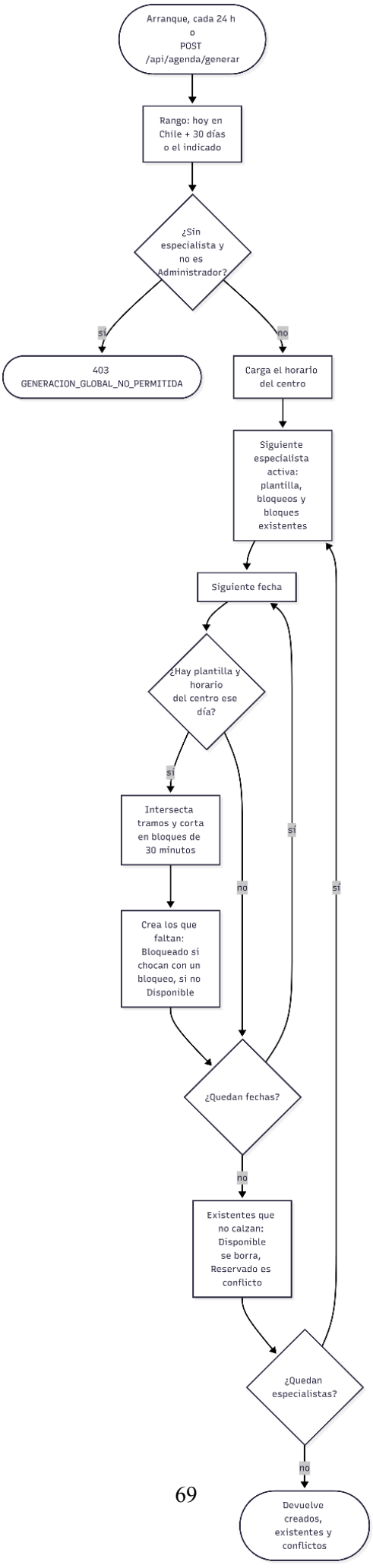

Arranque, cada 24 h
o
POST
/api/agenda/generar
Rango: hoy en
Chile + 30 días
o el indicado
¿Sin
especialista y
no es
Administrador?
sí
no
403
GENERACION_GLOBAL_NO_PERMITIDA
Carga el horario
del centro
Siguiente
especialista
activa:
plantilla,
bloqueos y
bloques
existentes
Siguiente fecha
¿Hay plantilla y
horario
del centro ese
día?
sí
Intersecta
tramos y corta
en bloques de
30 minutos
Crea los que
faltan:
Bloqueado si
chocan con un
bloqueo, si no
Disponible
no
¿Quedan fechas?
sí
no
Existentes que
no calzan:
Disponible
se borra,
Reservado es
conflicto
¿Quedan
especialistas?
sí
no
Devuelve
creados,
existentes y
conflictos

Figura IV.4 Generación de agenda (horizonte deslizante)

La generación corre al arrancar la API, cada Agenda:IntervaloGeneracionHoras (24 horas por omisión) sobre un horizonte de Agenda:HorizonteDias (30 días por omisión), y también a pedido con POST /api/agenda/generar. Es idempotente: no modifica los bloques existentes que siguen correspondiendo y reporta como conflicto los Reservado que quedaron fuera del horario, sin borrarlos, para que el personal los resuelva. Los Disponible que ya no corresponden se eliminan, salvo que alguna cita los referencie por citas.bloque_horario_id, por ejemplo una cita cancelada: esos no se pueden borrar y se retiran, es decir, pasan a Bloqueado sin bloqueo asociado. Un bloque retirado no se ofrece en la reserva ni aparece en la agenda del panel, y vuelve a quedar Disponible si el horario lo cubre de nuevo.

Una especialista solo puede generar su propia agenda. La generación global, sin especialista, está reservada al rol Administrador; los procesos internos, sin usuario, no tienen esa restricción.

4.5 Consentimientos y Firma Pública

Los consentimientos se generan a partir de las plantillas que el servicio exige en servicios_documento. La generación es idempotente y se dispara al confirmar el pago, al crear una reserva manual, al consultar el detalle de una cita y al marcarla Atendida.

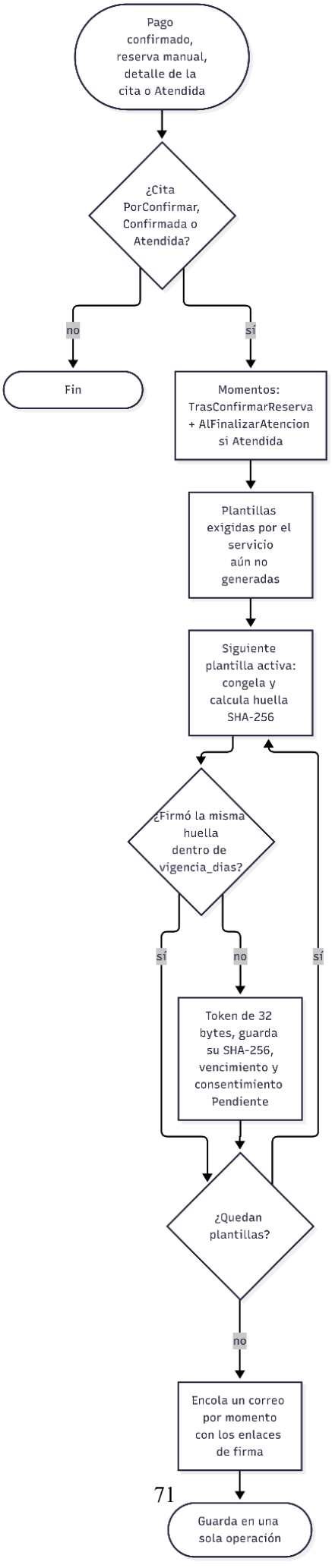

Pago confirmado, reserva manual, detalle de la cita o Atendida
¿Cita PorConfirmar, Confirmada o Atendida?
no
sí
Fin
Momentos: TrasConfirmarReserva + AlFinalizarAtencion si Atendida
Plantillas exigidas por el servicio aún no generadas
Siguiente plantilla activa: congela y calcula huella SHA-256
¿Firmó la misma huella dentro de vigencia_dias?
sí
no
sí
Token de 32 bytes, guarda su SHA-256, vencimiento y consentimiento Pendiente
¿Quedan plantillas?
no
Encola un correo por momento con los enlaces de firma
Guarda en una sola operación

Figura IV.5 Generación de consentimientos (parte 1 de 2)

Al generar un consentimiento se congela la plantilla, es decir, se guarda una copia de su nombre, tipo, origen, cuerpo y archivo, y se calcula su huella SHA-256. Si el paciente ya firmó un consentimiento con la misma huella dentro de los vigencia_dias de la plantilla, ese consentimiento cubre la cita nueva y no se genera otro.

El enlace de firma usa un token de 32 bytes aleatorios en Base64Url. En la base solo se guarda su hash SHA-256, por lo que un enlace perdido no se puede recuperar: se emite uno nuevo con POST /api/documentos/{id}/reenviar-token, que lo devuelve al panel, o con POST /api/documentos/{id}/reenviar-correo, que además lo envía por correo. El enlace es de un solo uso y vence en el mayor de dos plazos: un día desde la emisión o el inicio del día siguiente a la cita, en hora de Chile. El enlace se arma con Frontend:BaseUrl.

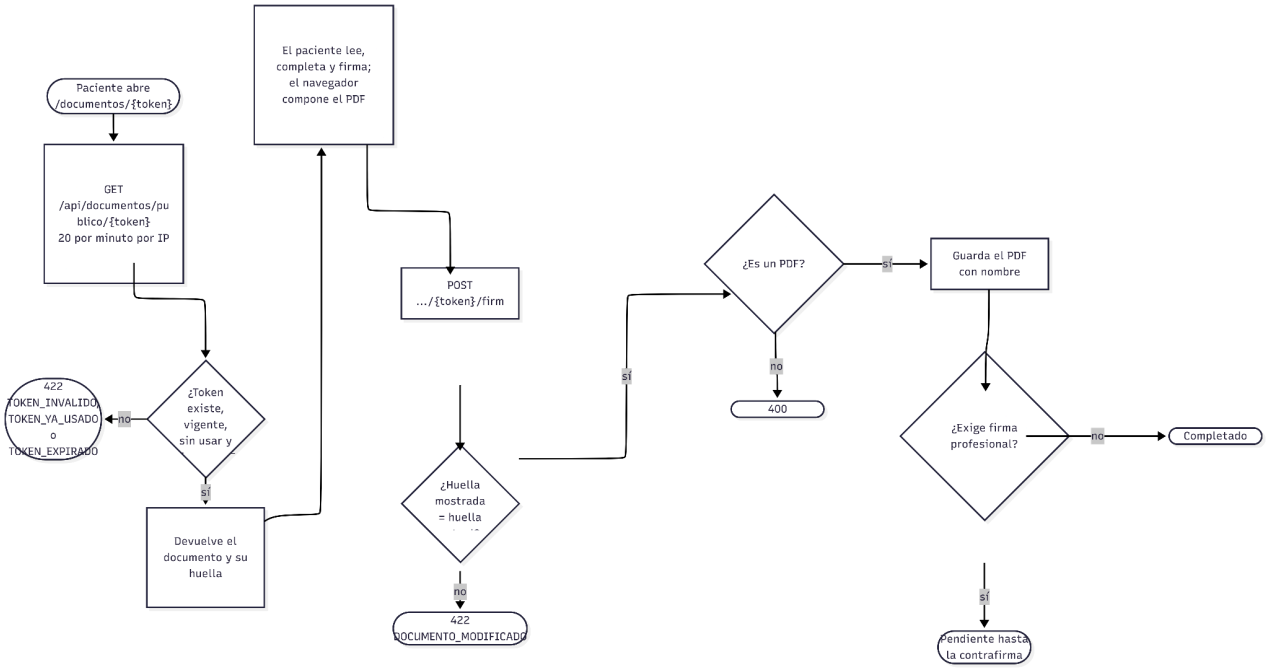


Figura IV.5 Firma pública del consentimiento (parte 2 de 2)

El navegador compone el PDF firmado con pdf-lib: lo construye a partir del cuerpo de la plantilla o estampa la firma sobre el PDF cargado, que muestra con pdfjs-dist. El servidor comprueba que la huella que vio el paciente sea la actual, verifica por sus primeros bytes que el archivo sea un PDF y lo guarda con un nombre opaco en el volumen de adjuntos. El respaldo de lo firmado está en el cuerpo congelado, la huella, la fecha de firma y la IP de origen.

Si la plantilla exige firma profesional, el documento queda Pendiente hasta que la profesional contrafirma con POST /api/documentos/{id}/firma-profesional, que exige la firma previa del paciente.

Un consentimiento entregado se puede rechazar con POST /api/documentos/{id}/rechazar y un motivo obligatorio de hasta 500 caracteres. Solo puede hacerlo la especialista de la cita o el administrador, y solo si el documento está Completado o Pendiente con la firma del paciente y la cita no está Atendida. En cualquier otro caso la API responde 422, con CITA_ATENDIDA o NO_RECHAZABLE. La respuesta del consentimiento y del detalle del documento incluye puedeRechazarse, calculado en el backend, y el panel solo muestra el botón cuando vale true.

Al rechazar, el documento vuelve a Pendiente con origen Firmado, y se vacían la firma del paciente (fecha e IP), la firma de la profesional, las referencias a los PDF firmados y al archivo en papel, y el contenido llenado por el paciente. También se vacía el token de acceso: sin eso, el enlace anterior volvería a funcionar, porque su marca de uso se reinicia. El motivo queda en motivo_rechazo y en la auditoría, y se vacía cuando el paciente vuelve a firmar en línea o cuando se carga el archivo en papel. Los archivos rechazados no se borran del volumen de adjuntos; solo dejan de estar referenciados.

La pantalla pública de firma tiene dos modos, Leer y Firmar, para que en el celular el dedo pueda recorrer el documento o dibujar la firma. El paciente puede pasar a Firmar en cualquier momento y el botón Guardar está siempre habilitado: si no dibuja, se entrega el PDF sin trazos y la revisión queda a cargo de la especialista, que puede rechazarlo. Los pasos Firmar y Revisar usan cada uno su propia instancia del visor, para que "Volver a firmar" empiece con el lienzo limpio. La pantalla de firma no ofrece la opción de pantalla completa.

4.6 Notificaciones por Correo

Los correos siguen el patrón de bandeja de salida: la operación de negocio inserta una fila en notificaciones dentro de su misma transacción, y un proceso en segundo plano la envía después. Así, una falla de Resend nunca revierte una reserva ni un pago.

Tipo	Quién lo encola	Cuándo
Confirmacion	Interceptor de auditoría	Cuando la cita pasa a Confirmada, por el pago web o por el personal.
CambioEstado	Interceptor de auditoría	Cuando el personal marca la cita como Cancelada o No Asistida.
Recordatorio	Proceso de notificaciones	Notificaciones:AntelacionRecordatorioHoras antes de una cita confirmada (24 por omisión), si se reservó con más antelación que esa.

Tipo	Quién lo encola	Cuándo
DocumentoParaFirma	DocumentoService	Al generarse los consentimientos de la cita (momento TrasConfirmarReserva) y al usar Reenviar por Correo.
DocumentoPostAtencion	DocumentoService	Al marcar la cita Atendida si el servicio tiene consentimientos AlFinalizarAtencion, y al enviar una recomendación.

Cada tipo de notificación usa su propia plantilla HTML, ubicada en src/Application/Templates/Email, y su propio asunto:

Tipo	Plantilla	Asunto
Confirmacion	Confirmacion.html	Tu cita en KineFit está confirmada
Recordatorio	Recordatorio.html	Recordatorio de tu cita en KineFit
CambioEstado	CambioEstado.html	Actualización sobre tu cita en KineFit
DocumentoParaFirma	DocumentoParaFirma.html	Documentos por firmar antes de tu cita en KineFit
DocumentoPostAtencion	DocumentoPostAtencion.html	Documentos de tu atención en KineFit

Las plantillas usan los marcadores {{ASUNTO}}, {{NOMBRE}} (nombre del paciente), {{SERVICIO}}, {{ESPECIALISTA}}, {{FECHA}} (dd-MM-yyyy), {{HORA}} (HH:mm), {{ESTADO}} (texto de la cancelación o de la inasistencia), {{NOTA}} (la nota para el paciente, solo en la confirmación) y {{ENLACES}} (una fila por documento, con el botón "Firmar" o "Ver Documento"). Los valores se escapan como HTML. El logo, la dirección, el teléfono y el correo del centro están escritos directamente en cada plantilla: si cambian, hay que editar los cinco archivos. El estilo sigue al del panel: fuente Roboto, azul de marca #0c5dc5, textos en tonos slate y tablas con estilos en línea para que Gmail y Outlook las muestren correctamente.

Si un correo falla al armarse, por ejemplo porque falta su plantilla, se registra como un envío fallido de esa notificación, con los mismos reintentos, y el proceso continúa con las demás.

> **Nota:** El correo de recomendación se encola con el nombre de la recomendación y sin enlace, porque el paciente no tiene una página donde verla. El correo le avisa que hay una recomendación, pero no le entrega su contenido.

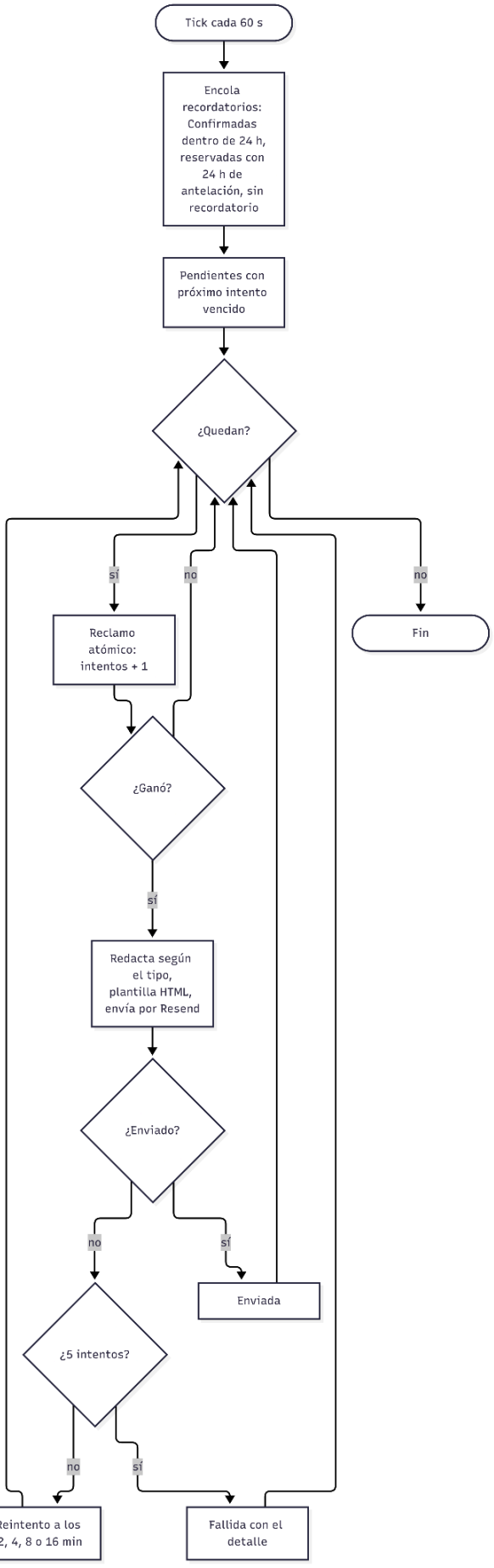


Figura IV.6 Procesamiento de notificaciones por correo

Cada Notificaciones:IntervaloProcesamientoSegundos, 60 por omisión, el proceso encola los recordatorios y toma las notificaciones pendientes cuyo próximo intento ya venció. Cada envío se reclama de forma atómica, incrementando el contador de intentos, para que no se envíe dos veces. Una falla programa un reintento a los 2, 4, 8 o 16 minutos; al quinto intento fallido la notificación queda Fallida con el detalle del error. El recordatorio no se envía a citas reservadas con menos antelación que la configurada.

4.7 Sesión del Personal

El personal inicia sesión con correo y contraseña. La contraseña se verifica con PBKDF2-HMAC-SHA256 y la respuesta es la misma para un correo inexistente y para una contraseña incorrecta.

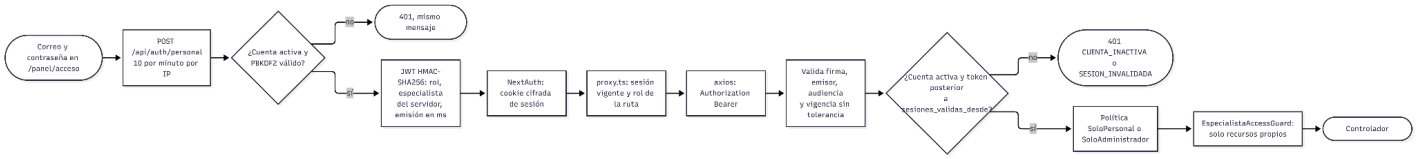


Figura IV.7 Inicio de sesión del personal y revocación de sesiones

El JWT incluye el rol y la especialista asociada a la cuenta, que el servidor resuelve desde la base y nunca acepta del cliente, y la marca emitido_en en milisegundos. En cada petición, ValidacionSesionPersonalMiddleware lee la cuenta y rechaza el token si la cuenta está inactiva (CUENTA_INACTIVA) o si fue emitido antes de sesiones_validas_desde (SESION_INVALIDADA). Desactivar una cuenta o cambiar la contraseña actualiza esa marca, lo que invalida de inmediato todas las sesiones abiertas.

Antes de cada petición del panel, axiosInstance revisa el vencimiento de la sesión de NextAuth: si venció, la cierra, avisa al usuario y no envía la petición.

4.8 Inicio de Sesión del Paciente

El paciente se identifica con su cuenta de Google. El frontend obtiene un ID token con Google Identity Services y lo envía a POST /api/auth/google junto con la aceptación de la política de privacidad.

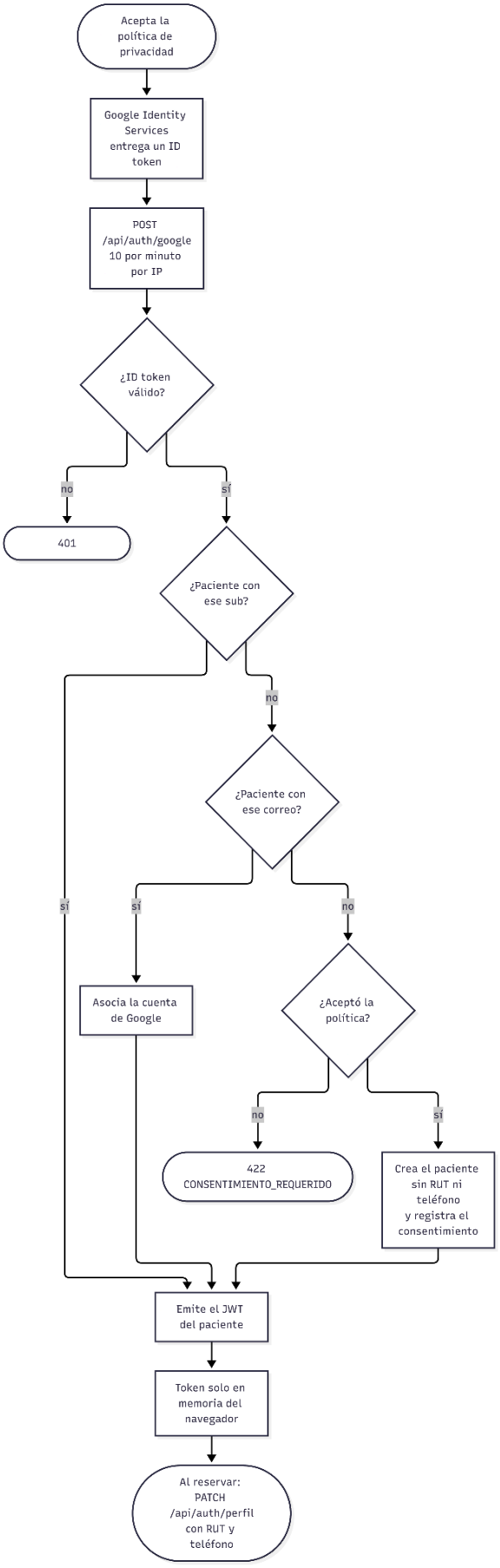


Figura IV.8 Inicio de sesión del paciente con Google

GoogleAuthService valida la firma del ID token y que su audiencia sea Google:ClientId. POST /api/auth/google acepta además un rut opcional, y el paciente se resuelve en este orden: primero por el identificador de Google (google_sub), si la cuenta ya inició sesión antes; luego por RUT, cuando el cliente lo envía y la ficha encontrada no tiene una cuenta asociada, que es el caso de la ficha creada por el personal en una atención presencial; y por último por correo, como respaldo. Si nada coincide, se crea un registro nuevo sin RUT ni teléfono, con la fecha de aceptación de la política en consentimiento_datos_en, y el perfil se completa al reservar. El JWT del paciente contiene su identificador, su correo, su nombre y el tipo de sujeto, y vive en la memoria del navegador: una recarga de la página obliga a iniciar sesión de nuevo.

Si el RUT corresponde a una ficha que ya tiene una cuenta asociada, el inicio de sesión se rechaza con RUT_CON_OTRA_CUENTA y se indica al paciente que se acerque al centro. El sitio público habilita el botón de Google solo cuando el RUT ingresado es válido.

4.9 Venta y Reparto

Una venta registra hechos, no cálculos: guarda los ítems, el método de pago, el terminal y la fecha. El IVA, la comisión y el reparto se calculan al leer, con las tasas vigentes a la fecha de la venta, de modo que un período ya cerrado siempre produce el mismo resultado.

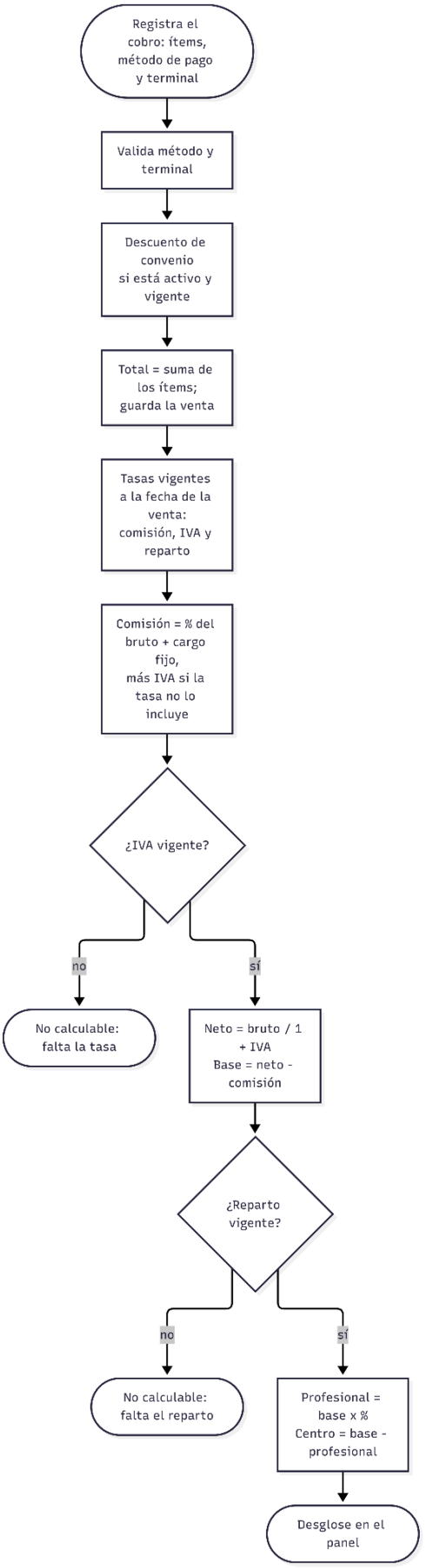


Figura IV.9 Registro de una venta y cálculo del reparto

CalculoReparto.Calcular es una función pura. Con una venta de $30.000 pagada con débito, una comisión del 2 % sin cargo fijo e IVA incluido en la tasa, IVA del 19 % y un reparto del 60 %, el cálculo es:

Concepto	**Fórmula**	**Resultado**
Comisión del terminal	30.000 × 2 %	$600
Neto	30.000 / 1,19, redondeado	$25.210
IVA	`30.000 − 25.210`	$4.790
Base de reparto	`25.210 − 600`	$24.610
Profesional	24.610 × 60 %	$14.766
Centro	`24.610 − 14.766`	$9.844

Si la tasa del terminal no incluye IVA, se suma el IVA sobre la comisión. Si a la fecha de la venta no hay tasa de IVA o acuerdo de reparto vigente, el desglose se marca como no calculable con el motivo. El descuento de convenio se informa en el desglose y no altera la fórmula.

Cada ítem de una venta debe tener un monto mayor a cero; si no, la API responde 400 con "El monto debe ser mayor a cero". El total puede quedar en cero solo si un convenio descuenta el 100 % del servicio. Si la venta trae una cita y un paciente, la cita debe pertenecer a ese paciente; si no, la API responde 422 con CITA_DE_OTRO_PACIENTE. Una cita puede tener más de una venta, por ejemplo una propina o un producto cobrado aparte: no hay restricción de unicidad. El terminal debe estar activo, y GET /api/terminales acepta el parámetro opcional soloActivos, que por omisión vale false; la ventana de cobro del panel lo usa con true.

La ventana de cobro del panel no valida el monto, porque no tiene mínimo ni escalón, y muestra el mensaje de error que devuelve la API.

V. Seguridad

Este capítulo reúne los controles de seguridad del sistema: quién puede hacer qué, cómo se protegen los documentos clínicos, cómo se administran los valores sensibles y qué queda registrado.

5.1 Autenticación, Roles y Políticas

El sistema reconoce dos tipos de sujeto, indicados en el claim tipo_sujeto del JWT:

- **Paciente:** se identifica con su cuenta de Google. Solo puede operar sobre sus propios datos y reservas.
- **Personal:** se identifica con correo y contraseña. Tiene el rol Administrador o Especialista, indicado en el claim rol.

Los dos tipos de token los firma la API con HMAC-SHA256 y la clave Jwt:Secret, con emisor KineFit, audiencia KineFit-Users y una vigencia de Jwt:ExpirationMinutes, 1440 minutos. La API valida firma, emisor, audiencia y vigencia en cada petición, sin tolerancia de reloj.

Claim	Sujeto	Contenido
sub	Ambos	Identificador de Google del paciente o id de la cuenta del personal.
tipo_sujeto	Ambos	Paciente o Personal.
paciente_id	Paciente	Id del paciente en la tabla pacientes.
usuario_id	Personal	Id de la cuenta en usuarios_personal.
rol	Personal	Administrador o Especialista.
especialista_id	Personal	Especialista asociada a la cuenta, resuelta por el servidor. Solo si existe.
debe_cambiar_password	Personal	Indica si la cuenta debe cambiar su contraseña.
emitido_en	Personal	Momento de emisión en milisegundos Unix, usado para revocar sesiones.
email y name	Ambos	Correo y nombre, para mostrar en la interfaz.

Los controladores no razonan sobre claims: declaran una de tres políticas con nombre, definidas en PolicyNames. Los endpoints sin política son públicos.

Política	Exige	Endpoints
SoloPersonal	tipo_sujeto = Personal	63
SoloAdministrador	tipo_sujeto = Personal y rol = Administrador	36
SoloPaciente	tipo_sujeto = Paciente	5
Sin política	Nada; son públicos	18

Sobre las políticas actúa EspecialistaAccessGuard. Cuando la cuenta tiene el rol Especialista, la guarda acota las operaciones a su propia especialista: puede consultar la agenda, las fichas y los documentos de las demás profesionales, e incluso agendar en sus horarios, pero no cambiar el estado de sus citas ni editar sus fichas, plantillas horarias o bloqueos. Un intento sobre un recurso ajeno responde 403 con el código ESPECIALISTA_AJENO. Del lado del paciente, cada consulta se filtra por el paciente_id del token.

Las contraseñas del personal se guardan con PBKDF2-HMAC-SHA256, 100.000 iteraciones, una sal aleatoria de 16 bytes y una clave derivada de 32 bytes, con el formato <iteraciones>.<sal>.<clave> en Base64. La verificación compara en tiempo constante. El inicio de sesión del personal y el del paciente comparten el límite AuthPersonal, 10 peticiones por minuto por IP.

5.2 Controles OWASP ASVS 4.0.3, Nivel 1

La tabla relaciona cada requisito del nivel 1 de ASVS 4.0.3 cubierto por el sistema con el control que lo implementa. Solo se listan requisitos con un control implementado y verificable en el código o en la configuración del servidor.

Requisito	Exigencia	Control en KineFit
2.2.1	Controles contra la automatización de ataques a las credenciales.	Límite AuthPersonal de 10 intentos por minuto por IP en POST /api/auth/personal y POST /api/auth/google, con respuesta 429.
3.2.1	Un token de sesión nuevo en cada autenticación.	Cada inicio de sesión emite un JWT nuevo con su propia marca emitido_en.
3.2.3	Almacenamiento seguro del token en el navegador.	El token del panel vive dentro de la cookie de sesión cifrada de NextAuth. El token del paciente vive solo en memoria y no se persiste.
3.3.2	Reautenticación periódica.	El JWT y la cookie del panel duran como máximo 24 horas; después se exige iniciar sesión de nuevo.
3.4.1 a 3.4.3	Cookies de sesión con los atributos Secure, HttpOnly y SameSite.	NextAuth emite la cookie de sesión con HttpOnly, SameSite=Lax y, bajo HTTPS, Secure.

Requisito	Exigencia	Control en KineFit
4.1.1	Control de acceso aplicado en una capa de servicio confiable.	Las políticas se evalúan en la API. proxy.ts del frontend solo controla la navegación.
4.1.2	Atributos de control de acceso no manipulables por el usuario.	La especialista asociada, el monto del anticipo y el total de una venta los resuelve el servidor y nunca se aceptan del cliente.
4.1.3	Mínimo privilegio.	Tres políticas con nombre y la guarda por especialista; las funciones administrativas exigen SoloAdministrador.
4.1.5	El control de acceso falla de forma segura.	Sin token válido la respuesta es 401 y sin la política requerida es 403; una excepción no concede acceso.
4.2.1	Protección contra el acceso directo a objetos ajenos.	EspecialistaAccessGuard (ESPECIALISTA_AJENO) y filtros por paciente_id (CITA_AJENA).
4.2.2	Protección contra la falsificación de peticiones entre sitios.	La API se autentica con el encabezado Authorization y no con cookies; los formularios de NextAuth usan su token anti falsificación.
4.3.2	Sin listado de directorios ni exposición de metadatos de archivos.	La API no sirve archivos estáticos; los adjuntos se entregan solo por endpoints autorizados.
5.1.3	Validación positiva de las entradas.	Validación de modelos de ASP.NET, validadores de RUT y teléfono y listas cerradas de valores.
5.1.4	Datos estructurados con tipos estrictos.	DTO tipados en la API y contrato tipado en models del frontend, validado con zod en los formularios.
5.3.4	Consultas parametrizadas.	Entity Framework Core parametriza las consultas; las sentencias SQL escritas a mano usan ExecuteSqlInterpolatedAsync, que convierte cada valor en un parámetro.
11.1.1	Los flujos de negocio respetan su orden.	MaquinaEstadosCita solo admite las ocho transiciones declaradas.
11.1.5	Límites de negocio contra riesgos previsibles.	Índice único contra la doble reserva, reclamo atómico de pagos y expiración a los 10 minutos.
12.1.1	No se aceptan archivos que puedan llenar el almacenamiento.	Límite de 30 MB en Kestrel y en nginx, y de 25 MB para las imágenes del sitio.
12.3.1	El nombre entregado por el usuario no se usa en el sistema de archivos.	Los archivos se guardan con un GUID como nombre.
12.4.1	Archivos no confiables fuera de la raíz web.	El volumen de adjuntos está fuera de la imagen y no se publica por nginx.
12.5.2	Los archivos cargados no se ejecutan como HTML o JavaScript.	Solo se admiten PDF e imágenes, reconocidos por su contenido, y se entregan con su tipo MIME real.

Requisito	Exigencia	Control en KineFit
13.2.1	Solo los métodos HTTP válidos para cada acción.	Cada acción declara su verbo con los atributos HttpGet, HttpPost, HttpPut, HttpPatch o HttpDelete.
14.5.3	CORS con una lista estricta de orígenes.	Política AllowedEcosystem con los orígenes de CORS:AllowedOrigins.

5.3 Protección de los Documentos Clínicos

Los documentos clínicos tienen los controles más estrictos del sistema:

- **Acceso:** todos los endpoints de documentos, salvo los tres públicos de firma, exigen SoloPersonal. Un token de paciente recibe 403, incluso en la descarga de adjuntos.
- **Almacenamiento:** los archivos se guardan en Adjuntos:RutaBase, dentro del volumen /var/lib/kinefit/adjuntos, con nombres opacos. La base guarda solo sus metadatos.
- **Validación:** el tipo de cada archivo se determina por sus primeros bytes, no por su extensión ni por el tipo declarado. Se admiten PDF, JPEG, PNG, GIF, BMP y WEBP.
- **Firma pública:** los enlaces públicos usan tokens aleatorios de un solo uso, guardados como hash y con vencimiento; sus endpoints tienen el límite DocumentosPublicos de 20 peticiones por minuto por IP.
- **Integridad:** el cuerpo congelado y su huella SHA-256 garantizan que el paciente firma exactamente lo que leyó.
- **Trazabilidad:** consultar el historial clínico de un paciente deja una fila de Lectura en auditorias_eventos.

El token de firma viaja en la ruta del enlace, por lo que aparece en los registros de acceso de nginx. Su riesgo está acotado porque el token es de un solo uso y de vida corta.

5.4 Secretos y Configuración Sensible

Ningún valor sensible se versiona. El archivo appsettings.json del backend está excluido del repositorio y el servidor mantiene el suyo en /etc/kinefit/appsettings.json. Los valores sensibles llegan a los contenedores por dos vías: el archivo montado y las variables de entorno que el flujo de despliegue toma de los secretos de GitHub.

Valor	Clave o variable	Dónde se entrega
Cadena de conexión a PostgreSQL	ConnectionStrings:PostgreSQL	Secretos DB_CONNECTION_STRING y DB_CONNECTION_STRING_TEST
Clave de firma de los JWT	Jwt:Secret	Archivo de configuración del servidor

Valor	Clave o variable	Dónde se entrega
Credenciales de Webpay	Webpay:CommerceCode y Webpay:ApiKey	Archivo de configuración del servidor
Clave de Resend	ResendAPIKey	Archivo de configuración del servidor
Credenciales de Cloudinary	Cloudinary:CloudName, Cloudinary:ApiKey y Cloudinary:ApiSecret	Archivo de configuración del servidor
Clave de Google Places	GooglePlaces:ApiKey	Archivo de configuración del servidor
Administrador inicial	Seed:AdminUser:Nombre, Email y Password	Secretos SEED_ADMIN_NOMBRE, SEED_ADMIN_EMAIL y SEED_ADMIN_PASSWORD
Firma de la sesión del panel	AUTH_SECRET y NEXTAUTH_SECRET	Secreto AUTH_SECRET
Acceso SSH al servidor	Usuario y clave privada	Secretos VPS_USERNAME y VPS_SSH_KEY
Credenciales de Cloudflare R2	Remoto r2 de rclone	Configuración de rclone del usuario root

Si falta ConnectionStrings:PostgreSQL o Jwt:Secret, la API no arranca y el registro indica qué valor falta y con qué variable de entorno entregarlo. NEXT_PUBLIC_GOOGLE_CLIENT_ID y Google:ClientId contienen el identificador público del cliente OAuth de Google, que no es secreto: el primero queda incluido en el paquete del frontend al compilar.

> **Nota:** Cambiar Jwt:Secret invalida de inmediato todas las sesiones de pacientes y personal, y cambiar AUTH_SECRET cierra todas las sesiones del panel. Ambos cambios deben hacerse fuera del horario de atención.

5.5 Auditoría y Trazabilidad

AuditingSaveChangesInterceptor intercepta cada guardado de Entity Framework Core y escribe la auditoría en la misma operación, sin que los servicios tengan que llamarla:

- **auditorias_citas:** cada cambio de estado de una cita genera una fila con el estado anterior, el nuevo, el tipo de actor (Sistema, Paciente o Personal), el usuario, el motivo y, al confirmar, la vía de confirmación.
- **auditorias_eventos:** cada creación, modificación y eliminación de 27 entidades vigiladas genera una fila con la entidad, el id, la acción, el actor y el detalle del cambio. Las entidades vigiladas incluyen pacientes, especialistas, servicios, documentos, plantillas, horarios, cuentas, contenido del sitio, ventas y tasas.

El motivo de una operación, como el de una cancelación, llega al interceptor por IAuditReasonContext. Las filas de auditoría son inmutables: el interceptor rechaza cualquier intento de modificarlas o eliminarlas. El historial de una cita se consulta con GET /api/auditoria/citas/{citaId} y los eventos con GET /api/auditoria, reservado al rol Administrador.

Las acciones sobre documentos clínicos (firma del paciente y de la profesional, carga en papel, rechazo, emisión y reenvío del enlace, edición y cierre de fichas, actualización de recomendaciones y bloqueo por cancelación) dejan una frase descriptiva en IAuditReasonContext antes de guardar. Cuando la entidad modificada es un Documento y hay una frase, el interceptor la usa como detalle del evento en lugar de la lista de cambios por campo; las demás entidades vigiladas siguen registrando esa lista. Las lecturas de documentos registran "Abrió el documento." o "Abrió el archivo.". El panel muestra cada evento como "fecha, actor: detalle" y, si el evento no tiene detalle, como en las creaciones, muestra la acción en español.

Además de la auditoría, la API escribe su registro de aplicación en la salida estándar del contenedor, que se consulta con docker logs. Ese registro se pierde cuando el contenedor se elimina, lo que ocurre en cada despliegue.

VI. Infraestructura, Despliegue y Servicios Externos

6.1 Vista de Despliegue

Todo el sistema corre en un único servidor virtual. En él conviven los entornos de producción y de prueba, cada uno con su frontend, su API y su base de datos. La Figura VI.1 muestra los nodos, los contenedores y las conexiones.

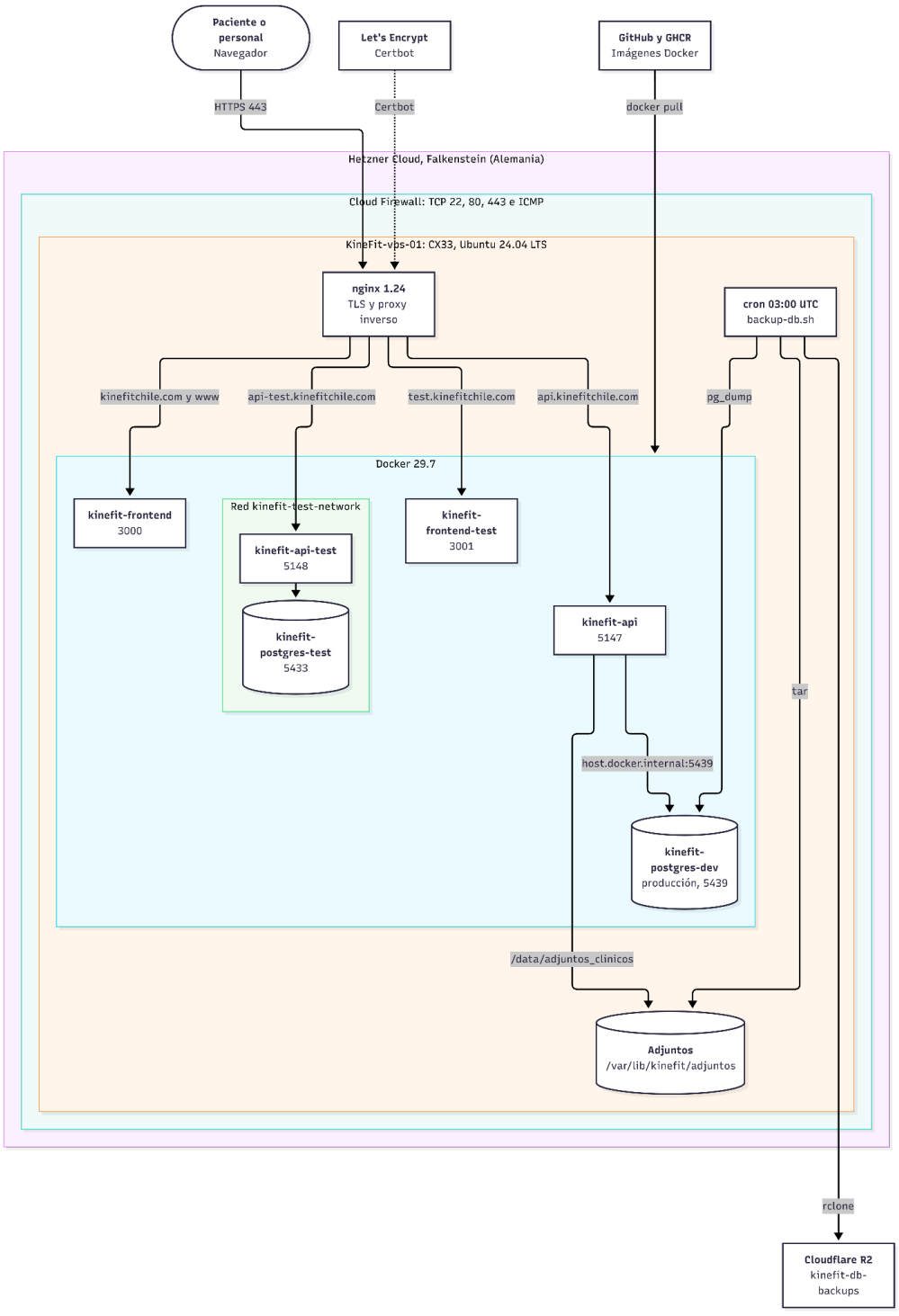


Figura VI.1 Diagrama de despliegue (C4)

6.2 Servidor

Característica	Valor
Proveedor y plan	Hetzner Cloud, plan CX33
Ubicación	Falkenstein, Alemania
Capacidad	4 vCPU compartidas, 8 GB de memoria, 80 GB de disco, sin memoria de intercambio
Tráfico incluido	20 TB mensuales
Sistema operativo	Ubuntu 24.04.4 LTS
Software en el anfitrión	nginx 1.24, Docker 29.7.2, Certbot y rclone
Firewall	Hetzner Cloud Firewall kinefit-firewall: entrada TCP 22, TCP 80, TCP 443 e ICMP

El firewall de Hetzner filtra el tráfico en la red del proveedor, antes de que llegue al servidor. Por eso ningún puerto de los contenedores es alcanzable desde Internet: solo nginx, en los puertos 80 y 443, y SSH, en el 22.

6.3 Contenedores, Redes y Volúmenes

Contenedor	Imagen	Puerto	Entorno
kinefit-frontend	ghcr.io/jhoanck7/kinefit-frontend-front:latest	3000 → 3000	Producción
kinefit-api	ghcr.io/jhoanck7/kinefit-backend-api:latest	5147 → 8080	Producción
kinefit-postgres-dev	postgres:16-alpine	5439 → 5432	Producción
kinefit-frontend-test	ghcr.io/jhoanck7/kinefit-frontend-front:test	3001 → 3000	Prueba
kinefit-api-test	ghcr.io/jhoanck7/kinefit-backend-api:test	5148 → 8080	Prueba
kinefit-postgres-test	postgres:16-alpine	5433 → 5432	Prueba

> **Nota:** A pesar de su nombre, kinefit-postgres-dev es la base de datos de producción. Se creó con Docker Compose desde el clon del repositorio del backend en /opt/kinefit-backend, a partir del servicio postgres de su docker-compose.yml, y guarda sus datos en el volumen kinefit_pg_data de ese proyecto.

Todos los contenedores se ejecutan con la política de reinicio always. Las conexiones internas son las siguientes:

- **Producción:** kinefit-api usa la red por omisión de Docker y alcanza la base a través de la pasarela del anfitrión, con el nombre host.docker.internal y el puerto 5439.
- **Prueba:** kinefit-api-test y kinefit-postgres-test comparten la red kinefit-test-network y se comunican por nombre de contenedor.
- **Entrada:** nginx llega a cada contenedor por el puerto publicado en el anfitrión.

El flujo de producción del backend publica la API solo en la interfaz local, 127.0.0.1:5147. Los demás contenedores publican su puerto en todas las interfaces del anfitrión y quedan contenidos por el firewall de Hetzner.

Ruta en el anfitrión	Ruta en el contenedor	Contenido
/etc/kinefit/appsettings.json	/app/appsettings.json (kinefit-api)	Configuración de producción.
/var/lib/kinefit/adjuntos	/data/adjuntos_clinicos (kinefit-api)	Adjuntos clínicos, PDF firmados, escaneos y plantillas de producción.
/etc/kinefit-test/appsettings.json	/app/appsettings.json (kinefit-api-test)	Configuración de prueba.
/var/lib/kinefit-test/adjuntos	/data/adjuntos_clinicos_test (kinefit-api-test)	Archivos del entorno de prueba.
Volumen kinefit_pg_test_data	/var/lib/postgresql/data (kinefit-postgres-test)	Datos de la base de prueba.
/etc/kinefit/backups	No se monta	Respaldos locales, guion de respaldo y registros.

La imagen del backend se construye en dos etapas sobre mcr.microsoft.com/dotnet/sdk:10.0 y se ejecuta sobre mcr.microsoft.com/dotnet/aspnet:10.0, escuchando en el puerto 8080. La del frontend se construye sobre node:20-alpine; NEXT_PUBLIC_API_URL y NEXT_PUBLIC_GOOGLE_CLIENT_ID se incorporan al paquete durante npm run build, por lo que cambiarlos exige construir una imagen nueva.

Los archivos docker-compose.yml de los repositorios no describen el despliegue actual, que hacen los flujos de GitHub Actions con docker run. La única excepción es el servicio postgres del compose del backend, que originó la base de producción.

6.4 Publicación Web, Dominios y Certificados

nginx, instalado en el anfitrión, termina TLS y reenvía cada dominio a su contenedor. Cada bloque server reenvía las cabeceras Host, X-Real-IP, X-Forwarded-For y X-Forwarded-Proto, que la API necesita para conocer la IP y el protocolo del cliente. Certbot instaló la redirección de HTTP a HTTPS en todos los dominios.

Dominio	Destino	client_max_body_size	Certificado
kinefitchile.com y www.kinefitchile.com	127.0.0.1:3000	50M	Linaje kinefitchile.com
test.kinefitchile.com	127.0.0.1:3001	50M	Linaje kinefitchile.com
api.kinefitchile.com	localhost:5147	30M	Linaje test.kinefitchile.com
api-test.kinefitchile.com	localhost:5148	30M	Linaje api-test.kinefitchile.com

Linaje de Certbot	Nombres que cubre
kinefitchile.com	kinefitchile.com, www.kinefitchile.com y test.kinefitchile.com
test.kinefitchile.com	test.kinefitchile.com y api.kinefitchile.com
api-test.kinefitchile.com	api-test.kinefitchile.com

Los certificados son de Let's Encrypt, con clave ECDSA, y Certbot los renueva automáticamente antes de su vencimiento.

> **Nota:** El linaje llamado test.kinefitchile.com cubre también api.kinefitchile.com. Eliminarlo o dejarlo vencer deja a la API de producción sin certificado.

El límite client_max_body_size de los dominios de la API debe ser de al menos 30M, igual que el de Kestrel: si es menor, nginx rechaza los adjuntos grandes con 413 antes de que lleguen a la API.

6.5 Integración y Entrega Continua

Cada repositorio tiene dos flujos de GitHub Actions: uno de producción y uno de prueba. Cada flujo construye la imagen, la publica en GitHub Container Registry y la despliega en el servidor por SSH con appleboy/ssh-action. La Figura VI.2 muestra la secuencia.

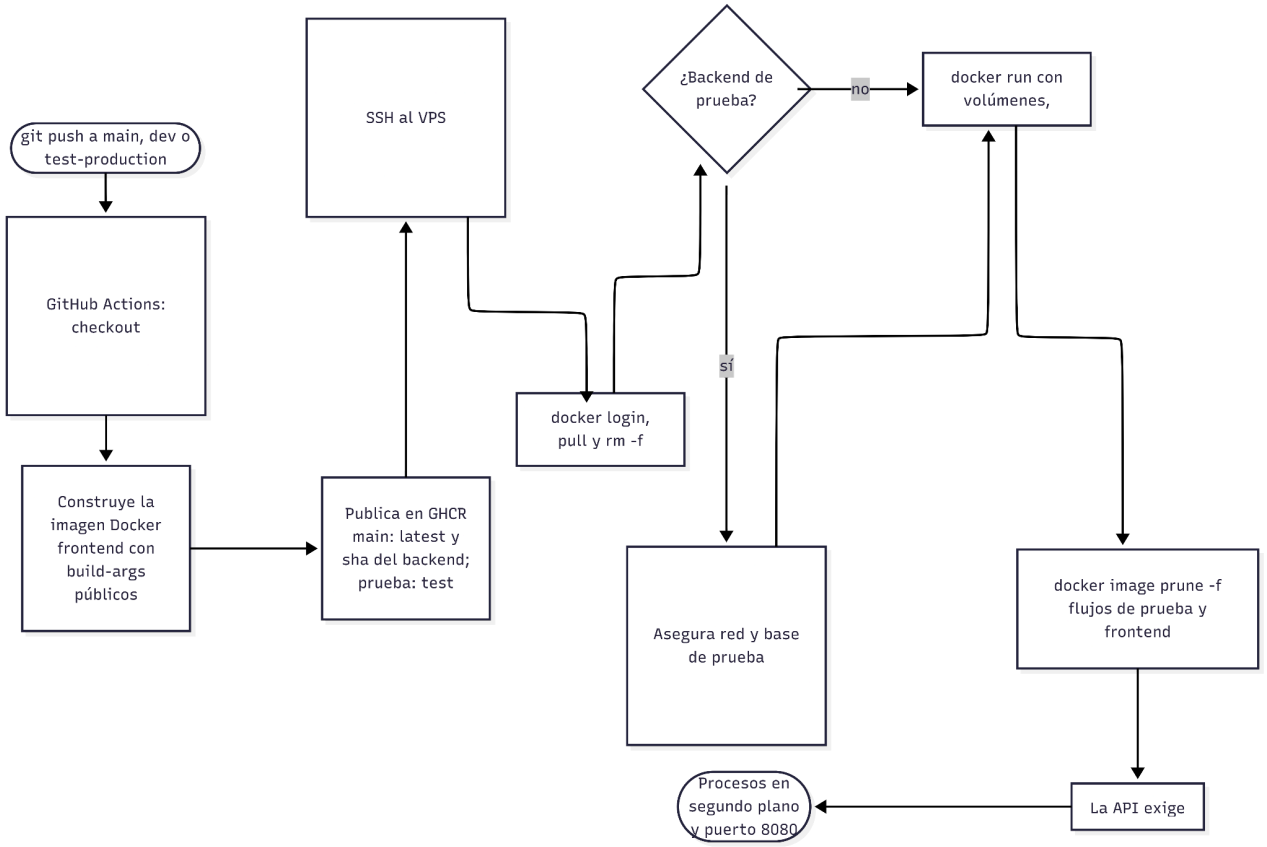


Figura VI.2 Integración y entrega continua

Repositorio	**Flujo**	**Rama**	**Etiquetas de la imagen**	**Contenedor**
kinefit-backend	Deploy Backend (GHCR)	main	latest y el sha del commit	kinefit-api
kinefit-backend	Deploy Backend Test (GHCR)	dev	test	kinefit-api-test
kinefit-frontend	Deploy Frontend Production (GHCR)	main	latest	kinefit-frontend
kinefit-frontend	Deploy Frontend Test (GHCR)	test-production	test	kinefit-frontend-test

El paso remoto de cada flujo inicia sesión en GHCR con el GITHUB_TOKEN del flujo, descarga la imagen, elimina el contenedor anterior con docker rm -f y crea el nuevo con docker run, con los mismos volúmenes, puertos y variables. Los flujos de prueba y los del frontend terminan con docker image prune -f. El flujo de prueba del backend crea además la red kinefit-test-network y la base kinefit-postgres-test si no existen.

Secreto de GitHub	**Uso**
VPS_IP, VPS_USERNAME y VPS_SSH_KEY	Conexión SSH al servidor.

Secreto de GitHub	Uso
DB_CONNECTION_STRING	Cadena de conexión de la API de producción.
DB_CONNECTION_STRING_TEST	Cadena de conexión de la API de prueba.
SEED_ADMIN_NOMBRE, SEED_ADMIN_EMAIL y SEED_ADMIN_PASSWORD	Administrador inicial en una base vacía.
AUTH_SECRET	Firma de la sesión de NextAuth en ambos entornos del frontend.
NEXT_PUBLIC_GOOGLE_CLIENT_ID	Identificador del cliente OAuth de Google, incorporado al compilar.

Los flujos se disparan solo con un push a su rama. Para repetir un despliegue sin cambios de código, se vuelve a ejecutar la última ejecución exitosa desde la pestaña Actions del repositorio, con la opción Re-run all jobs.

6.6 Configuración por Entorno

La API lee su configuración de appsettings.json y de las variables de entorno, que tienen precedencia. La tabla lista las claves con los valores que corresponden a cada entorno; los valores sensibles se indican solo por su propósito.

Clave	Producción	Prueba	Propósito
ASPNETCORE_ENVIRONMENT	Production	Production	Swagger solo se habilita en Development.
Webpay:Provider	Real	Real	Fake usa un simulador en memoria, solo para pruebas automatizadas.
Webpay:Environment	Production	Integration	Ambiente de Transbank.
Webpay:ReturnUrl	https://www.kinefitchile.com/confirmacion	https://test.kinefitchile.com/confirmacion	Retorno desde Webpay.
Webpay:MontoAnticipo	10000	10000	Anticipo en pesos.
Webpay:ExpiracionMinutos	10	10	Plazo para completar el pago.
Webpay:IntervaloExpiracionSegundos	60	60	Frecuencia del proceso de expiración.
CORS:AllowedOrigins	https://www.kinefitchile.com y https://kinefitchile.com	https://test.kinefitchile.com	Orígenes que pueden llamar a la API desde el navegador.

Clave	Producción	Prueba	Propósito
Red:ProxiesConfiables	Pasarela de la red de Docker del contenedor	Pasarela de kinefit-test-network	Proxies cuyas cabeceras X-Forwarded se aceptan.
Frontend:BaseUrl	https://www.kinefitchile.com	https://test.kinefitchile.com	Base de los enlaces de firma.
Adjuntos:RutaBase	/data/adjuntos_clinicos	/data/adjuntos_clinicos_test	Carpeta de archivos.
Jwt:Issuer, Jwt:Audience	KineFit, KineFit-Users	KineFit, KineFit-Users	Emisor y audiencia.
Jwt:ExpirationMinutes	1440	1440	Vigencia de los tokens.
EmailConfiguration:From	Remitente del dominio verificado	Igual que producción	Remitente de los correos.
Imagenes:MaxSizeBytes	26214400	26214400	Tamaño máximo de una imagen del sitio.
Imagenes:TransformationWidth	2560	2560	Ancho al que Cloudinary ajusta las imágenes.
Agenda:IntervaloGeneracionHoras	24	24	Frecuencia de la generación de agenda.
Agenda:HorizonteDias	30	30	Días hacia adelante con bloques generados.
Notificaciones:IntervaloProcesamientoSegundos	60	60	Frecuencia del envío de correos.
Notificaciones:AntelacionRecordatorioHoras	24	24	Antelación del recordatorio.

Las claves de Agenda y Notificaciones tienen esos valores por omisión en el código y solo es necesario declararlas para cambiarlos. Red:ProxiesConfiables debe contener la dirección desde la que nginx llega al contenedor: en la red por omisión de Docker es la pasarela 172.17.0.1, y en kinefit-test-network se obtiene con el siguiente comando:

```
docker network inspect kinefit-test-network --format '{{(index .IPAM.Config 0).Gateway}}'
```

Sin esa clave, la API ignora X-Forwarded-For y ve a todos los clientes con la misma IP, de modo que comparten los límites por IP y las firmas registran la IP de la pasarela.

El frontend recibe en ejecución AUTH_SECRET y NEXTAUTH_SECRET con la clave de sesión, AUTH_URL y NEXTAUTH_URL con su dominio público y AUTH_TRUST_HOST=true, porque corre detrás de nginx. NEXT_PUBLIC_API_URL apunta a https://api.kinefitchile.com/api en producción y a https://api-test.kinefitchile.com/api en prueba.

> **Nota:** La API lee su configuración al arrancar. Después de editar /etc/kinefit/appsettings.json hay que reiniciar el contenedor con docker restart kinefit-api.

6.7 Servicios Externos

Cada servicio externo se describe con su función, su configuración y lo que ocurre si falla. La respuesta ante una falla prolongada está en el Plan de Contingencia de la sección 8.4.

6.7.1 Transbank Webpay Plus

Cobra el anticipo de la reserva web. La integración usa TransbankSDK 7.2.0 desde TransbankWebpayService, con las operaciones de creación y confirmación de la transacción. Webpay:Environment elige entre el ambiente de integración, con tarjetas de prueba, y el de producción. Las devoluciones no están automatizadas: se hacen desde el portal de comercios de Transbank. Si Transbank no responde al iniciar el pago, la API devuelve 502, no crea la transacción y la cita queda en PendientePago; la sección 7.4 explica cómo liberar sus bloques si el pago no se reintenta.

6.7.2 Google Identity

Identifica a los pacientes. El frontend carga Google Identity Services desde accounts.google.com/gsi/client con NEXT_PUBLIC_GOOGLE_CLIENT_ID, y la API valida el ID token con Google.Apis.Auth contra Google:ClientId. En la consola de Google Cloud, el cliente OAuth debe declarar como orígenes autorizados los dominios del sitio de producción y de prueba. La cabecera Cross-Origin-Opener-Policy: same-origin-allow-popups, definida en next.config.ts, es necesaria para la ventana emergente de Google.

6.7.3 Google Places

Proporciona las reseñas de Google que muestra el sitio. El administrador las sincroniza con POST /api/configuracion/sincronizar-google-reviews, usando el identificador del lugar guardado en landing_configs y la clave GooglePlaces:ApiKey. Si esa clave no está definida, se usa la guardada en landing_configs.google_api_key. Una falla deja visibles las reseñas ya sincronizadas.

6.7.4 Resend

Envía los correos al paciente. EmailService usa el cliente oficial de Resend con ResendAPIKey y el remitente EmailConfiguration:From, cuyo dominio debe estar verificado en Resend, y solo envía el HTML que recibe. El HTML lo arma NotificacionService con una plantilla por tipo de notificación, ubicada en src/Application/Templates/Email y copiada a la salida de la compilación y de la publicación. Una falla no afecta a las reservas: la notificación queda pendiente y se reintenta como se explica en la sección 4.6.

6.7.5 Cloudinary

Aloja las imágenes del sitio público, como las fotos de las profesionales y las imágenes de la portada. FileService las sube con CloudinaryDotNet, rechaza las que superan Imagenes:MaxSizeBytes y las ajusta a Imagenes:TransformationWidth de ancho. next.config.ts autoriza las imágenes remotas de res.cloudinary.com y de images.unsplash.com. Los documentos clínicos nunca se suben a Cloudinary.

6.7.6 Cloudflare R2

Guarda la copia externa de los respaldos diarios en el bucket kinefit-db-backups. El servidor accede con rclone, mediante el remoto r2 configurado para el usuario root. La sección 7.2 describe el respaldo y la verificación.

6.7.7 GitHub y GitHub Container Registry

Alojan el código de los dos repositorios, ejecutan los flujos de despliegue y guardan las imágenes en ghcr.io/jhoanck7. El servidor descarga las imágenes con el token temporal de cada ejecución. Si GitHub no está disponible, el sistema sigue funcionando, pero no se puede desplegar.

6.7.8 Hetzner Cloud

Provee el servidor virtual y el firewall. Su consola permite reiniciar el servidor, acceder a la consola de rescate y crear instantáneas del disco, que son un complemento útil antes de cambios mayores en el sistema operativo.

6.8 Entorno de Desarrollo Local

Para trabajar en el sistema se necesitan el SDK de .NET 10, Node.js 20, Docker y Git. Los pasos para levantar ambos proyectos son:

1. **Base de datos:** desde el repositorio del backend, levante PostgreSQL con docker compose up -d postgres. Queda disponible en localhost:5439.
2. **Configuración del backend:** copie api-dotnet/appsettings.example.json como appsettings.json, que está excluido del control de versiones, y entregue la cadena de conexión, la clave JWT y los datos del administrador inicial como variables de entorno.
3. **Backend:** ejecute dotnet run --project api-dotnet. La API escucha en http://localhost:5147, aplica las migraciones, siembra los datos de demostración y publica Swagger en /swagger.
4. **Frontend:** copie .env.example como .env.local, defina NEXT_PUBLIC_API_URL como http://localhost:5147/api, NEXT_PUBLIC_GOOGLE_CLIENT_ID y AUTH_SECRET, que se genera con npx auth secret. Luego ejecute npm install y npm run dev.

5. **Pagos:** use Webpay:Environment Integration con las credenciales de integración de Transbank.

```
export
ConnectionStrings__PostgreSQL="Host=localhost;Port=5439;Database=<base>;Use
rname=<usuario>;Password=<clave>"
export Jwt__Secret="<clave de al menos 32 caracteres>"
dotnet run --project api-dotnet
```

La base de desarrollo se siembra con un catálogo, las profesionales, pacientes de demostración, una cita de prueba y el administrador inicial. El sembrador corre en todos los entornos, pero solo inserta en las tablas vacías.

VII. Operación y Continuidad del Servicio

Este capítulo reúne lo necesario para operar el sistema día a día: los procesos automáticos, el respaldo, la recuperación ante desastres, la atención de incidentes y la gestión de cambios. Sigue las prácticas de gestión de servicios de ITIL 4: cada procedimiento indica qué observar, qué hacer y cómo confirmar que el servicio volvió a la normalidad.

7.1 Procesos en Segundo Plano

Tres procesos BackgroundService corren dentro del contenedor de la API. Arrancan con ella y se detienen con ella, por lo que la API debe ejecutarse en una sola instancia: una segunda instancia duplicaría la generación de agenda y el envío de correos.

Proceso	Frecuencia	Qué hace	Si se detiene
ExpiracionTransaccionesBackgroundService	Webpay:IntervaloExpiracionSegundos, 60 s	Expira las transacciones Iniciado vencidas, pasa sus citas a Expirada y libera los bloques.	Los bloques de pagos abandonados quedan ocupados hasta que el proceso vuelva a correr.
GeneracionAgendaBackgroundService	Al arrancar y cada Agenda:IntervaloGeneracionHoras, 24 h	Mantiene generados los bloques de los próximos Agenda:HorizonteDias días.	El horizonte deja de avanzar y el sitio ofrece cada día menos fechas.
NotificacionesBackgroundService	Notificaciones:IntervaloProcesamientoSegundos, 60 s	Encola recordatorios y envía los correos pendientes con reintentos.	Los correos se acumulan como pendientes y salen al reanudarse.

Los procesos registran su actividad y sus errores en el registro del contenedor. El proceso de expiración recorre transacciones, de modo que una cita web cuya transacción nunca llegó a crearse no la libera ese proceso; el runbook de la sección 7.4 cubre ese caso.

7.2 Respaldo y Verificación

El respaldo diario lo ejecuta el cron del usuario root a las 03:00 UTC, que en Chile corresponde a la medianoche en horario de verano y a las 23:00 en horario de invierno:

```
0 3 * * * /etc/kinefit/backups/backup-db.sh >>
/etc/kinefit/backups/cron.log 2>&1
```

El guion instalado en el servidor es la copia de scripts/backup-db.sh del repositorio del backend con los valores reales del contenedor, el usuario y la base. La Figura VII.1 muestra su secuencia y la de la verificación.

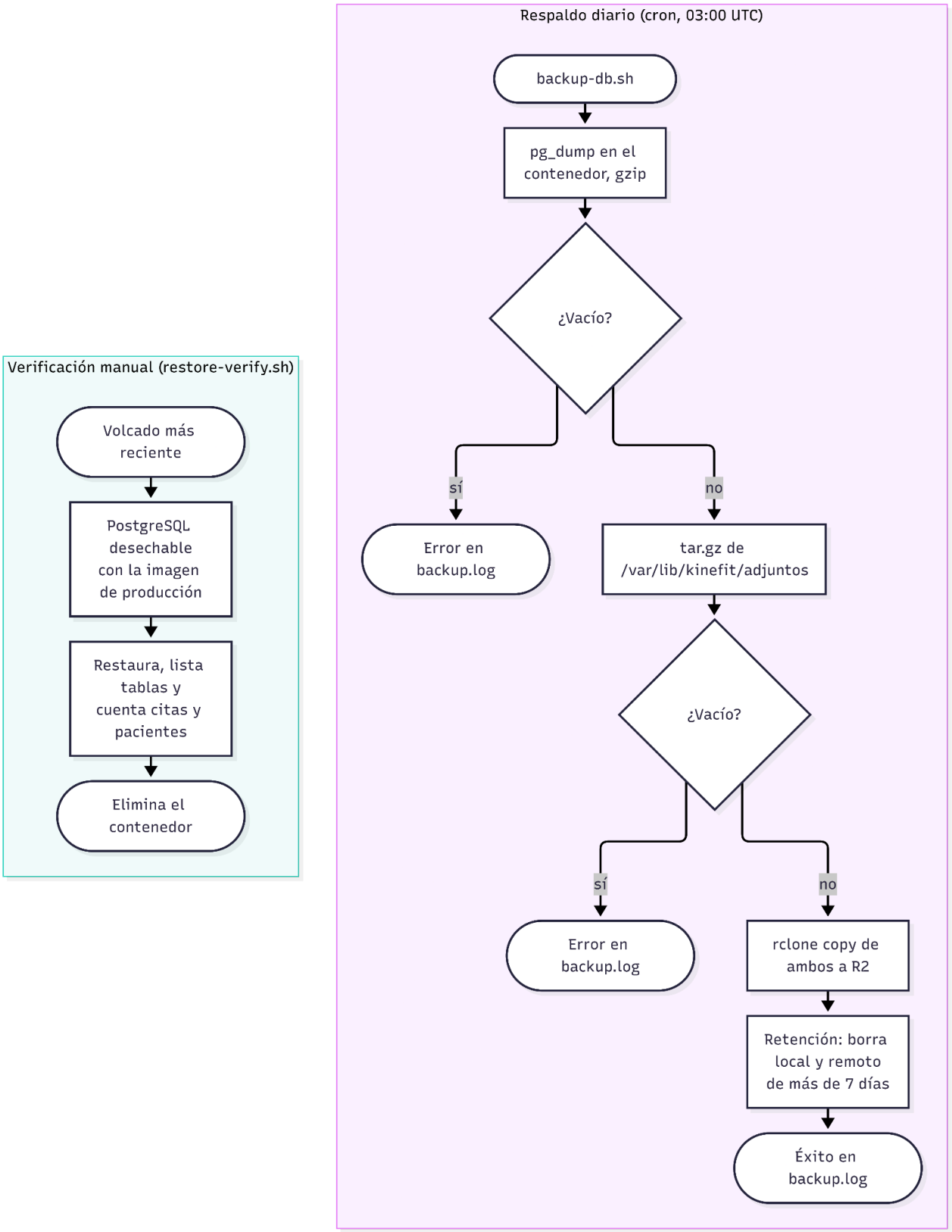


Figura VII.1 Respaldo diario y verificación de la restauración

- **Base de datos:** vuelca la base con pg_dump dentro de kinefit-postgres-dev y lo comprime como kinefit_<fecha>.sql.gz.

- **Archivos:** empaqueta /var/lib/kinefit/adjuntos como adjuntos_<fecha>.tar.gz. Incluye adjuntos clínicos, PDF firmados, escaneos y plantillas en PDF.
- **Copia externa:** sube ambos archivos con rclone al bucket kinefit-db-backups de Cloudflare R2.
- **Retención:** elimina los archivos de más de siete días, en /etc/kinefit/backups y en R2.
- **Registro:** anota el resultado en /etc/kinefit/backups/backup.log y se detiene con error si un archivo queda vacío.

scripts/restore-verify.sh comprueba que el último volcado sirve: lo restaura en un PostgreSQL desechable con la misma imagen de producción, lista las tablas, cuenta citas y pacientes y elimina el contenedor, sin tocar producción. Conviene ejecutarlo una vez al mes y después de cada migración importante.

> **Nota:** Los respaldos no incluyen /etc/kinefit/appsettings.json, /etc/kinefit-test/appsettings.json ni la configuración de nginx. Esos archivos deben tener una copia segura fuera del servidor, porque la recuperación de la sección 7.3 los necesita.

7.3 Plan de Recuperación ante Desastres

Objetivo	Valor	Fundamento
RPO, pérdida máxima de datos	24 horas	Un respaldo diario de la base y de los archivos.
RTO, tiempo máximo de recuperación	Menos de 2 horas	Arranque en frío sobre un servidor nuevo, según los pasos del escenario A.

Requisitos previos: acceso a Hetzner Cloud, a los dos repositorios de GitHub con permiso para editar secretos, a Cloudflare R2 y al proveedor de DNS de kinefitchile.com, y la copia segura de los archivos de configuración.

> **Nota:** Nunca arranque la API de producción contra una base vacía antes de restaurar el volcado. El sembrador insertaría el catálogo, pacientes de demostración y una cita de prueba, y habría que borrar la base y restaurar de nuevo.

Escenario A, pérdida del servidor: se recupera el sistema completo en un servidor nuevo.

1. **Servidor (10 min):** cree un servidor CX33 con Ubuntu 24.04, agregue la clave SSH de despliegue al usuario de VPS_USERNAME y aplíquele kinefit-firewall.
2. **Software (15 min):** instale Docker, nginx, Certbot y rclone, y configure el remoto r2 de rclone para root.
3. **DNS y GitHub (10 min):** apunte los registros de kinefitchile.com, www, test, api y api-test a la IP nueva y actualice el secreto VPS_IP en los dos repositorios.

4. **Configuración (5 min):** restaure /etc/kinefit/appsettings.json y /etc/kinefit-test/appsettings.json desde la copia segura.
5. **Base de datos (15 min):** clone el backend en /opt/kinefit-backend, levante la base con docker compose up -d postgres, descargue el último volcado y restáurelo con los comandos de abajo.
6. **Archivos (10 min):** descargue el último adjuntos_<fecha>.tar.gz y extráigalo en /var/lib/kinefit.
7. **nginx y certificados (15 min):** recree los bloques server de la sección 6.4 y emita los certificados con certbot --nginx.
8. **Aplicación (15 min):** en la pestaña Actions de cada repositorio, vuelva a ejecutar el último despliegue exitoso de main y del entorno de prueba.
9. **Respaldo (5 min):** copie el guion de respaldo en /etc/kinefit/backups con sus valores y reinstale la línea de cron.
10. **Verificación (10 min):** inicie sesión en el panel, consulte la agenda, abra la disponibilidad en el sitio y revise docker logs kinefit-api.

```
rclone lsf r2:kinefit-db-backups/ | sort
rclone copy r2:kinefit-db-backups/<archivo> /etc/kinefit/backups/
gunzip -c /etc/kinefit/backups/kinefit_<fecha>.sql.gz | \
  docker exec -i kinefit-postgres-dev psql -U <usuario> -d <base>
tar -xzf /etc/kinefit/backups/adjuntos_<fecha>.tar.gz -C /var/lib/kinefit
```

Escenario B, datos dañados o borrados: se restaura la base en el mismo servidor.

1. **Detener la escritura:** docker stop kinefit-api, para que nadie escriba durante la restauración.
2. **Conservar el estado actual:** haga un volcado de la base dañada con pg_dump, por si se necesita revisar qué ocurrió.
3. **Recrear la base:** elimine y cree de nuevo la base con dropdb y createdb dentro del contenedor.
4. **Restaurar:** descargue de R2 el volcado anterior al daño y restáurelo con psql como en el escenario A.
5. **Reanudar y verificar:** docker start kinefit-api; la API aplica las migraciones que falten y el sembrador no inserta nada. Revise las citas del día e informe qué ventana de datos se perdió.

7.4 Runbook de Incidentes

La tabla relaciona los síntomas más probables con su causa y los comandos para diagnosticarlos y resolverlos. Los comandos se ejecutan en el servidor como root. Todo incidente debe anotarse con su fecha, síntoma, causa y solución.

Síntoma	Causa probable	Diagnóstico y solución
Un adjunto grande falla con 413.	client_max_body_size de nginx menor que 30M en el dominio de la API.	grep -rn client_max_body_size /etc/nginx/sites-enabled/; fije 30M en el bloque del dominio; nginx -t && systemctl reload nginx.
El sitio o la API responden 502.	El contenedor está detenido o reiniciándose.	docker ps -a --filter name=kinefit; docker logs --tail 200 kinefit-api; si la API no arranca, el registro indica el secreto faltante o la migración que falló; docker restart <contenedor>.
Un paciente pagó, pero su cita figura Expirada.	Pago aprobado por Transbank después de que la transacción expiró.	docker logs kinefit-api 2>&1 | grep -i "devolución"; busque la orden KF-<cita>-<segundos> en el portal de Transbank, anule el cobro y contacte al paciente para reagendar. Revise el registro el mismo día: se pierde al recrear el contenedor.
Un bloque sigue ocupado por una cita web sin pago iniciado.	La reserva se creó, pero el inicio del pago falló o se abandonó antes de crear la transacción.	SELECT c.id FROM citas c LEFT JOIN transacciones t ON t.cita_id = c.id WHERE c.estado = 4 AND t.id IS NULL AND c.created_at < now() - interval '30 minutes'; en una transacción, devuelva sus bloques a estado 0, borre sus filas de citas_bloques y pase la cita a estado 3. Anote el cambio, porque no pasa por la auditoría.
Errores de conexión a la base en el registro.	Conexiones de PostgreSQL agotadas.	docker exec kinefit-postgres-dev psql -U <usuario> -d <base> -c "SELECT state, count(*) FROM pg_stat_activity GROUP BY state;"; termine las sesiones idle in transaction antiguas con pg_terminate_backend(pid) y reinicie la API para renovar su pool.
Los correos no llegan.	Clave de Resend inválida, dominio no verificado o correos Fallida.	SELECT estado, count(*) FROM notificaciones GROUP BY estado; revise detalle_fallo de las Fallida y el panel de Resend. Para reintentar una: estado = 0, intentos = 0 y proximo_intento_en = now().
El sitio no ofrece horas para una profesional.	Falta su plantilla horaria o no se generaron bloques.	Revise plantillas_horario de la especialista y ejecute Generar Agenda desde el panel o POST /api/agenda/generar.
Todo el personal recibe 401 SESION_INVALIDADA.	Se cambió Jwt:Secret o se invalidaron las sesiones.	Es el comportamiento esperado: cada usuario inicia sesión de nuevo.
Muchos usuarios reciben 429 a la vez.	Red:ProxiesConfiables vacía o incorrecta: todos comparten una IP.	docker network inspect bridge --format '{{(index .IPAM.Config 0).Gateway}}'; declare esa IP en Red:ProxiesConfiables y reinicie la API.
El navegador indica que el certificado venció.	La renovación automática de Certbot falló.	certbot certificates; systemctl status certbot.timer; certbot renew --dry-run; certbot renew y systemctl reload nginx.
Fallas de escritura o disco lleno.	Imágenes antiguas, registros o respaldos acumulados.	df -h /; docker system df; docker image prune -f; du -sh /etc/kinefit/backups /var/lib/kinefit/adjuntos; journalctl --vacuum-time=14d.

Síntoma	Causa probable	Diagnóstico y solución
No se generan consentimientos o el reenvío de enlace falla con 500.	Falta Frontend:BaseUrl o el servicio exige más de una plantilla de consentimiento.	docker logs kinefit-api 2>&1 | grep -i "documentos"; defina Frontend:BaseUrl y reinicie la API; deje una sola plantilla de consentimiento por servicio.
El sitio carga, pero la reserva falla con error de CORS en la consola.	El origen exacto, con su esquema, no está en CORS:AllowedOrigins.	Agregue el origen, por ejemplo https://kinefitchile.com, y reinicie la API.
No aparece el respaldo del día en R2.	Falla del guion, de rclone o de cron.	tail -n 20 /etc/kinefit/backups/backup.log /etc/kinefit/backups/cron.log; rclone lsf r2:kinefit-db-backups/ | tail; ejecute el guion a mano y revise su salida.

7.5 Gestión de Cambios y Reversión

Todo cambio llega a producción por Git. El recorrido es el siguiente:

1. El cambio se desarrolla en una rama propia y se prueba en local.
2. Se integra en dev, en el backend, o en test-production, en el frontend, lo que despliega el entorno de prueba en api-test.kinefitchile.com o test.kinefitchile.com.
3. Se verifica en el entorno de prueba, con Webpay en integración.
4. Se integra en main, lo que despliega producción.

Antes de integrar en main se revisa la lista de control: la suite de pruebas pasa con dotnet test, el frontend pasa npm run lint y npm run type-check, cada migración nueva fue revisada y probada en el entorno de prueba, y el respaldo del día existe en R2.

Para revertir el backend se usa la imagen etiquetada con el sha del commit anterior. Se vuelve a crear el contenedor con los mismos parámetros del flujo de producción, reemplazando solo la etiqueta:

```
docker rm -f kinefit-api
docker run -d --name kinefit-api --restart always -p 127.0.0.1:5147:8080 \
  --add-host=host.docker.internal:host-gateway \
  -v /etc/kinefit/appsettings.json:/app/appsettings.json \
  -v /var/lib/kinefit/adjuntos:/data/adjuntos_clinicos \
  -e ConnectionStrings__PostgreSQL="<cadena>" \
  ghcr.io/jhoanck7/kinefit-backend-api:<sha anterior>
```

El frontend solo publica la etiqueta latest, por lo que se revierte con git revert del commit y un push a main. Las migraciones no se revierten solas: si un cambio de esquema debe deshacerse, se escribe una migración compensatoria o se restaura el respaldo según el escenario B.

VIII. Calidad, Evolución y Mantenimiento

8.1 Pruebas Automatizadas del Backend

El proyecto api-dotnet.Tests contiene las pruebas del backend, escritas con xUnit 2.9.2. La mayoría son de extremo a extremo: KineFitWebApplicationFactory levanta la API completa con Microsoft.AspNetCore.Mvc.Testing sobre un PostgreSQL 16 real y efímero creado con Testcontainers.PostgreSql 4.1.0. Controladores, servicios, Entity Framework Core, migraciones y sembrador corren igual que en producción; solo se reemplazan los bordes con terceros: Google, Resend, Cloudinary y Webpay, este último con Webpay:Provider = Fake.

La fábrica entrega los secretos por variables de entorno, igual que el servidor, y ejecuta la API en el entorno Testing, que desactiva los límites de peticiones. La paralelización está desactivada porque esas variables son globales al proceso. La suite tiene 25 clases con 137 métodos de prueba, que suman 220 casos al expandir las pruebas parametrizadas.

```
dotnet test api-dotnet.Tests
```

Nota: La prueba Fase8Tests.UnBloqueoConMostrarEnSitio_ExponeElMotivoPublico_NuncaElMotivoInterno usa una fecha fija a 730 días y bloquea las 09:00. Cuando esa fecha cae en sábado o domingo, la prueba falla porque el fin de semana el centro abre a las 10:00 y ese bloque no existe. Se trata de una limitación de la prueba, no del sistema.

Clase	Qué verifica
AgendaPanelTests	Agenda del panel: reserva, confirmación y atención; bloqueos; aislamiento entre especialistas; competencia entre una cita web y una manual.
AuditoriaTests	Una fila de auditoría por transición con el actor correcto; inmutabilidad.
CalculoRepartoTests	Aritmética del reparto con y sin IVA en la tasa y con descuento.
CobroSinCitaRaceTests	Pago aprobado justo después de expirar: la cita no se confirma y queda advertido.
ContenidoEImagenTests	Subida de imágenes, comisión mixta de terminales y catálogo.
ContenidoInstitucionalTests	Lectura pública del contenido y escritura exclusiva del administrador.
DocumentoClinicoTests	Convivencia de tipos de documento en una cita y unicidad por tipo; validación de PDF.
DocumentoPacienteTests	Tokens vencidos y usados; firma profesional; generación sin duplicados.
EmpresaServiceEsVigenteTests	Vigencia de convenios en sus cinco casos de borde.
EspecialistaServicioNaMTests	Habilitaciones entre especialistas y servicios.
EstadoCitaTransicionesEndpointTests	Expiración de la sesión de pago y transiciones a Atendida y NoAsistida.

Clase	Qué verifica
Fase8Tests	Vía de confirmación, contadores del paciente, impacto de cancelación y verificación de RUT.
FichaClinicaTests	Fichas sobre citas atendidas, adjuntos y rechazo de tokens de paciente.
FlujoReservaWebTests	Reserva por servicio, fecha, hora y especialista; mis citas; servicios inactivos.
GeneracionAgendaTests	Idempotencia, plantillas acotadas, colación y conflictos.
IdentidadPersonalTests	Cuentas del personal, invalidación de sesiones y trazas de lectura.
MaquinaEstadosCitaTests	Las 42 combinaciones de estados: solo prosperan las ocho transiciones.
MigracionEstadoCitaTests	Migración de estados sobre una base con datos previos.
NotificacionesTests	Encolado, envío, reintentos con espera creciente y nota al paciente.
OcupacionMultiBloqueTests	Servicios de 30 y 60 minutos, colación y solapamientos.
PacientesAdminTests	Alta manual de pacientes, RUT obligatorio, único y no editable, y baja lógica.
PersonalAuthAndScopingTests	Inicio de sesión del personal y acotamiento por especialista.
ReservaFlowTests	Flujo completo desde el inicio de sesión hasta el pago confirmado.
VentasYComisionesTests	Ventas, terminales, comisiones vigentes y repartos.

8.2 Calidad del Frontend

El frontend usa TypeScript en modo estricto y un conjunto de herramientas de calidad que se ejecutan con los scripts de package.json:

Script	Herramienta	Qué comprueba
npm run lint	ESLint 9 con eslint-config-next	Reglas de Next.js y React, orden de importaciones y formato.
npm run type-check	TypeScript 5.9	Tipos de todo el proyecto, sin emitir archivos.
npm run format:check	Prettier 3	Formato del código.
npm run knip	knip 6	Archivos, exportaciones y dependencias sin uso.

lint-staged está configurado para corregir y formatear los archivos preparados para un commit, con cero advertencias permitidas. Las mismas comprobaciones forman parte de la lista de control de la sección 7.5.

8.3 Plan de Hardening y Evolución Continua

El sistema cumple sus objetivos de calidad y el plan siguiente eleva su robustez operativa. Cada mejora es independiente y puede incorporarse en cualquier orden, aunque el orden propuesto prioriza las que protegen el despliegue y los pagos.

N°	Mejora	Qué cambia	Beneficio
1	Pruebas antes de desplegar	Los flujos de main ejecutan dotnet test y, en el frontend, npm run lint y npm run type-check, y solo despliegan si pasan.	Ningún cambio llega a producción sin pasar la suite.
2	Despliegue con verificación de arranque y reversión automática	El flujo levanta el contenedor nuevo, comprueba que siga en ejecución y sin errores de arranque, y si falla vuelve a levantar la imagen anterior identificada por su sha.	Una imagen defectuosa no deja el servicio caído.
3	Registro persistente de pagos aprobados fuera de plazo	Un pago aprobado cuyo reclamo ganó la expiración se guarda en la base y se muestra en el panel.	Las devoluciones pendientes no dependen del registro del contenedor.
4	Mensajes genéricos para errores internos	La respuesta 500 entrega un mensaje genérico y un identificador de seguimiento; el detalle queda solo en el registro.	El cliente no ve detalles internos y el soporte ubica el error por su identificador.
5	Puertos publicados solo en la interfaz local	Todos los contenedores publican su puerto en 127.0.0.1.	Una segunda capa de contención además del firewall de Hetzner.
6	Imagen del frontend con salida standalone	El Dockerfile copia .next/standalone y arranca con node server.js.	Una imagen más liviana y un arranque más rápido.
7	Protección del endpoint de revalidación	POST /api/revalidate exige un secreto compartido con la API.	Solo la API puede regenerar la portada.
8	Rotación periódica de credenciales	Calendario de rotación para la base, Jwt:Secret, AUTH_SECRET, Webpay, Resend, Cloudinary, R2 y la clave SSH.	Una credencial expuesta tiene una vida útil acotada.
9	Vigencia de sesión informada igual a la del token	La respuesta de inicio de sesión informa el vencimiento real del JWT, según Jwt:ExpirationMinutes.	El frontend conoce con exactitud cuándo vence la sesión.

8.4 Plan de Contingencia

El plan indica cómo mantener la atención cuando falla una dependencia, hasta que el servicio se normalice. La pérdida del servidor se trata en el Plan de Recuperación ante Desastres de la sección 7.3.

Evento	Impacto	Respuesta de contingencia
Transbank no disponible	No se pueden pagar anticipos.	Desactivar las reservas en línea desde la configuración del sitio y atender por reserva manual.

Evento	Impacto	Respuesta de contingencia
Resend no disponible	No salen correos.	Los correos se reintentan solos; los que queden Fallida se reencolan al normalizarse y, si urge, se contacta al paciente por WhatsApp.
Google Identity no disponible	Los pacientes no pueden iniciar sesión.	Desactivar las reservas en línea y atender por reserva manual.
Cloudinary no disponible	El sitio muestra imágenes rotas.	Sin acción en el sistema: la reserva y el panel siguen operando.
Cloudflare R2 no disponible	El respaldo del día no sale del servidor.	Los respaldos locales de siete días siguen disponibles; verificar la subida al normalizarse.
GitHub no disponible	No se puede desplegar.	Postergar los cambios; producción sigue operando.
Credencial expuesta	Riesgo de acceso indebido.	Rotar de inmediato la credencial en su proveedor, actualizarla en el servidor o en GitHub, reiniciar el contenedor afectado y revisar la auditoría del período.
Falla de una migración al desplegar	La API no arranca.	Revertir a la imagen anterior según la sección 7.5 y, si el esquema quedó a medias, restaurar según el escenario B.

8.5 Inventario de Dependencias y Licencias

El inventario usa los identificadores de licencia de SPDX. Las versiones son las declaradas en los proyectos; en el frontend, las resueltas en package-lock.json.

Paquete NuGet	Versión	Licencia SPDX
Bogus	35.6.5	MIT
CloudinaryDotNet	1.29.2	MIT
EFCore.NamingConventions	10.0.1	Apache-2.0
Google.Apis.Auth	1.68.0	Apache-2.0
Microsoft.AspNetCore.Authentication.JwtBearer	10.0.0-preview.2.25120.7	MIT
Microsoft.EntityFrameworkCore, .Design y .Tools	10.0.9	MIT
Npgsql.EntityFrameworkCore.PostgreSQL	10.0.2	PostgreSQL
Resend	0.1.6	MIT
SixLabors.ImageSharp	3.1.12	LicenseRef-SixLabors-Split-1.0
Swashbuckle.AspNetCore	6.6.2	MIT
TransbankSDK	7.2.0	BSD-3-Clause
Microsoft.NET.Test.Sdk (pruebas)	17.12.0	MIT
xunit (pruebas)	2.9.2	Apache-2.0

Paquete NuGet	Versión	Licencia SPDX
xunit.runner.visualstudio (pruebas)	2.8.2	Apache-2.0
Microsoft.AspNetCore.Mvc.Testing (pruebas)	10.0.9	MIT
Microsoft.EntityFrameworkCore.Relational (pruebas)	10.0.9	MIT
Testcontainers.PostgreSql (pruebas)	4.1.0	MIT

Bogus está declarado en el proyecto y no se usa en el código. SixLabors.ImageSharp se distribuye con la Six Labors Split License 1.0, que permite su uso bajo Apache-2.0 en las condiciones que define la propia licencia; fuera de ellas exige una licencia comercial, por lo que su uso debe revisarse si cambian las condiciones del proyecto.

Paquete npm	Versión	Licencia SPDX
@hookform/resolvers	3.10.0	MIT
@tanstack/react-query	5.101.4	MIT
@vercel/speed-insights	2.0.0	Apache-2.0
axios	1.19.0	MIT
class-variance-authority	0.7.1	Apache-2.0
clsx	2.1.1	MIT
jwt-decode	4.0.0	MIT
libphonenumber-js	1.13.13	MIT
lucide-react	1.31.0	ISC
next	16.2.9	MIT
next-auth	5.0.0-beta.32	ISC
next-themes	0.4.6	MIT
pdf-lib	1.17.1	MIT
pdfjs-dist	6.3.289	Apache-2.0
radix-ui	1.6.7	MIT
react	19.2.4	MIT
react-dom	19.2.4	MIT
react-hook-form	7.85.0	MIT
shadcn	4.18.0	MIT
sonner	2.0.8	MIT

tailwind-merge	3.6.0	MIT
tw-animate-css	1.4.0	MIT
zod	3.25.76	MIT
zustand	5.0.14	MIT
@tailwindcss/postcss (desarrollo)	4.3.3	MIT
@types/node (desarrollo)	20.19.43	MIT
@types/react (desarrollo)	19.2.17	MIT
@types/react-dom (desarrollo)	19.2.3	MIT
eslint (desarrollo)	9.39.4	MIT
eslint-config-next (desarrollo)	16.2.9	MIT
eslint-config-prettier (desarrollo)	10.1.8	MIT
eslint-plugin-import (desarrollo)	2.32.0	MIT
eslint-plugin-prettier (desarrollo)	5.5.6	MIT
eslint-plugin-simple-import-sort (desarrollo)	14.0.0	MIT
knip (desarrollo)	6.32.2	ISC
lint-staged (desarrollo)	17.3.0	MIT
prettier (desarrollo)	3.9.6	MIT
tailwindcss (desarrollo)	4.3.3	MIT
typescript (desarrollo)	5.9.3	Apache-2.0
Imagen base	**Componente principal**	**Licencia SPDX**
mcr.microsoft.com/dotnet/sdk:10.0 y aspnet:10.0	.NET 10	MIT
node:20-alpine	Node.js 20	MIT
postgres:16-alpine	PostgreSQL 16	PostgreSQL

Glosario

Término	Definición
Anticipo	Pago de $10.000 que el paciente hace con Webpay Plus para asegurar una reserva web.
Bandeja de salida	Patrón en que los mensajes se guardan en la base dentro de la operación de negocio y un proceso separado los envía después. En KineFit es la tabla notificaciones.
Bloque horario	Unidad reservable de la agenda: 30 minutos de una especialista en una fecha.
C4	Modelo para describir una arquitectura en cuatro niveles: contexto, contenedores, componentes y código.
Cadena de bloques	Secuencia de bloques consecutivos de la misma especialista y fecha, en que cada uno empieza donde termina el anterior.
Claim	Dato incluido en un JWT, como el rol o el identificador del usuario.
CORS	Mecanismo del navegador que permite o bloquea que un sitio llame a una API de otro dominio.
Huella	Hash SHA-256 del contenido congelado de un documento, usado para comprobar que no cambió.
Idempotente	Operación que produce el mismo resultado aunque se ejecute varias veces.
Interceptor	Componente de Entity Framework Core que actúa antes y después de guardar cambios.
JWT	JSON Web Token: credencial firmada que la API emite al iniciar sesión y que el cliente envía en cada petición.
Migración	Cambio versionado del esquema de la base, generado por Entity Framework Core.
PBKDF2	Función de derivación de claves que se usa para guardar contraseñas de forma segura.
Política de autorización	Regla con nombre que un endpoint exige, como SoloPersonal.
Proxy inverso	Servidor que recibe las peticiones de Internet y las reenvía a la aplicación; en KineFit, nginx.
Reclamo atómico	Actualización condicionada al estado actual que garantiza que solo una operación concurrente gane.

Término	Definición
RPO	Objetivo de punto de recuperación: pérdida máxima de datos aceptable, medida en tiempo.
RTO	Objetivo de tiempo de recuperación: plazo máximo para restablecer el servicio.
Sembrador	DataSeeder: código que aplica las migraciones y carga los datos iniciales en tablas vacías.
SPDX	Estándar para identificar licencias y componentes de software.
TPH	Herencia de tabla por jerarquía: varias clases se guardan en una sola tabla con una columna discriminadora.
UTC	Tiempo universal coordinado, la referencia horaria con que se guardan las marcas de tiempo.

Referencias Normativas

- **arc42.** Plantilla para la documentación de arquitecturas de software. Gernot Starke y Peter Hruschka. https://arc42.org
- **Modelo C4.** Simon Brown, The C4 model for visualising software architecture. https://c4model.com
- **ISO/IEC/IEEE 42010:2022.** Software, systems and enterprise: Architecture description.
- **OWASP ASVS 4.0.3.** Application Security Verification Standard, versión 4.0.3, nivel 1. OWASP Foundation. https://owasp.org/www-project-application-security-verification-standard
- **ISO/IEC 11179.** Information technology: Metadata registries (MDR), en particular la parte 4, Formulation of data definitions.
- **SPDX 2.3 e ISO/IEC 5962:2021.** Software Package Data Exchange y su lista de licencias. https://spdx.dev
- **ITIL 4.** Marco de buenas prácticas para la gestión de servicios de TI. AXELOS.
- **Mermaid.** Lenguaje de diagramas como texto. https://mermaid.js.org
- **PlantUML.** Lenguaje de diagramas UML como texto. https://plantuml.com